

אבטחת מידע

ספר הקורס המלא

תכנית הלימודים - מגמת תקשוב, משרד החינוך
9 פרקים · חומר עיון, סיפורים, תרגילים ושאלות בסגנון בגרות (שאלון 735001)

תוכן העניינים

2	מבוא: איך להשתמש בחומר הזה
7	תזכורת רשתות תקשורת
12	פרק 1 - מבוא לאיומי רשת חדשים
24	פרק 2 - אבטחת אביזרי רשת
36	פרק 3 - מודל ה-AAA
45	פרק 4 - חומות אש ברשת הבינונית והרחבה
57	פרק 5 - מניעת חדירה לרשת המקומית והרחבה (IDS / IPS)
66	פרק 6 - אבטחת הרשת המקומית (LAN Security)
75	פרק 7 - מערכות הצפנה וקריפטולוגיה
84	פרק 8 - מערכות VPN
92	פרק 9 - ניהול אבטחת רשת מתקדם

מבוא: איך להשתמש בחומר הזה

קראו את הפרק הזה לפני שמתחילים ללמוד

מה יש כאן

החומר בנוי משני חלקים שמשלימים זה את זה:

- **מדריך למורה (ה-PDF הזה)** – פרק לכל פרק בתכנית הלימודים. כל פרק כולל: מטרות ותכנון שעות, את החומר העיוני עצמו בעומק שמאפשר לענות על שאלות של תלמידים, מדריך פקודות CLI, תיבות "שאלת תלמיד נפוצה" עם תשובה מוכנה, תיבות "טעות נפוצה", תיבות "טיפ להוראה", ושאלות בסגנון בגרות עם פתרון מלא.
- **מצגות (תיקית slides)** – קובץ HTML אחד לכל פרק, פותחים בדפדפן ומקרנים. עובד ללא אינטרנט. לחיצה על N פותחת הערות למורה בתחתית המסך (מה להגיד, איזו שאלה לשאול את הכיתה). לחיצה על F – מסך מלא. חיצים / רווח – מעבר שקף. בשקפי "שאלה" התשובה מופיעה רק בלחיצה נוספת – כך אפשר לתת לכיתה לנסות קודם.

טיפ: סדר עבודה מומלץ לכל שבוע

1. קראו את פרק המדריך הרלוונטי (30-60 דקות). 2. עברו על המצגת עם הערות המורה פתוחות (N).
3. הריצו בעצמכם את פקודות ה-CLI ב-Packet Tracer לפני השיעור – תלמידים ישאלו "מה קורה אם..." ועדיף שכבר ראייתם. 4. אחרי השיעור – תנו לתלמידים את שאלות "סגנון בגרות" מהמדריך כתרגול.

על תכנית הלימודים ועל שאלון הבגרות

תכנית הלימודים הרשמית (120 שעות: 96 עיוני + 24 מעשי) מבוססת על קורס CCNA Security של סיסקו מהדור הקודם. שימו לב לשלושה דברים:

1. **SDM / CCP הם כלים שיצאו משימוש**. התכנית מזכירה הרבה "הגדרה על ידי" SDM (ממשק גרפי של סיסקו לנתבים). SDM הוחלף ב-CCP וגם הוא הופסק. **שאלון הבגרות בודק אך ורק** CLI. לכן במדריך הזה ההגדרות הן ב-CLI, ואת SDM אנו מזכירים רק כמושג ("קיים גם ממשק גרפי").
2. **בתכנית הרשמית יש שגיאת העתקה**: רשימת הנושאים של פרק 3 (AAA) זהה לרשימה של פרק 2. במדריך הזה פרק 3 בנוי לפי המטרות של פרק 3 (מודל AAA, ACS, TACACS+, RADIUS) – זה גם מה שנשאל בבגרות.
3. **מחצית משאלון הבגרות (50 נקודות) היא "רשתות תקשורת"** – סאבנטים, DHCP, STP, OSPF, ניתוב סטטי, VLAN וכו'. החומר הזה אל נמצא בתכנית "אבטחת מידע" והוא נלמד בקורס הרשתות. במדריך הזה נגענו בו רק היכן שהוא נוגע ישירות לאבטחה (למשל STP בפרק 6, ACL בפרק 4, פקודות line vty בפרק 2). מומלץ לוודא שהתלמידים מגיעים עם רקע ב-CCNA 1-2.

תכנון שנתי – 30 שבועות, 4 שעות שבועיות

שבועות	פרק	שעות בתכנית	מה מכסים	מעשי
3-1	פרק 1 – מבוא לאיומי רשת	10	מושגי יסוד (CIA), אבולוציית האיומים, סוגי תוקפים, נזקות, שלבי תקיפה, DoS/DDoS, הנדסה חברתית, ברוט-פורס. שבוע 1: היכרות עם הקורס ומבחן רמה קצר ברשתות.	Wireshark / דמו phishing

שבועות	פרק	שעות בתכנית	מה מכסים	מעשי
6-4	פרק 2 - אבטחת אביזרי רשת	12	הקשחת נתב: enable, סיסמאות, secret, SSH, רמות הרשאה, banner, syslog, NTP, SNMP, AutoSecure, OOB.	:Packet Tracer הקשחת נתב + SSH
9-7	פרק 3 - מודל AAA	14	Authentication/Authorization/Accounting, AAA מקומי, RADIUS מול TACACS+, ACS/ISE, פקודות AAA.	:Packet Tracer שרת RA- + DIUS/TACACS
12-10	פרק 4 - חומות אש	13	ACL סטנדרטי/מורחב, wildcard מיקום, ACL מבוסס זמן-/reflexive/dy, namic סוגי חומות אש, CBAC, ZPF.	Packet Tracer: ACL + ZPF
16-13	פרק 5 - IDS / IPS	14	IDS מול IPS, חתימות, HIPS מול NIPS, אזעקות (true/false positive), IOS IPS, ניטור ופתרון תקלות. שבוע 16: חזרה + מבחן מחצית.	Packet Tracer: IOS IPS
19-17	פרק 6 - אבטחת הרשת המקומית	13	התקפות שכבה 2: MAC flooding, VLAN hopping/DTP, STP, DHCP/ARP spoofing. הגנות: port security, BPDU guard, DHCP snooping, DAI, storm control, SPAN. NAC, IronPort, VoIP/SAN, Evil Twin.	Packet Tracer: port security + BPDU guard

שבועות	פרק	שעות בתכנית	מה מכסים	מעשי
23-20	פרק 7 - הצפנה וקריפטולוגיה	14	היסטוריה (קיסר, ויז'נר), CIA + הצפנה, גיבוב (MD5/SHA), HMAC, סימטרי (DES/3DES/AES), א-סימטרי (RSA/DH), חתימה דיגיטלית, PKI.	תרגול: צופן קיסר, hash בפייטון/אונליין
26-24	פרק 8 - VPN	13	סוגי VPN, GRE, IPsec (AH/ESP, IKE, DH), site-to-site ב-VPN, CLI, SSL (ASA). ציוד.	Packet Tracer: GRE + IPsec site-to-site
29-27	פרק 9 - ניהול אבטחה מתקדם	14	ניהול סיכונים, סוגי בקורות (מנהלי/פיזי/לוגי), בדיקות חדירה, Nmap/Nessus, BCP/DRP, SDLC, מדיניות ואתיקה.	Nmap במעבדה מבודדת
30	חזרה לבגרות	3	פתרון שאלון לדוגמה בתנאי אמת, חזרה על פקודות.	

מיפוי שאלון הבגרות (חלק ב' - אבטחת מידע) לפרקי הקורס

ניתחנו את שאלון 735001 (אביב תשפ"ג). כך מתפלגים נושאי חלק ב' (50 נקודות) בין הפרקים - זה אומר לכם על מה לשים דגש:

נושא שנשאל	פרק	סוג שאלה
זיהוי הודעת phishing / הנדסה חברתית	1	רב-ברירה על תמונה
סוגי תוקפים: Script kiddies, Hactivist, Insider פשע מאורגן	1	התאמה
Brute force (מילון), Buffer overflow, DoS, Port redirection	1	רב-ברירה
הפקת מפתחות RSA - משמשים SSH-ל	2	רב-ברירה
שלושת שירותי AAA (הגדרות) RADIUS מול TACACS+	3	התאמה
(הצפנה, UDP/TCP, הרשאות)	3	נכון/לא נכון
הפקודה aaa new-model	3	השלמת פקודה
ACL סטנדרטי לחסימת רשת; מיקום ACL וכיוון (in/out)	4	רב-ברירה
IDS מול IPS	5	התאמה

נושא שנשאל	פרק	סוג שאלה
MAC table נגד Port security VLAN-overflow; DTP hopping; BPDU Guard; Evil Twin	6	רב-ברירה
Diffie-Hellman, צופן קיסר mod 26, מפתח ציבורי/פרטי, AES מול hash (סודיות)	7	רב-ברירה
IPsec - פועל על TCP/IP	8	רב-ברירה
בקורות מנהליות / פיזיות / לוגיות; Nmap	9	התאמה / רב-ברירה

פתרון מלא - חלק ב' של שאלון הדוגמה (735001), תשפ"ג

כדי שתוכלו לפתור עם התלמידים בסוף השנה. ההסברים מופיעים בהרחבה בפרקים.

שאלה (20) 4 נק'

- א. הודעת "UPS - Last Call - Confirm Now" - תשובה 4: Social Engineering (phishing). סימנים: שולח מ-hotmail.com ולא מדומיין UPS, דחיפות ("Last Call"), כפתור לאישור פרטים.
- ב. זיהוי ואימות משתמשים = Authentication; ניהול הרשאות = Authorization; רישום למעקב = Accounting.
- ג. ניטור + חסימה אוטומטית = IPS; ניטור + התראה בלבד = IDS.
- ד. חסימת 20.20.20.0/24 ב-ACL סטנדרטי: תשובה 2: `access-list 10 deny 20.20.20.0 0.0.0.255` (מספר 1-99 = סטנדרטי; wildcard 0.0.0.255).
- ה. RADIUS 1. מצפין רק את הסיסמה - נכון. RADIUS 2. מבצע אימות ולא מתייחס להרשאות - נכון (RA-DIUS משלב authentication+authorization בתהליך אחד ואינו מאפשר הרשאה נפרדת לכל פקודה). TACACS 3. משתמש רק ב-UDP - לא נכון. TACACS 4. (TCP 49) + מספק שירות AAA - נכון.
- ו. הסכמה על מפתח פרטי בערוץ ציבורי - Diffie-Hellman: 2.

שאלה (9) 5 נק'

- א. `R1(config)# aaa new-model`
- ב. מפתחות RSA - 2: ניתן להשתמש בהם לצורך חיבור SSH (ללא איפוס).
- ג. modulo 26 - 4: מספר האפשרויות (האותיות) בשפה האנגלית; ה-"mod" ממגלגל חזרה מ-Z ל-A.
- ד. הצפנה במפתח ציבורי $\Rightarrow$ פענוח ב-1: מפתח פרטי.
- ה. סודיות (confidentiality) של מידע מוצפן - AES 3: MD5/HASH = שלמות; WPA-2 הוא פרוטוקול, לא אלגוריתם).

שאלה (12) 6 נק'

- א. IPsec נועד לאבטח את חבילת הפרוטוקולים TCP/IP: 2: (שכבה. 3)
- ב. מנהלי = כתיבת מדיניות, הנחיות, נהלים, תקנים; פיזי = הגנה על חדר שרתים וארונות תקשורת; לוגי = רשימות גישה, סיסמאות, מערכות למניעת גישה.
- ג. Script kiddies = משתמש בכלי פריצה בלי להיות מודע לתהליכים; Hacktivist = תוקף מתוך אמונות ומניעים אידיאולוגיים; Insider = משתמש בגישה מורשית לצרכים זרים.
- ד. Nmap - 3: גילוי, ניתוח ובקרה ברשתות תקשורת (סריקת פורטים ומארחים).
- ה. Evil Twin - 1: נקודת גישה זדונית עם SSID זהה לנקודה חוקית.

שאלה (9) 7 נק'

1. א. ניחוש סיסמה בעזרת מילון - Brute force attack: 4 (התקפת מילון היא תת-סוג).
2. ב. port security - MAC table overflow: 1 על כל הממשקים שאינם trunk + הגבלת מספר כתובות MAC.
3. ג. השבתת DTP מונעת VLAN hopping: 3 (switch spoofing).
4. ד. BPDU Guard גלובלי - 3: **spanning-tree portfast bpduguard default** (תשובה 2 גם נכונה תחבירית לממשק בודד - **spanning-tree bpduguard enable** - אך התשובה המצופה היא 3).
5. ה. חסימת 192.168.2.0 ל-192.168.3.0 בלבד: 2 - **deny 192.168.2.0 permit any**, ומחילים out על G0/2 (הממשק שיוצא לרשת המוגבלת). סדר השורות קריטי: **permit any** קודם היה מבטל את ה-**deny**.

סביבת מעבדה מומלצת

- Cisco Packet Tracer (חינם דרך Cisco Networking Academy) - תומך ב: SSH, AAA עם RA-
port security, BPDU guard, DHCP snoop-, (בסיסי) IOS IPS, (חלקית) DIUS/TACACS+, ACL, ZPF
ing, GRE ו-IPsec site-to-site. זה מכסה כמעט את כל המעשי בקורס.
- Wireshark - להדגמת Telnet בטקסט גלוי מול SSH מוצפן (פרק 2), ולהצגת handshake של TLS (פרק 7).
- Nmap / Zenmap - רק ברשת מעבדה מבודדת ובאישור בית הספר (פרק 9). אף פעם לא על רשת בית הספר או האינטרנט.
- אתרי הדגמה: cryptii.com (צופן קיסר/ויז'נר), sha256algorithm.com (הדמיה של גיבוב).

חשוב - אתיקה ומשמעת

בקורס הזה מלמדים איך התקפות עובדות כדי לדעת להגן. הבהירו לתלמידים כבר בשיעור הראשון: הרצת סורקים, כלי פריצה או ניסיונות "לבדוק" את רשת בית הספר ללא אישור בכתב היא עבירה על חוק המחשבים (1995) - ותאמרו להם זאת במפורש. פרק 9 מקדיש לכך חלק.

תזכורת רשתות תקשורת

רענון לקראת חלק א' של הבגרות · אינו מחליף את קורס הרשתות

מטרה: לרענן את מושגי הרשתות הנדרשים לחלק א' של שאלון (50 735001 נק')
הערה: החומר נלמד בהרחבה אצל מורה הרשתות; זהו דף עזר מרוכז לחזרה

1. מודל OSI ו-TCP/IP – היכן יושב כל דבר

פרוטוקולים / התקנים	יחידה	#	שכבה OSI
HTTP, HTTPS, DNS, DHCP, FTP, SMTP, IMAP, SSH, Telnet, SNMP	Data	5-7	Application / Presentation / Session
TCP (אמין, מספרי רצף, לחיצת יד), UDP (מהיר, ללא חיבור)	Segment	4	Transport
IP, ICMP, OSPF (Router); נתב	Packet	3	Network
Ethernet, ARP, STP (Switch), כתובות MAC	Frame	2	Data Link
כבלים, חשמל	Bits	1	Physical

נשאל בבגרות (נכון/לא נכון)

TCP פועל בשכבה 4 (לא 3!) · IMAP מקבל דוא"ל (נכון) · UDP בניא יוצר תקשורת אמינה (לא נכון – זה TCP).

2. בסיסי ספירה: בינארי · הקסדצימלי · אוקטלי

- 1 ספרה הקסדצימלי = 4 ביטים; 1 ספרה אוקטלי = 3 ביטים.
- המרה: הקס → בינארי (כל ספרה ל-4 ביט), ואז לקבץ ל-3 לאוקטלי.

דוגמה (כמו בבגרות): BA3F בהקס

1011 1010 0011 1111: **בינארי** ⇒ B=1011, A=1010, 3=0011, F=1111
לאוקטלי מקבצים 3 ביטים מימין: 1 011 101 000 111 111: **אוקטלי**: 135077

3. כתובות IPv4, סאבנטיים ו-Wildcard

כתובות פרטיות	192.168.0.0/16 · 172.16.0.0/12 · 10.0.0.0/8
מספר מארחים שמישים	2 ^(32-prefix) – 2 (פחות כתובות רשת ו-broadcast)
Wildcard	subnet mask – 255.255.255.255

טבלת ייחוס מהירה

Prefix	Subnet mask	גודל בלוק	מארחים שמישים	Wildcard
24/	255.255.255.0	256	254	0.0.0.255
25/	255.255.255.128	128	126	0.0.0.127
26/	255.255.255.192	64	62	0.0.0.63

Prefix	Subnet mask	גודל בלוק	מארחים שמישים	Wildcard
27/	255.255.255.224	32	30	0.0.0.31
28/	255.255.255.240	16	14	0.0.0.15
30/	255.255.255.252	4	2	0.0.0.3

דוגמאות מהבגרות

- מספר מארחים שמישים ב-172.16.16.16/28 $14 = 2^{-4} \Rightarrow$
- $0.0.0.63 = \text{Wildcard} \cdot 255.255.255.192 = \text{Subnet mask} \Rightarrow 135.8.x/26$
- מציאת הרשת: לכתובת עם 30/ , הבלוקים הם 0,4,8... $\Rightarrow 10.10.2.20/30 \leftarrow$ רשת 20, מארחים שמישים 21..23, broadcast 22

4. IPv6 - קיצור וסוגי כתובות

כללי קיצור

- משמיטים אפסים מובילים בכל בלוק (130F נשאר, 0000 $\rightarrow$ 0).
- : : מחליף רצף אחד של בלוקי אפסים (פעם אחת בלבד בכתובת).

דוגמה מהבגרות

$3001:0:130F::1:133B \Rightarrow 3001:0000:130F:0000:0000:0000:0001:133B$

סוג כתובת	תחילית	תפקיד
Global Unicast	2000::/3	ניתובה באינטרנט (כמו כתובת ציבורית)
Link-Local	FE80::/10	תקשורת בקו/רשת מקומית בלבד; לא עוברת נתב
Unique Local (ULA)	FC00::/7 (FD00::/8)	תקשורת בין תתי-רשתות פנימיות, לא ניתובה באינטרנט (מקביל לכתובת פרטית)
Multicast	FF00::/8	שידור לקבוצה

נשאל בבגרות

"סוג כתובת המספק תקשורת בין תתי-רשתות אך שאינו ניתוב באינטרנט" $\Rightarrow$ Unique Local.

5. פרוטוקולים ופורטים חשובים

פרוטוקול	פורט	TCP/UDP	תפקיד
FTP	20/21	TCP	העברת קבצים
SSH	22	TCP	ניהול מרחוק מוצפן
Telnet	23	TCP	ניהול מרחוק (לא מוצפן!)
SMTP	25	TCP	שליחת דוא"ל
DNS	53	UDP/TCP	תרגום שם $\rightarrow$ כתובת
DHCP	67/68	UDP	הקצאת כתובות אוטומטית
HTTP / HTTPS	80 / 443	TCP	גלישה
IMAP / POP3	143 / 110	TCP	קבלת דוא"ל
SNMP	161	UDP	ניטור ציוד
Syslog	514	UDP	יומן אירועים

6. ניתוב: מרחק ניהולי, ניתוב סטטי ו-DHCP Relay

מרחק ניהולי (Administrative Distance) - "עד כמה סומכים על מקור המידע" (נמוך = עדיף)

מקור	AD
Connected (מחובר ישירות)	0
ניתוב סטטי (Static)	1
External BGP	20
Internal EIGRP	90
OSPF	110
RIP	120

```

! ניתוב סטטי: אל רשת היעד, דרך ה-next-hop
R1(config)# ip route 10.10.2.20 255.255.255.252 10.10.255.1
! ניתוב ברירת מחדל (לאינטרנט / כגיבוי)
R1(config)# ip route 0.0.0.0 0.0.0.0 200.1.1.1
! גיבוי (floating static) - AD גבוה מ-OSPF כדי שלא יבטל את הניתוב הדינמי
R1(config)# ip route 10.0.0.0 255.0.0.0 200.1.1.2 120

```

DHCP Relay - כשהשרת ברשת אחרת

בקשת DHCP היא broadcast ואינה עוברת נתב. מגדירים על הממשק של הלקוח את כתובת שרת ה-DHCP: `ip helper-address 192.50.100.100 #R1(config)# interface g0/0 R1(config-if) DHCP-ה`

7. מיתוג: VLAN, Trunk ו-Router-on-a-Stick

- VLAN - מפצל מתג לרשתות לוגיות מבודדות. מעבר בין VLANים דורש ניתוב.
- Trunk (802.1Q) - קישור שנושא כמה VLANים בין מתגים; מוסיף תג של מספר ה-VLAN.
- Router-on-a-Stick - נתב עם תת-ממשקים (subinterfaces), אחד לכל VLAN, לניתוב ביניהם.

```

! ניתוב בין VLANים על ממשק פיזי אחד
R1(config)# interface g0/0/1.10
R1(config-subif)# encapsulation dot1q 10
R1(config-subif)# ip address 172.18.1.254 255.255.0.0
R1(config)# interface g0/0/1.20
R1(config-subif)# encapsulation dot1q 20
R1(config-subif)# ip address 172.18.2.254 255.255.0.0
! בדיקת טבלת ה-MAC של המתג
S1# show mac address-table

```

8. STP ו-OSPF - כללי הבחירה (נשאלים כמעט תמיד)

STP - בחירת Root Bridge

Priority = Bridge ID (ברירת מחדל) + MAC.
 מנצח: ה-Priority רומנה; בתיקו - ה-MAC הנמוך.
 STP פועל בשכבה 2 ומונע לולאות ע"י חסימת יציאות (port blocking).

OSPF - בחירת DR / BDR

מנצח: ה-Priority הגבוה; בתיקו - ה-Router-ID הגבוה.
STP-M רופה - בל ומיש ב-STP נמוך מנצח, ב-OSPF גבוה מנצח.

דוגמאות מהבגרות

- 4 מתגים, priority זהה, MAC הנמוך $\Rightarrow$ אותו מתג הופך ל-root.
- R1(pri 2, RID 1.1.1.1), R3(pri 2, RID 3.3.3.3) $\Rightarrow$ OSPF: בין בעלי priority 2 מנצח (RID גבוה) R3 (גבוה) כ-DR, ו-R1 כ-BDR.

9. פקודות CLI ואבחון תקלות

מצב	הנחיה
User EXEC	Router> - פקודות show בסיסיות, ping
Privileged EXEC	Router# - enable
Global config	Router(config)# - configure terminal
Interface	Router(config-if)#

```
Switch(config)# hostname R1
R1(config)# interface g0/1
R1(config-if)# no switchport ! הופך פורט מתג L3 לפורט מנותב
R1(config-if)# ip address 10.100.20.42 255.255.255.0
R1(config-if)# no shutdown
! בדיקות נפוצות
R1# show ip interface brief
R1# show ip route
R1# show running-config
```

אבחון תקלות - שיטת Top-Down

בודקים מהשכבה העליונה כלפי מטה: גישה לאפליקציה/שירות $\rightarrow$ הגדרות רשת (IP/gateway/DNS) $\rightarrow$ חיבור פיזי (כבל, נורית). דוגמה: בדיקת גישה לנתב החברה $\rightarrow$ בדיקת הגדרות $\rightarrow$ בדיקת כבל רשת.

פקודות אבחון בתחנת קצה (Windows)

- IP, MAC, gateway, DNS. - ipconfig /all
- ipconfig /displaydns - הצגת זיכרון המטמון (cache) של ה-DNS במחשב.
- ipconfig /flushdns - איפוס המטמון. • arp -a, tracert, ping, nslookup.

CDP

פרוטוקול CDP מאפשר לזהות התקנים סמוכים של סיסקו ברשת המקומית (show cdp neighbors). מטעמי אבטחה מכבים אותו על פורטי קצה (no cdp enable).

10. תרגילי חזרה מהירים

תרגיל 1

א. כמה מארחים שמישים ב-27/? ב. מהי ה-wildcard של 10.20.0.0/16? ג. באיזו שכבה פועל TCP?
א. 30 ב. 0.0.255.255 ג. שכבה (Transport) 4

תרגיל 2

קצרו: 2001:0DB8:0000:0000:0000:00FF:0000:0001

2001:DB8::FF:0:1

תרגיל 3

לנתב יש מסלול (AD 110) OSPF ומסלול סטטי (AD 1) לאותה רשת. איזה ייבחר ולמה?
הסטטי - ה-AD הנמוך יותר מעיד על מקור מהימן/מועדף.

תרגיל 4

מנהל רוצה ששרת DHCP ברשת אחרת יקצה כתובות ללקוחות ברשת של R1. איזו פקודה נדרשת ועל איזה ממשק?

<DHCP-ה תרש לש IP <ip helper-address על הממשק של R1 הפונה ללקוחות.

פרק 1 – מבוא לאיומי רשת חדשים

10 שעות עיוני · שבועות 1-3

מטרות: אבולוציית אבטחת המידע · כלים לאבטחה · מערכות והתקפת מערכות
בבגרות: phishing, סוגי תוקפים, brute force, DoS, buffer overflow

לפני שמתחילים – מושגי יסוד ברשת (למי שאין רקע)

כדי להבין איומים ואבטחה, צריך קודם להבין מה זו בכלל רשת. הנה כל מה שצריך, בשפה פשוטה: **מחשב מארח** (Host) – כל מכשיר ברשת: מחשב, טלפון, שרת, מדפסת. **כתובת IP** – ה"כתובת" של המכשיר ברשת, כמו כתובת בית (למשל 192.168.1.10). לפיה יודעים לאן לשלוח מידע. **כתובת MAC** – מספר סידורי ייחודי "צרוב" בכרטיס הרשת של כל מכשיר (למשל 0C:0E:15:22:05:97). כמו מספר שלדה של רכב. **חבילה** (Packet) – המידע ברשת לא נשלח כמקשה אחת אלא נחתך ל"מעטפות" קטנות. כל חבילה נושאת כתובת מקור וכתובת יעד, בדיוק כמו מעטפה בדואר. **שרת** (Server) ו**לקוח** (Client) – הלקוח מבקש שירות (הדפדפן שלכם), השרת נותן אותו (אתר האינטרנט). הלקוח שואל, השרת עונה. **נתב** (Router) – מכשיר שמעביר חבילות בין רשתות שונות (למשל בין הרשת בבית לאינטרנט). "צומת דרכים". **מתג** (Switch) – מכשיר שמחבר מכשירים בתוך אותה רשת מקומית (כל המחשבים במשרד). **פרוטוקול** – "שפה"/כללים מוסכמים שמכשירים מדברים בהם (HTTP) לאתרים, DNS לתרגום שמות). כמו כללי נימוס בשיחת טלפון. **פורט** (Port) – "דלת" ממוספרת במכשיר לכל שירות (80 לאתר, 443 לאתר מאובטח, 22 ל-Ssh). כל כתובת IP יש 65,535 דלתות כאלה. כל אלה מוסברים בהרחבה ביחידת "תזכורת רשתות תקשורת". **הרעיון המרכזי של הקורס:** בכל נקודה כזו – מכשיר, כתובת, חבילה, פורט – תוקף יכול לנסות לתקוף, ואנחנו נלמד להגן.

1.1 מהי אבטחת מידע ולמה הרשת היא שדה הקרב

אבטחת מידע (Information Security) היא ההגנה על מידע ועל המערכות שמעבדות אותו מפני גישה, שימוש, חשיפה, שיבוש, שינוי או השמדה בלתי מורשים. **אבטחת רשת** (Network Security) היא תת-תחום: ההגנה על התשתית שמעבירה את המידע – נתבים, מתגים, חומות אש, קווי תקשורת – ועל התעבורה שעוברת בהם. ההבחנה המרכזית שכדאי להציג לתלמידים כבר ביום הראשון: **נכס** (asset) · **איום** (threat) · **פגיעות** (vulnerability) · **סיכון** (risk) · **בקרה** (control).

נכס (Asset)	מה שמגנים עליו: מידע לקוחות, שרתים, מוניטין, זמינות שירות.
פגיעות (Vulnerability)	חולשה במערכת: באג בתוכנה, סיסמה חלשה, פורט פתוח, עובד שלא הוכשר.
איום (Threat)	גורם שעלול לנצל פגיעות: האקר, נזקה, עובד ממורמר, גם שריפה או הצפה.
ניצול (Exploit)	הדרך/הקוד הקונקרטי שבו האיום מנצל את הפגיעות.
סיכון (Risk)	הסתברות שהאיום יממש את הפגיעות × הנזק שייגרם. סיכון = איום × פגיעות × ערך הנכס.
בקרה (Control / Countermeasure)	אמצעי שמקטין סיכון: חומת אש, הצפנה, נוהל, מנעול.

שלושת עקרונות היסוד – CIA Triad

עיקרון	משמעות	דוגמה לפגיעה	אמצעי הגנה אופייני
סודיות (Confidentiality)	רק מי שמורשה רואה את המידע	האזנה (sniffing), דליפת DB, Telnet-ל	הצפנה (AES, SSH, VPN), בקרת גישה, ACL
שלמות (Integrity)	המידע לא שונה בדרך או במנוחה ללא הרשאה	שינוי סכום בהעברה, בנקאית, MITM	גיבוב (SHA), HMAC, חתימה דיגיטלית
זמינות (Availability)	המידע והשירות נגישים כשצריך	DDoS, כופרה, כשל חומרה	יתירות, גיבויים, IPS, סינון תעבורה

שני מושגים נלווים שנשאלים לעיתים: **אימות** (Authentication) – מי אתה) ו**אי-הכחשה** (Non-repudiation) – השולח לא יכול להכחיש ששלח; מושג באמצעות חתימה דיגיטלית, פרק 7).

שאלת תלמיד: "למה צריך שלושה? הרי אם מצפינים הכול – הכול בסדר"

הצפנה נותנת סודיות בלבד. קובץ מוצפן עדיין יכול להימחק (פגיעה בזמינות) או להיות מוחלף בקובץ מוצפן אחר (שלמות). כופרה (Ransomware) היא הדוגמה המושלמת: היא מצפינה את הקבצים שלכם – ובכך פוגעת בזמינות. הצפנה בידיים הלא נכונות היא נשק.

סיפור מהחיים: בית החולים שביטל ניתוחים (WannaCry), מאי 2017

בבוקר יום שישי אחד, מחשבים ב-80 בתי חולים של ה-NHS באנגליה הציגו מסך אדום: "הקבצים שלך הוצפנו. שלם \$300 בביטקוין". המערכות לתורים, לתוצאות בדיקות ולמכשירי הדמיה הפסיקו לעבוד. 19,000 תורים וניתוחים בוטלו, אמבולנסים הופנו לבתי חולים אחרים. הנוזקה לא "גנבה" כלום – היא פשוט מנעה גישה. זו פגיעה **בזמינות**. ואיך היא התפשטה? דרך פגיעות ב-SMB של Windows שמיקרוסופט כבר תיקנה חודשיים קודם – אבל בתי החולים לא התקינו את העדכון. המסקנה לכיתה: עדכון תוכנה הוא אמצעי אבטחה, ולא מטרד.

1.2 אבולוציית אבטחת הרשת – ציר זמן

שנה	אירוע	מה השתנה בעקבותיו
1971	Creeper – "וירוס" הניסוי הראשון ב-ARPANET, ואחריו Reaper שנכתב כדי למחוק אותו	ההוכחה שקוד יכול להתפשט ברשת
1983	פרד כהן טובע את המונח "וירוס מחשב"	תחילת המחקר האקדמי
1988	תולעת מוריס – ~10% ממחשבי האינטרנט מושבתים תוך יום. ניצלה חולשות ב-sendmail וב-finger וניחוש סיסמאות	הקמת ה-CERT הראשון (Carnegie Mellon); החוק הפדרלי הראשון להרשעה בפריצה
1990s	חומות אש מסחריות (Check Point FireWall-1, 1994), IDS ראשונים (Snort, 1998), SSL (1995)	מודל "הגנה היקפית" – פנים מהימן, חוץ עוין
2004-2000	ILoveYou (2000), Code Red (2001), SQL Slammer (2003) – 75,000 שרתים ב-10 דקות, Blaster, Sasser	תולעים שמנצלות חולשות ידועות ⇒ תרבות ה-patching, Windows Update אוטומטי, IPS
2010-2007	מתקפת DDoS על אסטוניה (2007); Stuxnet (2010) – נוזקה שפגעה בצנטריפוגות גרעיניות	לוחמת סייבר בין מדינות; APT (איום מתמשך מתקדם)
2017-2013	פריצת 40 Target מיליון כרטיסי אשראי דרך ספק מיזוג אוויר, Mirai botnet (2016) – מצלמות (2017 WannaCry, IoT) – כופרה שניצלה 200,000 SMB, 200,000 מחשבים ב-150 מדינות	אבטחת שרשרת אספקה, IoT, כופרה כמודל עסקי

שנה	אירוע	מה השתנה בעקבותיו
2020-היום	SolarWinds (2020) - פריצה דרך עדכון תוכנה, Log4Shell (2021), כופרה כשירות (RaaS), דיפ-פייק והנדסה חברתית מבוססת AI	מודל Zero Trust - "לעולם אל תסמוך, תמיד תאמת"; אין יותר "פנים מהימן"

טיפ להוראה

אל תקריאו את הטבלה. בחרו 3 סיפורים ותספרו אותם: תולעת מוריס (סטודנט שרצה "למדוד את האינטרנט" והסתבר), Target (איך מזגן הפיל רשת ענק) ו-WannaCry (בית חולים באנגליה שביטל ניתוחים). תלמידים זוכרים סיפורים, לא שנים.

סיפור מהחיים: הסטודנט שהפיל את האינטרנט בטעות (תולעת מוריס, 1988)

רוברט מוריס, סטודנט בן 23 בקורנל, כתב תוכנית שנועדה "למדוד כמה גדול האינטרנט" - היא הייתה אמורה להעתיק את עצמה למחשב פעם אחת. בגלל באג, היא שאלה כל מחשב "אתה כבר נגוע?" ואם הוא ענה "כן" - בכל זאת הדביקה אותו מחדש ב-1 מ-7 מהמקרים (מוריס חשש שמנהלים יזייפו "כן"). התוצאה: כל מחשב הריץ מאות עותקים עד שקרסו 6,000 מחשבים - כעשירית מהאינטרנט דאז - הושבתו. מוריס היה האדם הראשון שהורשע לפי חוק הונאת המחשבים האמריקאי. היום הוא פרופסור ב-MIT. השאלה לכיתה: האם זה היה ירוס או תולעת? (תולעת - התפשטה לבד דרך הרשת ללא מגע אדם.)

1.3 מי תוקף? סוגי תוקפים (Threat Actors)

נושא שנשאל ישירות בבגרות (שאלה ג6). חשוב להבחין לפי מניע ויכולת:

סוג	מי הוא	מניע	רמת יכולת
Script Kiddie	חובבן שמריץ כלים שאחרים כתבו, בלי להבין את התהליך	סקרנות, יוקרה, שעמום	נמוכה - אבל הכלים חזקים
Hacktivist	תוקף ממניעים אידיאולוגיים/פוליטיים (Anonymous)	מחאה, השחתת אתרים, הדלפות	בינונית
פשע מאורגן (Organized crime / Cybercriminal)	קבוצה מאורגנת שמטרתה רווח כספי	כסף: כופרה, גניבת כרטיסי אשראי, הונאות	גבוהה, משאבים רבים
Insider (איום פנימי)	עובד/קבלן עם גישה מורשית שמשתמש בה לרעה (או ברשלנות)	נקמה, כסף, טעות	מסוכן במיוחד - כבר בפנים
מדינה (State-sponsored / APT)	יחידות סייבר ממשלתיות	ריגול, חבלה בתשתיות	הגבוהה ביותר, סבלנות של שנים
White hat / Gray hat / Black hat	חלוקה לפי אתיקה: white - בודק חדירה באישור; black - פושע; gray - פורץ ללא אישור אבל מדווח		

סיפור מהחיים: איך מזגן הפיל רשת קמעונאית (Target, 2013)

רשת החנויות Target איבדה פרטי 40 מיליון כרטיסי אשראי. התוקפים לא פרצו ל-Target ישירות - הם שלחו phishing לחברה קטנה בפנסילבניה שמתחזקת את מערכות המיזוג של Target, גנבו את פרטי ההתחברות שלה לפורטל הספקים, ומשם - כי הרשת לא הייתה מפולחת - הגיעו לקופות. שלושה לקחים שממפים ישירות לקורס: (1) הנדסה חברתית היא נקודת הכניסה הנפוצה ביותר; " (2) יחסי אמון" עם צד

שלישי הם פגיעות (3); (Trust exploitation); פילוח רשת (VLAN, ACL) - פרקים 4 ו-6 (היה עוצר את התנועה הרוחבית).

1.4 נזקות: וירוסים, תולעים, סוסים טרויאנים ועוד

נוזקה (Malware = malicious software) הוא שם כולל. ההבחנה בין שלושת הסוגים הקלאסיים היא לפי איך הם מתפשטים:

סוס טרויאני (Trojan)	תולעת (Worm)	וירוס (Virus)	הגדרה
תוכנה שנראית לגיטימית אך מכילה קוד זדוני	תוכנית עצמאית שמשכפלת את עצמה דרך הרשת	קוד זדוני שמצמיד את עצמו לקובץ/תוכנה לגיטימית	
הוא עצמו "המארח" המזויף	לא - עומד בפני עצמו	כן - נדבק לקובץ	צריך מארח?
המשתמש - מתקין אותו מרצון (חושב שזה משחק)/crack	הוא עצמו - מנצל פגיעות ברשת אוטומטית	המשתמש (מריץ את הקובץ הנגוע, מעתיק בדיסק-און-קי)	מי מפיץ?
לא	כן, ובמהירות	כן	משכפל את עצמו?
Zeus (בנקאות), RAT (שליטה מרחוק)	Morris, Slammer, WannaCry	Melissa (1999 Word) מאקרו ב-	דוגמה

סוגי נזקות נוספים שכדאי להכיר

- Ransomware (כופרה) - מצפינה קבצים ודורשת תשלום. כיום הסוג המזיק ביותר לארגונים.
- Spyware / Keylogger - מרגל, מתעד הקשות.
- Adware - פרסומות; לרוב מטריד יותר ממסוכן.
- Rootkit - מסתתר עמוק במערכת ההפעלה (kernel) ומסווה נזקות אחרות; קשה מאוד לגילוי.
- Botnet / Bot / Zombie - מחשבים נגועים הנשלטים מרחוק על ידי C&C (Command & Control) ומשמשים ל-DDoS, spam, כריית מטבעות.
- Logic bomb - קוד ש"מתפוצץ" בתנאי מסוים (תאריך, פיטורי העובד).
- Backdoor - דלת אחורית שעוקפת אימות. יכולה להיות מותקנת על ידי טרויאני או להישאר מכוונה בקוד.

שאלת תלמיד: "אנטי-וירוס מספיק?"

אנטי-וירוס קלאסי מזהה לפי **חתימות** (signature) - תבניות של נזקות ידועות. נזקה חדשה (zero-day) או נזקה שעברה שינוי קל (polymorphic) לא תזוהה. לכן כיום משלבים: ניתוח התנהגות (EDR), (heuristics), עדכוני מערכת, הגנת רשת (IPS), והכי חשוב - משתמש שלא לוחץ על כל דבר. "הגנה לעומק" (Defense in Depth) - כמה שכבות עצמאיות, כך שכשל באחת לא מפיל הכול.

1.5 חקר ההתקפות - שלושת השלבים

מרבית התקפות הרשת מתחלקות לשלוש קטגוריות שסיסקו מגדירה, ואפשר גם לתאר אותן כשלבים בזמן:

1. **סיור / איסוף מידע** (Reconnaissance) → 2. **השגת גישה** (Access) → 3. **מניעת שירות** (DoS) או **ניצול**

מודל מפורט יותר, Cyber Kill Chain של לוקהיד-מרטין: De- → Weaponization → Reconnaissance → Installation → Exploitation → livery Actions on Objectives. → Command & Control → התקיפה נכשלת. אם שוברים חוליה אחת בשרשרת - התקיפה נכשלת.

1.5.1 איסוף מידע (Reconnaissance)

התוקף לומד את המטרה לפני שנוגע בה. הבחינו בין:

- **סיור פסיבי** - ללא מגע עם המטרה: whois (מי הבעלים של הדומיין), DNS (nslookup, dig), רשתות חברתיות, אתר החברה, מודעות דרושים ("דרוש מנהל רשת עם ניסיון ב-Cisco ASA - עכשיו התוקף יודע איזו חומת אש יש), OSINT.

- **סיור אקטיבי** - שליחת חבילות: Ping sweep - פינג לכל הכתובות בטווח כדי לגלות אילו מארחים חיים. Port scan - בדיקה אילו פורטים פתוחים בכל מארח (Nmap). פורט 22 פתוח ⇒ SSH; 445 ⇒ RDP; 3389 ⇒ SMB Fingerprinting - זיהוי מערכת ההפעלה והגרסה. (Nmap-O, banner grabbing) Packet sniffing - האזנה לתעבורה (Wireshark) - יעיל במיוחד ברשת אלחוטית פתוחה או כשמשתמשים בפרוטוקולים לא מוצפנים. (Telnet, HTTP, FTP)

הגנה: IPS שמזהה סריקות, חומת אש שחוסמת ICMP מבחוץ, סגירת שירותים לא נחוצים, הצפנה נגד sniffing, מדיניות מידע ברשתות חברתיות.

1.5.2 התקפות גישה (Access attacks)

התקפה	איך זה עובד	הגנה
Brute – Password attack force / Dictionary	ניסוי שיטתי של כל הצירופים (brute force) או של רשימת מילים נפוצות. (dictionary). כלים: John the Ripper, Hydra. בבגרות: "ניסיון לגלות סיסמה ע"י מילון" = Brute force attack.	סיסמאות ארוכות ומורכבות, נעילה אחרי X ניסיונות, MFA, האטת ניסיונות
Trust exploitation	ניצול יחסי אמון: אם שרת A סומך על B, פורצים ל-B (החלש) ומשם ל-A	מזעור יחסי אמון, פילוח רשת
Port redirection	מארח שנפרץ (ב-DMZ) משמש כ"קופץ" להעברת תעבורה למארח פנימי שחומת האש לא מאפשרת אליו גישה ישירה	HIPS, מודל אמון נכון בין DMZ לפנים
Man-in-the-Middle (MITM)	התוקף מכניס את עצמו בין שני צדדים ומקשיב/משנה (ARP spoofing ברשת מקומית - פרק 6; Evil Twin ב-Wi-Fi)	הצפנה עם אימות (TLS, SSH fingerprint), בדיקת DAI
Buffer overflow	שליחת קלט ארוך מהחוצץ שהוקצה לו, כך שהוא "גולש" ודורס זיכרון - כולל כתובת החזרה - ומריץ קוד של התוקף	עדכוני תוכנה, DEP/ASLR, בדיקת קלט
Social engineering	מניפולציה של בני אדם - ראו 1.6	הדרכה, נהלים

1.5.3 מניעת שירות - DoS ו-DDoS

DoS (Denial of Service): הפיכת שירות ללא זמין למשתמשים הלגיטימיים - על ידי הצפה בתעבורה או ניצול באג שמקריס את השירות. DDoS (Distributed): אותו דבר, אבל ממקורות רבים במקביל (botnet) - קשה לחסום כי אין כתובת מקור אחת.

התקפה	מנגנון
Ping of Death	שליחת חבילת ICMP גדולה מ-65,535 בתים (בעזרת פרגמנטציה); מערכות ישנות קרסו בהרכבה מחדש. היסטורי - היום מתוקן, אך נשאל בבחינות.
SYN flood	שליחת המוני SYN בלי לסיים את לחיצת היד המשולשת; טבלת החיבורים "החצי-פתוחים" של השרת מתמלאת ולקוחות אמיתיים נדחים. הגנה: SYN cookies, TCP intercept, SYN flood protection.

התקפה	מנגנון
Smurf	שליחת פינג לכתובת broadcast עם כתובת מקור מזויפת של הקורבן; כל המחשבים ברשת עונים לקורבן (הגברה). הגנה: no ip directed-broadcast (ברירת מחדל היום).
(DNS, NTP) Amplification / Reflection	שאיילתה קטנה עם IP מקור מזויף $\Rightarrow$ תשובה גדולה נשלחת לקורבן. יחס הגברה של פי 50 ויותר.
(HTTP flood, Application-layer DoS Slowloris)	בקשות "לגיטימיות" רבות או חיבורים שנשארים פתוחים לאט – מתישים את השרת.

הגנות מפני DoS: סינון בכניסה לרשת (anti-spoofing ACL) – פרק IPS, rate limiting, (4, שירותי ניקוי תעבורה בענן (Cloudflare, Akamai), יתירות ורוחב פס עודף, ip verify unicast reverse-path (uRPF).

1.6 הנדסה חברתית ו-Phishing

ההתקפה שלא צריכה אף פגיעות טכנית – היא מנצלת את האדם. סוגים:

- **Phishing** – דוא"ל/SMS שמתחזה לגוף לגיטימי (בנק, UPS, משרד) ומבקש ללחוץ על קישור, "לאשר פרטים" או לפתוח קובץ. **Spear phishing** – ממוקד לאדם ספציפי עם פרטים אמיתיים עליו. **Whaling** – ממוקד למנכ"ל. **Smishing / Vishing** – ב-SMS / בטלפון.
- **Pretexting** – סיפור כיסוי ("אני מהתמיכה, צריך את הסיסמה שלך כדי לתקן").
- **Baiting** – דיסק-און-קי "אבוד" בחניה עם תווית "משכורות".
- **Tailgating / Piggybacking** – כניסה פיזית בעקבות עובד מורשה.
- **Quid pro quo** – "תן לי גישה ואתן לך מתנה".

בבגרות (שאלה 4א): איך מזהים הודעת phishing? סימנים לחפש

1. כתובת השולח לא תואמת לארגון (UPS) ששולח מ-@hotmail.com. 2. תחושת דחיפות/איום ("Last Call!", "החשבון ייחסם"). 3. בקשה לאשר/להזין פרטים דרך כפתור. 4. שגיאות ניסוח, לוגו מטושטש, פנייה כללית ("Dear customer"). 5. קישור שהטקסט שלו שונה מהיעד האמיתי (מרחפים עם העכבר). **התשובה:** Social Engineering.

סיפור מהחיים: הסמנכ"ל ששילם 40 מיליון (הונאת "מנכ"ל", 2016)

עובד כספים בחברת Crelan הבלגית קיבל מייל "מהמנכ"ל": "אנחנו ברכישה סודית, העבר דחוף 70 מיליון אירו לחשבון הזה, אל תדבר עם אף אחד". הכתובת הייתה דומה לכתובת המנכ"ל בהבדל אות אחת. הכסף הועבר. זו הנדסה חברתית מסוג BEC (Business Email Compromise) – בלי נזקה, בלי פריצה, רק פסיכולוגיה: סמכות + דחיפות + סודיות. שאלו את התלמידים: איזה נוהל (בקרה מנהלית) היה מונע את זה? (אישור כפול לכל העברה מעל סכום, ואימות טלפוני בערוץ נפרד).

1.7 שיכון מתקפות ברוט-פורס – ומה אפשר לעשות כבר בנתב

"ברוטלי" בתכנית = Brute force. עקרונות ההגנה:

1. **סיסמאות חזקות** – אורך חשוב יותר ממורכבות. 8 תווים מאותיות קטנות $= 26^8 \approx 200$ מיליארד (נפרץ בדקות ב-12 GPU); תווים מכל הסוגים $= 95^{12} \approx 5 \times 10^{23}$. משפט-סיסמה (passphrase) עדיף.
2. **נעילה והאטה** – אחרי N ניסיונות כושלים: נעילת חשבון, השהיה מתארכת, (exponential backoff), CAPTCHA.
3. **אימות רב-שלבי (MFA)** – גם אם הסיסמה נפרצה, התוקף לא מחזיק את הטלפון.
4. **אחסון סיסמאות נכון** – לא בטקסט גלוי; גיבוב עם salt (פרק 7).
5. **ניטור** – התראה על ריבוי כניסות כושלות (syslog) – פרק 2).

ב-Cisco IOS יש מגנון מובנה שנלמד לעומק בפרק 2, אבל שווה להציג אותו כבר כאן כדי לחבר תיאוריה למעשה:

```
R1(config)# login block-for 120 attempts 3 within 60
! אם היו 3 ניסיונות כושלים תוך 60 שניות - חסום כניסות ל-120 שניות
R1(config)# login delay 2
! השהיה של 2 שניות בין ניסיונות
R1(config)# login on-failure log
! רשום כל כישלון ל-syslog
R1(config)# login on-success log
R1# show login
```

1.8 ארגון האבטחה: מדיניות, תפקידים ותקנים

מדיניות אבטחה (Security Policy)

מסמך שקובע מה מותר ומה אסור בארגון - ולא איך (זה בנהלים). מרכיבים אופייניים: מדיניות שימוש מקובל (AUP), מדיניות סיסמאות, גישה מרחוק, סיווג מידע, תגובה לאירועים. בלי מדיניות כתובה אי אפשר לאכוף ולא ניתן לפטר עובד ש"רק בדק".

סוגי בקורות (נשאל בבגרות - שאלה 6ב)

סוג בקרה	תיאור	דוגמאות
מנהלית (Administrative)	מדיניות, נהלים, הנחיות, תקנים, הדרכות, בדיקות רקע	איסור על עבודה ב-Zoom מרשת לא מאובטחת, נוהל סיסמאות, הכשרת עובדים
פיזית (Physical)	הגנה על החומרה והמבנה	מנעולים על חדר שרתים וארונות תקשורת, מצלמות, שומרים, כרטיסי כניסה
לוגית / טכנית (Logical / Technical)	אמצעים בתוכנה ובחומרה	רשימות גישה (ACL), סיסמאות, הצפנה, חומת אש, IPS, אנטי-וירוס

תפקידים

CISO (Chief Information Security Officer) - אחראי אבטחה ארגוני; SOC (Security Operations Center) - מרכז ניטור 24/7; CERT/CSIRT - צוות תגובה לאירועים; בישראל: מערך הסייבר הלאומי ו-CERT-IL.

תקנים וארגונים

- ISO/IEC 27001 - תקן בינלאומי לניהול אבטחת מידע (ISMS); ארגונים מוסמכים לו.
- NIST Cybersecurity Framework - Identify, Protect, Detect, Respond, Recover.
- PCI-DSS - חובה לכל מי שמעבד כרטיסי אשראי.
- CVE (Common Vulnerabilities and Exposures) - מאגר עולמי של פגיעויות עם מזהה, לדוגמה CVE-2017-0144 (הפגיעות ש-WannaCry ניצלה). CVSS - ציון חומרה 0-10.
- Top 10 SANS, OWASP (Top 10 SANS, OWASP) - לאפליקציות (web, MITRE ATT&CK) - קטלוג טקטיקות תוקפים.

1.9 אביזרי אבטחה ברשת - מפת הקורס

סקירה של הרכיבים שנלמד בפרקים הבאים, כדי שהתלמידים יראו את התמונה הגדולה:

רכיב	תפקיד	פרק
נתב מוקשח (Hardened router)	קו ההגנה הראשון בקצה; SSH, סיסמאות, logging	2
שרת AAA (RADIUS/TACACS+)	אימות מרכזי של משתמשים ומנהלים	3

פרק	תפקיד	רכיב
4	סינון תעבורה לפי כללים	חומת אש / ACL / Firewall) / ZPF
5	זיהוי וחסימת התקפות לפי חתימות	IDS / IPS
6	הגנה בשכבה 2	מתג מאובטח, (port security, DHCP snooping, DAI)
7	סודיות ושלמות	הצפנה, PKI
8	ערוץ מוצפן על גבי רשת ציבורית	VPN (IPsec, SSL)
9	בדיקה שהכול עובד	סורקי פגיעויות, ניהול סיכונים

Cisco ASA (Adaptive Security Appliance) – מכשיר ייעודי שמשלב חומת אש, VPN ו-IPS יורשו הנוכחי: Firepower / FTD. בתכנית מוזכר גם Cisco SDM – ממשיך ניהול גרפי ישן; היום. CLI.

טעויות נפוצות של תלמידים בפרק זה

- מבלבלים וירוס ותולעת – השאלה המכריעה: האם צריך פעולה של משתמש כדי להתפשט? וירוס – כן. תולעת – לא.
- חושבים שטרויאני משכפל את עצמו – לא. הוא מחכה שיתקינו אותו.
- "DDoS זה וירוס" – DDoS היא התקפה; botnet (שנבנה בעזרת נוזקה) הוא הכלי.
- "Phishing זה וירוס במייל" – phishing הוא הנדסה חברתית; המייל עצמו לא בהכרח מכיל נוזקה, לפעמים רק קישור לאתר מזויף.
- "Hacker = פושע" – הבהירו את white/black/gray hat.

1.10 תרגילים לתלמידים

תרגיל 1 – סיווג אירועים לפי CIA

לכל אירוע, ציינו איזה עיקרון נפגע (יכול להיות יותר מאחד):
 א. תלמיד מצא דרך לשנות ציון במערכת בית הספר. ב. אתר בית הספר קרס ביום ההרשמה. ג. רשימת הטלפונים של ההורים דלפה לקבוצת וואטסאפ. ד. כופרה הצפינה את שרת הקבצים. ה. מישהו האזין לשיחת Zoom שלא הוזמן אליה.

א. שלמות ב. זמינות ג. סודיות ד. זמינות (ואם הם גם מאיימים לפרסם – סודיות) ה. סודיות

תרגיל 2 – וירוס, תולעת או טרויאני?

א. תוכנה בשם "Free-Minecraft-Coins.exe" שמתקינה keylogger. ב. קובץ Excel עם מאקרו שמדביק את כל קובצי ה-Excel האחרים במחשב כשפותחים אותו. ג. תוכנית שסורקת את הרשת, מוצאת מחשבים עם פורט 445 פתוח ומעתיקה את עצמה אליהם. ד. אפליקציית פנס לאנדרואיד ששולחת את אנשי הקשר לשרת בסין.

א. טרויאני ב. וירוס (מאקרו) ג. תולעת ד. טרויאני (spyware)

תרגיל 3 – חישוב חוזק סיסמה

מחשב תקיפה מנסה 10 מיליארד 10^{10} סיסמאות בשנייה. כמה זמן ייקח במקרה הגרוע לפרוץ: א. 6 ספרות. (PIN) ב. 8 אותיות קטנות. ג. 8 תווים מכל 95 התווים. ד. 12 תווים מכל 95 התווים. (חישוב: מספר האפשרויות $10^{10} \div 10^{10}$)

א. $10^6 / 10^{10} = 0.0001$ שנייה. ב. $2.1 \times 10^{11} \approx 26^8 \Rightarrow 21 \sim$ שניות. ג. $95^8 \approx 6.6 \times 10^{15} \Rightarrow 7.6 \sim$ ימים. ד. $95^{12} \approx 5.4 \times 10^{23} \Rightarrow 1.7 \sim$ מיליון שנים. מסקנה: כל תו נוסף מכפיל את הזמן פי 95.

תרגיל 4 – זהו את שלב התקיפה

לתוקף יש את הרצף הבא. סדרו לפי Reconnaissance / Access / DoS, וצינו לכל שלב מה היה אפשר לעשות כדי לעצור אותו:

1. הריץ Nmap על טווח הכתובות של החברה. 2. מצא שרת FTP ישן וניחש את הסיסמה admin/ad-min. 3. העלה לשרת סקריפט שמציף את הראוטר בבקשות. 4. קרא במודעת דרושים שהחברה משתמשת ב-Windows Server 2012.

4. Reconnaissance: (פסיבי), 1 (אקטיבי) – הגנה: מדיניות פרסום, IPS שמזהה סריקות. 2. Access – הגנה: סיסמאות חזקות, כיבוי שירותים מיושנים, 3. DoS: login block. – הגנה: rate limiting, IPS, HIPS. על השרת.

תרגיל 5 – דיון: "אני לא מעניין אף אחד"

תלמיד טוען: "אין לי כלום במחשב, למה שמישהו יתקוף אותי?" תנו 4 סיבות שבגללן גם מחשב "לא מעניין" הוא מטרה.

1. הוא יכול להפוך ל-bot (botnet, DDoS, spam, כריית מטבעות). 2. הסיסמאות שלו כנראה זהות לסיסמאות בחשבונות אחרים. 3. (credential stuffing) הוא קפיצת מדרגה לרשת של ההורים/בית הספר. 4. הזהות שלו (חשבון אינסטגרם, מייל) שווה כסף להונאות. 5. כופרה לא בוררת – היא אוטומטית.

1.11 שאלות בסגנון בגרות – עם פתרונות

שאלה 1

משתמש קיבל "SMS: חבילתך ממתינה. לתשלום מכס של 4.90 ₪ לחץ כאן: post-il.delivery-confirm.xyz". מהו סוג ההתקפה?
1. Ping of Death 2. Smishing 3. Buffer overflow 4. (הנדסה חברתית) 3. תולעת
2. הודעת SMS מתחזה עם דחיפות וסכום קטן שנועד להשיג פרטי כרטיס אשראי. הדומיין אינו של דואר ישראל.

שאלה 2

התאימו: (א) קוד שמצמיד את עצמו לקובץ ומתפשט כשמריצים אותו; (ב) תוכנית שמתפשטת ברשת ללא התערבות משתמש; (ג) תוכנה שנראית כמשחק אך פותחת דלת אחורית. אפשרויות: Worm / Trojan / Virus.
(א) Virus (ב) Worm (ג) Trojan

שאלה 3

תוקף שולח אלפי חבילות SYN לשרת ואינו משיב ל-SYN-ACK. איזו התקפה זו ואיזה עיקרון ב-CIA נפגע?
SYN flood (DoS). נפגעת הזמינות. (Availability) טבלת החיבורים החצי-פתוחים מתמלאת.

שאלה 4

מנהל רשת רוצה שהנתב יחסום ניסיונות התחברות ל-60 שניות לאחר 4 ניסיונות כושלים בתוך 30 שניות. כתבו את הפקודה.
login block-for 60 attempts 4 within 30

שאלה 5

עובד לשעבר שעדיין מחזיק בסיסמה ל-VPN של החברה ומוריד ממנה קבצים – לאיזה סוג תוקף הוא שייך? מה הבקרה (מנהלית) שהייתה מונעת זאת?
Insider. נוהל סיום העסקה (offboarding) שכולל ביטול מידי של כל החשבונות – בקרה מנהלית; ביטול החשבון בפועל – בקרה לוגית.

1.12 הצעה למעבדה / פעילות

- Wireshark – Telnet מול SSH: הריצו Telnet לנתב ב-Packet Tracer (או במעבדה) ולכדו את התעבורה; הראו את הסיסמה בטקסט גלוי. חזרו על זה עם SSH. זה מכין את פרק 2.
- ניתוח 5 הודעות דוא"ל: תנו לתלמידים 5 צילומי מסך (2 phishing, 3) לגיטימיות) ובקשו לסמן את הסימנים. דוגמאות אמיתיות (מטושטשות) עובדות הכי טוב.
- חישוב חוזק סיסמה: חשבו עם התלמידים כמה זמן ייקח לפרוץ סיסמה ב-10¹⁰ ניסיונות/שנייה עבור אורכים שונים. המסקנה – אורך מנצח.

בנק שאלות שתלמידים שואלים – ותשובות מוכנות

אוסף שאלות שתלמידים סקרנים נוטים לשאול בפרק זה, עם תשובות מוכנות. מסודר לפי נושא – סרקו לפני השיעור.

מוטיבציה ותפיסות שגויות

ש: "אין לי מה להסתיר / אני לא מעניין אף אחד, אז למה שיתקפו אותי?"
 ת: רוב ההתקפות אינן ממוקדות אלא תויאנוטיסו תויטמוטוא. גם מחשב "לא מעניין" שווה לתוקף: אפשר להפוך אותו ל-bot ברשת זומבים (פרק 1.4, לגנוב סיסמאות שחוזרות על עצמן באתרים אחרים - credential stuff) (ing), להשתמש בו כקרח קפיצה לרשת של בית הספר/ההורים, או להצפין אותו בכופרה ולדרוש כסף. כופרה לא בוררת מטרות.

ש: "אנטי-וירוס מספיק כדי להיות מוגן?"
 ת: לא. אנטי-וירוס קלאסי מזהה לפי **חתימות** – תבניות של נזקות תועודי. נזקה חדשה (zero-day) או כזו ששונתה מעט (polymorphic) לא תזוהה. לכן צריך "הגנה לעומק": עדכוני מערכת, הגנת רשת (חומת אש/IPS), גיבוי, והכי חשוב – משתמש שלא לוחץ על כל דבר.

ש: "מה זה zero-day?"
 ת: פגיעות שהיצרן עדיין הילע עדוי אל או שאין לה תיקון – "יום אפס" מאז שהתגלתה. תוקף שמחזיק zero-day יכול לנצל אותה בלי שאף הגנה מבוססת-חתימות תזהה אותה. אלה הפגיעויות היקרות והמסוכנות ביותר.

ש: "האקר = פושע?"
 ת: לא בהכרח. White hat – בודק חדירה חוקי, באישור. Black hat – פושע. Gray hat – פורץ ללא אישור אך מדווח. המילה "hacker" במקורה היא מי שמבין מערכות לעומק; התקשורת הצמידה לה משמעות שלילית.

נוזקות

ש: "אז מה בדיוק ההבדל בין וירוס לתולעת? זה מבלבל."
 ת: שאלת המפתח: טשפתיש ידכ שמתשמ לש הלועפ קירצ מאה וירוס נדבק לקובץ וזקוק למשתמש שיריץ אותו. תולעת מתפשטת דבל דרך הרשת בלי אף פעולת אדם (למשל תולעת מוריס, Slammer טרויאני לא משכפל את עצמו כלל – המשתמש מתקין אותו מרצון כי הוא נראה לגיטימי).

ש: "האם מק / לינוקס / אייפון יכולים להידבק בנוזקה?"
 ת: כן, כל מערכת יכולה. Windows הוא היעד הנפוץ ביותר כי הוא הכי נפוץ, אבל יש נזקות ל-macOS, לינוקס, אנדרואיד ו-iOS אף מערכת אינה "חסונה" – זו תפיסה שגויה מסוכנת.

ש: "כדאי לשלם כופר בכופרה?"
 ת: הגישה הרשמית (גם של ה-FBI ומערך הסייבר) היא שלשל אל: אין ערובה שתקבלו מפתח, זה מממן פשע, והופך אתכם ליעד חוזר. הפתרון האמיתי הוא **גיבוי** תקין (פרק 9) שמאפשר לשחזר בלי לשלם.

התקפות והגנה

ש: "אם תוקף מפיל אותנו ב-DDoS, למה שלא פשוט נחסום את הכתובת שלו?"
 ת: כי ב-DDoS אין כתובת אחת – ההתקפה מגיעה בו-זמנית מאלפי מכשירים נגועים (botnet) בכל העולם,

ולעיתים עם כתובות מקור תופיזם. חסימה ידנית לא מספיקה; צריך סינון בקנה מידה גדול, שירותי ניקוי בענן, rate limiting.

ש: "אדם אחד יכול לבצע DDoS?"

ת: כן – אם הוא שולט ב-botnet (רשת מחשבים נגועים) או שוכר אחד בדארקנט ("DDoS כשירות"). ההבחנה היא לא מספר האנשים אלא מספר תורוקם התעבורה: DoS = מקור אחד, DDoS = מקורות רבים.

ש: "איך phishing עוקף אנטי-וירוס?"

ת: כי לרוב אין בו נזקה לסרוק – יש רק קישור לאתר מזויף או בקשה להזין פרטים. זו מניפולציה של סדאה, לא של המחשב. אנטי-וירוס לא "רואה" שאתם מקלידים סיסמה באתר מתחזה.

ש: "אם יש נעילה אחרי 3 ניסיונות, למה צריך בכלל סיסמה חזקה?"

ת: כי לא תמיד התוקף עובר דרך מסך ההתחברות. אם דלף פינותנה דסמ של הסיסמאות (גיבובים), התוקף מריץ מיליארדי ניחושים אופליין על החומרה שלו – שם אין נעילה. סיסמה ארוכה הופכת את זה לבלתי מעשי.

ש: "האם זה חוקי להריץ Nmap או להתקין Kali Linux?"

ת: הכלים עצמם חוקיים לחלוטין (זה כמו פטיש). מה שאסור הוא שומישה בהם על רשת שאינה שלכם וללא אישור בכתב – זו עבירה על חוק המחשבים התשנ"ה-1995. ברשת מעבדה מבודדת שלכם – מותר ומומלץ ללמוד.

ש: "מה ההבדל המדויק בין איום, פגיעות וסיכון?"

ת: **איום** = הגורם המסוכן (האקר, שריפה) – קיים תמיד, לא בשליטתנו. **פגיעות** = החולשה שהאיום מנצל (סיסמה חלשה, פורט פתוח) – זה מה שבשליטתנו. **סיכון** = ההסתברות שהאיום ינצל את הפגיעות, כפול הנזק. מנהלים סיכון על ידי צמצום פגיעויות.

מילון מונחים – הגדרות

הגדרות תמציתיות של המונחים המרכזיים בפרק. שימושי גם כדף עזר לבחינה (מותר מילון מונחים).

מונח	הגדרה
אבטחת מידע (Information Security)	הגנה על מידע ומערכות מפני גישה, שינוי, חשיפה או השמדה בלתי מורשים.
אבטחת רשת (Network Security)	תת-תחום: הגנה על תשתית הרשת ועל התעבורה שעוברת בה.
סודיות (Confidentiality)	הבטחה שרק גורמים מורשים רואים את המידע. מושגת בהצפנה ובבקרת גישה.
שלמות (Integrity)	הבטחה שהמידע לא שונה ללא הרשאה. מושגת בגיבוב וחתימה דיגיטלית.
זמינות (Availability)	הבטחה שהמידע והשירות נגישים כשצריך. נפגעת ב-DoS ובכופרה.
אימות (Authentication)	הוכחת זהות – מי אתה (שם משתמש וסיסמה, ביומטריה).
אי-הכחשה (Non-repudiation)	מניעת אפשרות של השולח להכחיש ששלח; מושגת בחתימה דיגיטלית.
נכס (Asset)	כל דבר בעל ערך שמגנים עליו: מידע, שרת, מוניטין, זמינות.
פגיעות (Vulnerability)	חולשה שניתן לנצל: באג, סיסמה חלשה, פורט פתוח, עובד לא מודרך.
איום (Threat)	גורם שעלול לנצל פגיעות: האקר, נזקה, עובד ממורמר, אסון טבע.
סיכון (Risk)	הסתברות שאיום ינצל פגיעות, כפול הנזק. = איום × פגיעות × ערך הנכס.
בקרה (Control)	אמצעי שמקטין סיכון. מנהלית (נהלים), פיזית (מנעולים), לוגית (הצפנה, ACL).
נוזקה (Malware)	שם כולל לתוכנה זדונית: וירוס, תולעת, טרויאני, כופרה ועוד.
וירוס (Virus)	קוד זדוני שנצמד לקובץ ומתפשט כשמשמש מריץ אותו.

מונח	הגדרה
תולעת (Worm)	תוכנה שמשכפלת ומתפשטת לבד ברשת, ללא פעולת משתמש.
סוס טרויאני (Trojan)	תוכנה שנראית לגיטימית אך מכילה קוד זדוני; אינה משכפלת את עצמה.
כופרה (Ransomware)	נוזקה שמצפינה קבצים ודורשת תשלום; פוגעת בזמינות.
Rootkit	נוזקה שמסתתרת עמוק במערכת ההפעלה ומסווה נזקות אחרות.
Botnet	רשת מחשבים נגועים (זומבים) הנשלטים מרחוק לביצוע התקפות.
Backdoor	דלת אחורית שעוקפת את מנגנון האימות ומאפשרת גישה סמויה.
הנדסה חברתית (Social Engineering)	מניפולציה של בני אדם כדי להשיג מידע או גישה (במקום פריצה טכנית).
Phishing	דוא"ל/הודעה מתחזים המבקשים ללחוץ על קישור או למסור פרטים.
DoS / DDoS	מניעת שירות - הצפת שירות עד קריסה, ממקור אחד (DoS) או ממקורות רבים (DDoS).
SYN flood	הצפת שרת בבקשות SYN חצי-פתוחות עד שטבלת החיבורים מתמלאת.
Buffer overflow	שליחת קלט ארוך מהחוצץ, שגולש ודורס זיכרון ומריץ קוד תוקף.
Brute force	ניסוי שיטתי של כל הסיסמאות האפשריות (או רשימת מילון) עד למציאה.
Reconnaissance	שלב הסיור - איסוף מידע על המטרה (whois, sniffing), סריקת פורטים.
Zero-day	פגיעות שאין לה עדיין תיקון או שאינה ידועה ליצרן.

מטרות: הקשחת נתב ב-CLI · אבטחת גישה · SSH · AutoSecure · syslog/NTP/SNMP ·
בבגרות: line vty / login local / secret, מפתחות RSA ל-SSH, פקודת logging

לפני שמתחילים – איך בכלל מדברים עם נתב? (למי שאין רקע)

כל הפרק הזה עוסק ב"הקשחת נתב" – אבל איך פונים לנתב מלכתחילה? הנה הבסיס: CLI (Command Line Interface) – ממשק שורת פקודה. במקום עכבר וחלונות, מקלידים פקודות טקסט. כל ציוד סיסקו מנוהל כך. IOS – מערכת ההפעלה של ציוד סיסקו (כמו Windows למחשב, רק לנתב). ה-CLI הוא הדרך לדבר איתה. **מצבי עבודה** (Modes) – ל-CLI יש "רמות". הסימן שאחרי שם הנתב מראה איפה אתם: R1> – מצב בסיסי (User) – רק צפייה. R1# – מצב מנהל (Privileged) – אחרי הקלדת enable. אפשר הכול. R1(config)# – מצב הגדרות – אחרי configure terminal. כאן משנים הגדרות. R1(config)# – מצב ממשק – מגדירים כרטיס רשת ספציפי. **קונפיגורציה** (Configuration) – כל ההגדרות של הנתב. יש running-config (הפעילה כרגע בזיכרון, נמחקת בכיבוי) ו-startup-config (השמורה, נטענת באתחול). שומרים עם copy running-config startup-config או write. **ממשק** (Interface) – כרטיס רשת/פורט פיזי בנתב, למשל GigabitEthernet0/0 (בקיצור. g0/0). **דוגמה – כניסה והגדרה ראשונה:** Router> enable ! מעבר למצב מנהל Router# configure terminal ! מעבר למצב הגדרות Router(config)# hostname R1 ! שינוי שם הנתב R1# write R1(config)# exit ! שמירת ההגדרות

2.1 למה הנתב הוא המטרה הראשונה

נתב הקצה (Edge router) הוא הנקודה שבה רשת הארגון פוגשת את האינטרנט. מי ששולט בו יכול לנתב תעבורה לאן שירצה, להאזין לה, לחסום אותה או לפתוח פתח פנימה. שלוש גישות לתכנון:

- **נתב יחיד** – הנתב הוא גם חומת האש. (ACL, ZPF) מתאים לעסק קטן. (SOHO).
- **הגנה לעומק** (Defense in depth) – נתב קצה מסנן גם ⇒ חומת אש ייעודית (ASA) ⇒ נתב פנימי. כל שכבה עצמאית.
- **DMZ** – אזור מפורז בין שתי חומות אש (או בין שני ממשקים של אותה חומה) ובו השרתים הציבוריים (web, mail). אם שרת ב-DMZ נפרץ, התוקף עדיין לא בפנים.

אבטחת הנתב עצמו כוללת שלושה תחומים: **אבטחה פיזית** (חדר נעול, UPS – מי שיש לו גישה פיזית לקונסול יכול לאפס סיסמה דרך (password recovery), **אבטחת מערכת ההפעלה** (גרסת IOS עדכנית, זיכרון מספיק, גיבוי של ה-image והקונפיגורציה) ו**הקשחה** (hardening) – סגירת שירותים מיותרים, סיסמאות, גישה מוצפנת, ניטור. זה ליבת הפרק.

סיפור מהחיים: הנתבים שנשארו עם admin/admin

ב-2016 רשת Mirai הדביקה 600,000 מכשירים – מצלמות אבטחה, ראוטרים ביתיים, מקליטי DVR – בשיטה פרימיטיבית להדהים: היא ניסתה 62 צירופים של שם משתמש וסיסמה מברירת המחדל של היצרנים (admin/admin, root/12345, admin/password). זהו. בלי פגיעות מתוככמת. עם הצבא הזה הופלו ב-DDoS של 1.2 טרה-ביט/שנייה שירותי ה-DNS של Dyn, ואיתו Twitter, Netflix, Spotify ו-PayPal. ליום שלם. כל מה שנלמד בפרק הזה – סיסמה חזקה, SSH במקום Telnet, כיבוי שירותים – היה מונע את ההדבקה. שאלו: כמה מכם שינו את הסיסמה של הראוטר בבית?

2.2 שלוש דרכי ניהול לנתב

ממשק	איך מתחברים	אבטחה
Console	כבל קונסול פיזי, line console 0	מי שמגיע פיזית – שולט. חובה סיסמה + exec-timeout.
AUX	פורט עזר למודם (ישן), line aux 0	לרוב מכבים: / no exec transport input none

ממשק	איך מתחברים	אבטחה
(Virtual Terminal) VTY	Telnet/SSH דרך הרשת, line 5 vty 0 4 קווים וירטואליים ב-0; 4-0 IOS חדש 15-0	הנקודה הרגישה ביותר - חייבים SSH בלבד + אימות משתמשים.

In-band מול Out-of-band (OOB)

In-band - ניהול דרך אותה רשת שמעבירה את תעבורת המשתמשים (SSH) מהמשרד לנתב). זול, אבל אם הרשת נופלת - אין ניהול, ואם התוקף ברשת - הוא רואה את תעבורת הניהול.
Out-of-band (OOB) - רשת ניהול נפרדת פיזית או לוגית: שרת קונסולים, VLAN ניהול ייעודי, מודם/LTE לחירום. עדיף לארגונים; לפחות VLAN ניהול נפרד.

2.3 סיסמאות בנתב - מה ההבדל בין כל הסוגים

```
! מדיניות מינימום
R1(config)# security passwords min-length 10
! סיסמת מצב enable - תמיד secret, לעולם לא password
R1(config)# enable secret Str0ng-P@ss
! קונסול
R1(config)# line console 0
R1(config-line)# password C0ns0le-P@ss
R1(config-line)# login
R1(config-line)# exec-timeout 5 0 ! ניתן אחר 5 דק' חוסר פעילות
R1(config-line)# logging synchronous ! שהודעות לוג לא ישברו את השורה שמקלידים
! הצפנת כל הסיסמאות בטקסט גלוי בקונפיג 7 (type) - חלשה, אבל עדיף מכלום
R1(config)# service password-encryption
```

פקודה	איך נשמר בקונפיג	חוזק
enable password X	טקסט גלוי (type 0)	אפס. לא להשתמש.
service password-encryption	re "type 7"èVigen	חלש - מפוענח באתרים אונליין בשנייה. מגן רק מהצצה מעבר לכתף.
enable secret X	MD5 (type 5), ב-0 IOS חדש script (type 9)	גיבוב חד-כיווני - לא ניתן לשחזר. זה מה שמשתמשים בו.
username admin secret X	גיבוב כמו enable secret	חזק - לחשבוניות מקומיים.
username admin password X	גלוי / type 7	חלש - לא להשתמש.

שאלת תלמיד: "אם הגדרתי גם enable password וגם enable secret - מה קובע?"

ה- secret IOS מתעלם מ- enable password כשקיים enable secret (ומזהיר אם הן זהות). למען הסדר - פשוט לא מגדירים enable password.

שאלת תלמיד: "מה ההבדל בין login ל- login local?"

login - מבקש רק את הסיסמה שהוגדרה בקו עצמו (password בתוך line). כולם משתמשים באותה סיסמה, אין שמות, אין מעקב מי נכנס.
login local - מבקש שם משתמש וסיסמה ומאמת מול מסד המשתמשים המקומי (se- ... username ... cret ...). SSH **דורש שם משתמש ולכן חייב** login local (או AAA זה בדיוק מה שנשאל בבגרות שאלה 2א: התשובה הנכונה היא ... login local + username admin privilege 15 secret).

Telnet 2.4 מול SSH - והגדרת SSH צעד אחר צעד

Telnet (TCP 23) מעביר הכול - כולל שם משתמש וסיסמה - בטקסט גלוי. כל מי שמאזין לרשת (Wireshark) רואה אותם. SSH (Secure Shell, TCP 22) מצפין את כל ההפעלה ומאמת את השרת. SSH גרסה 2 בלבד (גרסה 1 פגיעה).

כדי ש-SSH יעבוד, הנתב צריך **זוג מפתחות RSA** (פרק 7 יסביר לעומק: מפתח ציבורי שנשלח ללקוח ומפתח פרטי שנשאר בנתב). כדי לייצר מפתח הנתב צריך שם מלא $\text{hostname} + \text{domain-name} = \text{FQDN}$, כי השם נכנס למפתח.

```
! 1. שם ייחודי ודומיין - חובה לפני יצירת מפתחות
Router(config)# hostname R1
R1(config)# ip domain-name school.local
! 2. יצירת זוג מפתחות RSA (2048 ביט ומעלה)
R1(config)# crypto key generate rsa general-keys modulus 2048
The name for the keys will be: R1.school.local
! 3. משתמש מקומי
R1(config)# username admin privilege 15 secret Admin-P@ss
! 4. פרמטרים של SSH
R1(config)# ip ssh version 2
R1(config)# ip ssh time-out 60 ! זמן לסיום ההזדהות
R1(config)# ip ssh authentication-retries 2
! 5. קווי VTY - רק SSH, אימות מקומי
R1(config)# line vty 0 4
R1(config-line)# login local
R1(config-line)# transport input ssh ! חוסם Telnet לחלוטין
R1(config-line)# exec-timeout 5 0
! בדיקה
R1# show ip ssh
R1# show ssh ! חיבורים פעילים
R1# show crypto key mypubkey rsa
! חיבור מנתב אחר / ממחשב
R2# ssh -l admin 10.0.0.1
PC> ssh -l admin 10.0.0.1
```

טעויות נפוצות בהגדרת SSH

- שכחו `ip domain-name` ⇒ הפקודה `crypto key generate rsa` נכשלת ("Please define a domain-name first").
- השאירו `hostname "Router"` ⇒ אותה שגיאה.
- הגדירו `login local` במקום `login local SSH` ⇒ דוחה ("Password required, but none set") / אין אימות בשם משתמש).
- מפתח קטן מ-768 ביט לא מאפשר SSHv2. משתמשים ב-1024 לפחות; מומלץ 2048.
- `transport input ssh` חוסם Telnet - אם התלמיד היה מחובר ב-Telnet הוא לא יינתק, אבל חיבור הבא ייכשל. זה מכוון.

בבגרות (שאלה ב5)

"מנהל רשת הפיק מפתחות RSA בנתב. מה ניתן לעשות כעת עם המפתחות?" - ניתן להשתמש בהם לצורך חיבור SSH (ללא צורך באיפוס). Telnet לא משתמש במפתחות כלל.

סיפור מהחיים: Telnet בבית חולים

בבדיקת חדירה בבית חולים (סיפור שמופיע בדוחות של חברות אבטחה רבות), הבודקים חיברו מחשב נייד לשקע רשת בחדר המתנה, הריצו Wireshark, וחיכו. תוך 40 דקות הם לכדו session של Telnet של טכנאי שהתחבר למתג הראשי - שם משתמש וסיסמה בטקסט גלוי. עם הסיסמה הזו הם קיבלו שליטה בכל המתגים

בבניין. הטכנאי לא עשה שום דבר "לא נכון" - הוא פשוט השתמש בכלי שהיה זמין. ההגנה: transport ssh - שורה אחת.

2.5 רמות הרשאה (Privilege Levels) ותצוגות תפקיד (Role-Based CLI Views)

ל-IOS יש 16 רמות הרשאה (0-15). ב-15 פועל משתמש בשלוש:

מה מותר	שם	רמה
disable, enable, exit, help, logout	-	0
פקודות show בסיסיות, ping, login. ברירת מחדל אחרי	(R1>) User EXEC	1
מה שהמנהל מעביר אליהן בעזרת privilege	מותאם אישית	14-2
הכול, כולל configure terminal	(R1#) Privileged EXEC	15

```
! רמה 5: מותר גם reload ו-config-show running-config
R1(config)# privilege exec level 5 reload
R1(config)# privilege exec level 5 show running-config
R1(config)# enable secret level 5 Lvl5-P@ss
R1(config)# username helpdesk privilege 5 secret Help-P@ss
! כניסה לרמה
R1> enable 5
R1# show privilege
Current privilege level is 5
```

מגבלות של רמות: אין שליטה "בין רמות" (רמה 5 מקבלת אוטומטית גם כל מה שמותר ב-1-4), ופקודות show מסוימות חושפות הרבה. הפתרון המדויק יותר: Role-Based CLI Views - "תצוגה" שמכילה רשימת פקודות מדויקת. דורש AAA מופעל.

```
R1(config)# aaa new-model
R1(config)# exit
! נכנסים ל-root view (מבקש enable secret)
R1# configure terminal
R1(config)# parser view MONITOR
R1(config-view)# secret Mon-P@ss
R1(config-view)# commands exec include show ip interface brief
R1(config-view)# commands exec include show ip route
R1(config-view)# commands exec include ping
R1(config-view)# exit
! משתמש שמשויך לתצוגה
R1(config)# username noc view MONITOR secret Noc-P@ss
! בדיקה
R1# enable view MONITOR
R1# show parser view
Current view is 'MONITOR'
```

Superview - תצוגה שמאגדת כמה תצוגות (view MONITOR ⇒ parser view ADMIN superview).

2.6 Banner - אזהרה משפטית

```
R1(config)# banner motd #
** UNAUTHORIZED ACCESS IS PROHIBITED ***
This system is for authorized personnel only.
```

```
All activity is monitored and logged.
```

```
#
```

טיפ: מה לא לכתוב בבאנר

לא "Welcome" (בית משפט בארה"ב קיבל טענה של פורץ ש"הוזמן"), לא שם החברה, לא דגם הנתב, לא שם המנהל. רק אזהרה ותו לא. ה-motd מוצג לפני ההזדהות; login banner מוצג אחרי motd ולפני בקשת שם משתמש; exec banner אחרי הכניסה.

Syslog-2.7 Logging

הנתב מייצר הודעות על אירועים (ממשק עלה/ירד, כניסה כושלת, ACL שחסם). ניתן לשלוח אותן ל: **קונסול** (ברירת מחדל), **קווי VTY** (terminal monitor), **חוצץ בזיכרון** (buffer) - נמחק ב-(reload, ושרת syslog (UDP 514) - היעד הנכון לארגון, כי הלוגים נשמרים גם אם הנתב נפרץ או אופס.

מבנה הודעה

```
*Mar 1 00:12:45.123: %LINK-3-UPDOWN: Interface FastEthernet0/1, changed state to down
^מז ^ראית ^mnemonic ^severity ^facility
```

8 רמות חומרה (Severity) - חובה לזכור

רמה	שם	משמעות
0	Emergencies	המערכת אינה שמישה
1	Alerts	נדרשת פעולה מיידי
2	Critical	מצב קריטי
3	Errors	שגיאה (ממשק נפל)
4	Warnings	אזהרה
5	Notifications	אירוע רגיל אך משמעותי (ממשק עלה, config שונה)
6	Informational	מידע (ACL match)
7	Debugging	פלט debug - עצום, רק לפתרון תקלות

מנמוניקה באנגלית: E very A wesome C isco E ngineer I llW eedN ce-creaml aily.D כשמגדירים רמה - מקבלים אותה וכל מה שחמור ממנה (רמה 0 = 4-4).

```
R1(config)# logging host 2.9.20.22 ! או בקיצור: logging 2.9.20.22 (זו התשובה בבגרות שאלה 2)
R1(config)# logging trap warnings ! שלח לשרת רמות 0-4 (אפשר לכתוב 4)
R1(config)# logging source-interface loopback 0
R1(config)# logging buffered 16384 informational ! חוצץ 16KB, רמות 0-6
R1(config)# service timestamps log datetime msec ! חותמת זמן - חסר טעם בלי NTP
R1(config)# logging on
R1# show logging
```

NTP 2.8 - למה זמן מדויק הוא עניין של אבטחה

לוגים בלי זמן נכון חסרי ערך: אי אפשר לשחזר סדר אירועים בין נתב, חומת אש ושרת. גם תעודות דיגיטליות (פרק 7) ומפתחות IPsec (פרק 8) תלויים בזמן. NTP (Network Time Protocol, UDP 123) מסנכרן את כל הציוד למקור אחד. Stratum - מרחק ממקור הזמן (stratum 0 = שעון אטומי/GPS, stratum 1 = שרת שמחובר אליו ישירות...).

```

NTP נתב כלקוח !
R1(config)# ntp server 10.0.0.5
R1(config)# clock timezone IST 2
! אימות NTP - שלא יזייפו לנו את הזמן
R1(config)# ntp authenticate
R1(config)# ntp authentication-key 1 md5 NtpK3y
R1(config)# ntp trusted-key 1
R1(config)# ntp server 10.0.0.5 key 1
! נתב כשרת NTP לרשת הפנימית
R1(config)# ntp master 3
R1# show ntp status
R1# show ntp associations
R1# show clock

```

SNMP 2.9 - ניטור ציוד, ולמה גרסה 3

SNMP (Simple Network Management Protocol, UDP 161/162) מאפשר לתחנת ניהול (NMS) - PRTG, SolarWinds, Zabbix לקרוא נתונים מהנתב (GET) - תעבורה, CPU ואף לשנות (SET). הנתב יכול גם לשלוח התראות יזומות (trap). הנתונים מאורגנים ב-MIB (עץ של משתנים, כל אחד עם מזהה OID).

גרסה	אימות	הצפנה	הערכה
SNMPv1	Community string בטקסט גלוי public"/"private")")	אין	לא לשימוש
SNMPv2c	Community string בטקסט גלוי	אין	נפוץ, אך חלש - לפחות read-only + ACL
SNMPv3	HMAC + משתמש (MD5/SHA)	DES/AES	היחיד המומלץ . רמות: noAuthNoPriv, authNoPriv, authPriv

```

! v2c מוגבל (אם חייבים): קריאה בלבד ורק מ-NMS
R1(config)# access-list 5 permit host 10.0.0.50
R1(config)# snmp-server community S3cr3tR0 ro 5
! v3 - הדרך הנכונה
R1(config)# snmp-server group ADMINS v3 priv
R1(config)# snmp-server user monitor ADMINS v3 auth sha AuthP@ss priv aes 128 PrivP@ss
R1(config)# snmp-server host 10.0.0.50 version 3 priv monitor
R1(config)# snmp-server enable traps
R1# show snmp

```

2.10 שירותים שסוגרים ו-AutoSecure

ה-IOS מגיע עם שירותים שהיו נחוצים פעם והיום הם רק שטח תקיפה. רשימת הקשחה ידנית:

```

R1(config)# no cdp run ! CDP חושף דגם, IOS וכתובות לשכנים (השאירו על קישורים פנימיים אם צריך)
R1(config)# no ip http server ! ממשק web - או ip http secure-server אם חייבים
R1(config)# no ip finger
R1(config)# no ip bootp server
R1(config)# no service tcp-small-servers
R1(config)# no service udp-small-servers
R1(config)# no ip source-route ! מונע מהשולח להכתיב מסלול
R1(config)# no service pad

```

```
R1(config)# interface g0/0
R1(config-if)# no ip redirects
R1(config-if)# no ip proxy-arp
R1(config-if)# no ip unreachable
R1(config-if)# no ip directed-broadcast (נגד Smurf ברירת מחדל כבר כך)
```

AutoSecure – פקודה אחת שעושה את רוב זה: מכבה שירותים מסוכנים, מפעילה שירותי אבטחה (logging, login block), מקשיחה ממשקים, ומציעה להגדיר SSH ו-CBAC במצב אינטראקטיבי שואלת שאלות; במצב no-interact משתמשת בבירור מחדל.

```
R1# auto secure
R1# auto secure no-interact
R1# show auto secure config
```

שאלת תלמיד: "אז למה לא פשוט להריץ auto secure תמיד?"

כי הוא "עיוור": יכול לכבות CDP שהמתגים צריכים, להפעיל חומת אש (CBAC) שתחסום תעבורה לגיטימית, ואי אפשר לבטל אותו בפקודה אחת (no auto secure לא קיים – צריך לשחזר config). מומלץ להריץ אותו, לבדוק את מה שהוא שונה עם show auto secure config, ולכוון.

2.11 שמירה על ה-IOS והקונפיג – Resilient Configuration

תוקף שהשיג גישה יכול למחוק את ה-IOS ואת ה-startup-config ולהשבית את הנתב. תכונת IOS Resilient Configuration שומרת עותק מוגן (bootset) שלא ניתן למחוק מה-CLI, גם לא ב-format flash.

```
R1(config)# secure boot-image
R1(config)# secure boot-config
R1# show secure bootset
R1(config)# secure boot-config restore flash:rescue-cfg ואז ROMMON > boot flash:<image> שחזור!
```

גיבוי שוטף: tftp running-config archive / copy + path + time-period לניבוי אוטומטי.

2.12 ביקורת חשבונות (Auditing)

לדעת מי עשה מה ומתי. הכלים בפרק זה: login on-success log / login on-failure log, archive log config (רישום כל פקודת config עם שם המשתמש), syslog מרכזי, ו-show users לראות מי מחובר עכשיו. הרחבה מלאה – Accounting של AAA בפרק 3.

```
R1(config)# archive
R1(config-archive)# log config
R1(config-archive-log-cfg)# logging enable
R1(config-archive-log-cfg)# hidekeys ! לא לרשום סיסמאות
R1# show archive log config all
```

2.13 SDM / CCP – מה זה ומה אומרים לתלמידים

תכנית הלימודים מזכירה "SDM לוריפיקציה". SDM (Security Device Manager) היה ממשק גרפי מבוסס Java שרץ בדפדפן מול הנתב והציע אשפים (wizards) ל-SSH, חומת אש, VPN ו-"Security Audit" – סריקה שמציגה רשימת שירותים מסוכנים ומציעה לתקן בלחיצה ("One-step lockdown", המקבילה הגרפית של Au-toSecure). SDM הוחלף ב-CCP (Cisco Configuration Professional) ב-2009, ו-CCP הופסק ב-2015. **הבגרות בודקת CLI בלבד.** אמרו לתלמידים: "קיימים ממשקים גרפיים; אנחנו לומדים CLI כי הוא אוניברסלי, מדויק ונשאל בבחינה".

2.14 מדריך פקודות מרוכז – פרק 2

תפקיד	מצב	פקודה
סיסמת enable מגובבת	config	enable secret X
מסתיר סיסמאות type 7	config	service password-encryption
אורך סיסמה מינימלי	config	security passwords min-length N
משתמש מקומי	config	username U privilege 15 secret P
הגנה מ-brute force	config	login block-for S attempts N within T
הכנה ל-SSH	config	/ip domain-name D crypto key generate rsa
SSHv2 בלבד	config	ip ssh version 2
גישה מרחוק מאובטחת	line	login → line vty 0 4 transport input local ssh
ניתוק חוסר פעילות	line	exec-timeout M S
העברת פקודה לרמה	config	privilege exec level N CMD
תצוגת תפקיד	aaa (config new-model)	parser view V
אזהרה	config	banner motd #...#
syslog	config	/logging host IP logging trap LEVEL
זמן	config	ntp/ntp server IP authenticate
ניטור	config	snmp-server ...
הקשחה אוטומטית	exec	auto secure
הגנה על IOS וקונפיג	config	/secure boot-image secure boot-config
ורטיפיקציה	exec	show, show ip ssh show ntp, logging , show privilege, status show login

2.15 תרגילים לתלמידים

תרגיל 1 - מצאו את 5 הבעיות בקונפיג

```
Router(config)# enable password cisco Router(config)# line vty 0 4 Router(config-line)#
password cisco Router(config-line)# login Router(config-line)# transport input telnet
Router(config)# # !Router(config)# banner motd # Welcome to ACME Corp main router
snmp-server community public rw
```

1. enable password במקום enable secret (טקסט גלוי). 2. hostname. 3. SSH. סיסמה חלשה "cisco" ובלי שם משתמש (login במקום login). 4. transport input telnet - לא מוצפן; צריך. 5. ssh. באנר "Welcome" עם שם החברה. 6. SNMP community "public" עם הרשאת rw - כל אחד יכול לשנות את הקונפיג. 7. אין exec-timeout. (כל 5 מתוך 7 מתקבלים).

תרגיל 2 - סדר נכון

סדרו את הפקודות הבאות בסדר שבו חייבים להקליד אותן כדי ש-SSH יעבוד: crypto key generate username · hostname R1 · transport input ssh · ip domain-name lab.local · rsa

```
line vty 0 4 · login local · admin secret P@ss
```

username admin → crypto key generate rsa → ip domain-name lab.local → hostname R1
transport input ssh. (username → login local → line vty 0 4 → secret P@ss
crypto key.) מקום לפני domain-name ו-login local; hostname לפני

תרגיל 3 – syslog

הנתב הגדיר 4 logging trap. סמנו אילו מההודעות יגיעו לשרת:
א. %SEC_LOGIN-3-UPDOWN. ב. %SYS-5-CONFIG_I: Configured from console. ג. %SEC_LOGIN-3-UPDOWN. ד. %SEC-6-IPACCESSLOGP. ה. %OSPF-5-ADJCHG. ו. %SEC-6-IPACCESSLOGP.
ב (3) ו-ג (4) יגיעו. א (5), ד (6), ה (5) לא – חמורים פחות מ-4. **מנומניקה:** המספר במרכז ההודעה הוא רמת החומרה.

תרגיל 4 – תכנון

אתם מנהלי הרשת של בית ספר עם 3 נתבים ו-12 מתגים. כתבו רשימת 8 צעדי הקשחה שתבצעו על כל מכשיר, לפי סדר עדיפות, ונמקו את הראשון.
דוגמה: enable secret + username secret (בלי זה – כל השאר חסר ערך). 2. SSH בלבד, כיבוי HTTP, CDP לשרת מרכזי. 3. login block-for. 4. exec-timeout. 5. syslog + NTP config. 6. secure boot-image/config. 7. SNMPv3 קצה. 8. banner. 9. גיבוי small servers. 10. גיבוי boot-image/config.

2.16 שאלות בסגנון בגרות

שאלה 1

מנהל רשת הקליד: R1 hostname, crypto key generate rsa – וקיבל שגיאה. מה חסר?
ip domain-name. יצירת מפתחות RSA דורשת. FQDN (hostname + domain).

שאלה 2

מהו הסדר הנכון של רמות חומרה ב-syslog מהחמורה לקלה: Warning, Emergency, Debugging, Error?
Debugging (7). → Warning (4) → Error (3) → Emergency (0)

שאלה 3

השלימו כדי לאפשר גישה מרחוק ב-Ssh בלבד עם אימות מול משתמש מקומי:
R1(config)# line vty 0 4
R1(config-line)# _____
R1(config-line)# _____
login local ו-transport input ssh.

שאלה 4

מנהל הגדיר 3 logging trap. אילו הודעות יישלחו לשרת ה-syslog?
רמות 0-3: Emergencies, Alerts, Critical, Errors. הודעות Warning ומטה לא יישלחו.

שאלה 5

נכון / לא נכון: (א) service password-encryption מצפין את הסיסמאות באופן שאינו ניתן לפענוח.
(ב) SNMPv3 תומך בהצפנה. (ג) NTP משתמש ב-TCP (ד) SSH גרסה 1 מאובטחת יותר מגרסה 2.

(א) לא נכון - type 7, ניתן לפענוח בקלות. (ב) נכון. (ג) לא נכון. - UDP 123 (ד) לא נכון.

שאלה 6

איזו פקודה תגרום לנתב לנתק משתמש בקונסול לאחר 3 דקות ללא פעילות?

0 line console → 0 3 exec-timeout.

2.17 מעבדה (2 שעות) - הקשחת נתב ב-Packet Tracer

1. טופולוגיה: PC — Switch — R1 — Server-PT Syslog/NTP server עם שירותי SYSLOG ו-NTP מופעלים).
2. הגדירו: hostname, enable secret, min-length, service password-encryption, banner.
3. הגדירו SSH לפי 2.4. נסו Telnet - ודאו שנכשל. התחברו ב-SSH מה-PC.
4. הפעילו 30 within 3 login block-for 60 attempts; נסו 3 סיסמאות שגויות; ראו ב-show login את מצב ה-quiet mode.
5. הגדירו logging לשרת ו-logging trap informational; כבו והדליקו ממשק; ראו את ההודעה בשרת Syslog.
6. הגדירו NTP מול השרת; ודאו ב-show ntp status ש-synchronized.
7. צרו משתמש ברמה 5 שיכול רק show running-config; בדקו שאינו יכול להיכנס ל--configure terminal.

בנק שאלות שתלמידים שואלים - ותשובות מוכנות

שאלות נפוצות בפרק הקשחת הנתב, עם תשובות מוכנות.

סיסמאות וגישה

ש: "אם אני שם סיסמה חזקה ל-Telnet, למה בכל זאת צריך SSH?"
ת: כי Telnet מעביר את לוכה בטקסט גלוי, כולל את הסיסמה החזקה עצמה. כל מי שמאזין לרשת (Wireshark) רואה אותה. SSH מצפין את כל התקשורת. חוזק הסיסמה לא עוזר אם היא נשלחת גלויה.

ש: "מה ההבדל בין password ל-secret?"
ת: secret נשמר כינוי-דח בוביג (לא ניתן לשחזר). password נשמר גלוי, ואפילו עם service password-encryption הוא רק "7" type שמפוענח באתר אונליין בשנייה. תמיד להשתמש ב-secret.

ש: "אם service password-encryption זו הצפנה, למה היא חלשה?"
ת: כי זה אלגוריתם הפיך וישן (וריאציה על Vigen). re) הוא מגן רק מפני מישהו שמציץ מעבר לכתף בזמן שאתם צופים בקונפיג - לא מפני תוקף אמיתי. ה"חוזק" האמיתי הוא ב-secret (גיבוב).

ש: "מה קורה אם שכחתי את ה-enable secret?"
ת: יש הליך password recovery דרך גישה פיזית לקונסול: מאתחלים, נכנסים ל-ROMMON, משנים את ה-(0x2142) configuration register כדי לדלג על ה-startup-config, ומגדירים סיסמה חדשה. המסקנה החשובה: וב טלוש - בתנל תיזיפ השיג ול שיש ימ, ולכן אבטחה פיזית קריטית.

ש: "מה ההבדל בין רמות הרשאה (privilege levels) לתצוגות (views)?"
ת: רמות הרשאה גסות - רמה נתונה מקבלת אוטומטית גם את כל מה שמתחתיה. תצוגות (parser view) מדויקות - מגדירים רשימת פקודות מדויקת לכל תפקיד, אך דורשות שה-AAA יופעל.

SSH

ש: "למה צריך ip domain-name כדי ליצור מפתחות SSH?"
ת: כי שם המפתח נגזר מהשם המלא של הנתב = hostname + domain-name (FQDN). לא יודע איזה שם לתת למפתח, והפקודה נכשלת עם "Please define a domain-name first".

ש: "אחרי transport input ssh ניתקתי בטעות את Telnet - זו טעות?"
ת: לא, זה בדיוק מה שרוצים - לחסום את Telnet הלא-מאובטח ולאפשר רק SSH. חיבור Telnet חדש ייכשל, וזו התנהגות רצויה.

שירותים וניטור

ש: "למה זמן מדויק (NTP) קשור לאבטחה בכלל?"

ת: כי בלי זמן מסונכרן, הלוגים מכל המכשירים לא ניתנים לשחזור – אי אפשר לדעת מה קרה לפני מה כשחוקרים אירוע. בנוסף, תעודות דיגיטליות ומפתחות VPN תלויים בזמן נכון.

ש: "SNMPv2 באמת כל כך גרוע?"

ת: הבעיה שלו היא ה-community string (ולעיתים נשאר "public" אם חייבים v2c) – לפחות read-only + הגבלה ב-ACL לכתובת תחנת הניהול. אבל הנכון הוא v3, שמוסיף אימות (HMAC) והצפנה.

ש: "אז למה שלא נריץ תמיד auto secure ונגמור עם זה?"

ת: כי הוא "עיוור" – יכול לכבות CDP שהמתגים צריכים, להפעיל חומת אש שתחסום תעבורה לגיטימית, ואי אפשר לבטלו בפקודה אחת. מריצים אותו, בודקים מה שינה עם `show auto secure config`, ומכוונים.

ש: "מה זה בעצם CLI, ולמה לא ללמוד ממשק גרפי?"

ת: CLI הוא ממשק שורת הפקודה של הנתב. אנחנו לומדים אותו כי הוא אוניברסלי (עובד על כל ציוד סיסקו וגם דרך SSH, מדויק, וניתן לאוטומציה – דבלב ותוא תקדוב תורגבהו. הממשקים הגרפיים (SDM/CCP) יצאו משימוש.

מילון מונחים – הגדרות

הגדרות תמציתיות של המונחים המרכזיים בפרק. שימושי גם כדף עזר לבחינה (מותר מילון מונחים).

מונח	הגדרה
CLI (Command Line Interface)	ממשק שורת פקודה לניהול ציוד רשת בהקלדת פקודות טקסט.
IOS	מערכת ההפעלה של ציוד סיסקו.
running-config	ההגדרות הפעילות בזיכרון; נמחקות בכיבוי אם לא נשמרו.
startup-config	ההגדרות השמורות שנטענות באתחול הנתב.
Console / VTY / AUX	דרכי גישה לנתב: קונסול (פיזי), VTY (מרחוק ברשת), AUX (מודם ישן).
In-band / OOB	ניהול דרך רשת הנתונים (In-band) או דרך רשת ניהול נפרדת (Out-of-band).
enable secret	סיסמת מצב מנהל, נשמרת כגיבוב חד-כיווני (בטוח).
service password-encryption	מסתיר סיסמאות בקונפיג בהצפנה חלשה (type 7) – מגן רק מהצצה.
SSH (Secure Shell)	פרוטוקול ניהול מרחוק מוצפן (פורט 22); מחליף את Telnet הלא-מאובטח.
Telnet	פרוטוקול ניהול מרחוק לא מוצפן (פורט 23) – מסוכן, לא לשימוש.
מפתחות RSA	זוג מפתחות (ציבורי/פרטי) שהנתב מייצר כדי לאפשר הצפנת SSH.
רמות הרשאה (Privilege levels)	16 רמות (0)–(15) הקובעות אילו פקודות מותרות; 15 = הכול.
Parser View	תצוגת תפקיד – רשימת פקודות מדויקת למשתמש; דורשת AAA.
Banner	הודעת אזהרה משפטית המוצגת בכניסה לנתב.
Syslog	מנגנון יומן אירועים; שולח הודעות לשרת מרכזי (UDP 514).
Severity levels	8 רמות חומרה ליומן (0=Emergency החמור ביותר עד 7=Debug).
NTP (Network Time Protocol)	מסנכרן שעונים בכל הציוד (UDP 123); קריטי ללוגים ולתעודות.
SNMP	פרוטוקול לניטור ציוד (UDP 161); גרסה 3 בלבד מאובטחת.

מונח	הגדרה
AutoSecure	פקודה שמבצעת הקשחה אוטומטית של הנתב בצעד אחד.
Hardening (הקשחה)	סגירת שירותים מיותרים והגדרות אבטחה למזעור שטח התקיפה.
err-disabled	מצב שבו פורט מושבת אוטומטית עקב הפרת אבטחה.

פרק 3 - מודל ה-AAA

11 שעות עיוני + 3 מעשי · שבועות 7-9

מטרות: מודל AAA · שרתי (ACS/ISE) + TACACS + RADIUS עם מפתחות מוצפנים
בבגרות: הגדרת שלושת השירותים, aaa new-model, RADIUS מול TACACS

לפני שמתחילים - מה זו בכלל "הזדהות"? (למי שאין רקע)

כשאתם נכנסים לחשבון (מייל, בנק, נתב) קורים שלושה דברים שאנשים נוטים לבלבל - וזה בדיוק מה שמודל AAA מסדר: **הזדהות** (Authentication) - להוכיח התא ימ (שם משתמש + סיסמה). כמו להראות תעודת זהות. **הרשאה** (Authorization) - לקבוע ל רתום ה אחרי שנכנסת (לצפות בלבד? לשנות הכול?). כמו דרגת גישה בעבודה. **רישום** (Accounting) - לתעד תישע ה (מתי נכנסת, אילו פקודות הקלדת). כמו יומן מעקב. **למה מרכזי?** בלי מערכת מרכזית, כל נתב מחזיק רשימת משתמשים משלו. אם יש 50 נתבים ועובד עוזב - צריך למחוק אותו מ-50 מקומות. מודל AAA מאפשר "מקום אחד" שכל הנתבים שואלים אותו (שרת). זה כל הרעיון.

מושג שיחזור: שרת = מחשב מרכזי שנותן שירות (כאן: שירות "מי מורשה"). **לקוח** של השרת הזה = הנתב עצמו, ששואל את השרת "האם להכניס את המשתמש הזה?".

הערה על תכנית הלימודים

רשימת הנושאים של פרק 3 בתכנית הרשמית הועתקה בטעות מפרק 2. הפרק כאן בנוי לפי המטרות של פרק 3 - שהן גם בדיוק מה שהבגרות שואלת.

3.1 שלוש ה-A

עד עכשיו כל האימות היה **מקומי**: שם משתמש וסיסמה בקונפיג של כל נתב. זה לא מתרחב: 50 נתבים $\times$ 10 מנהלים = 500 חשבונות לתחזוק, ועובד שעוזב צריך להימחק מ-50 מקומות. AAA הוא המסגרת שפותרת את זה - בין אם המשתמשים מקומיים ובין אם בשרת מרכזי.

דוגמה	הגדרה (כפי שנדרש בבגרות)	השאלה שהוא עונה עליה	שירות
שם משתמש + סיסמה, כרטיס חכם, טביעת אצבע	זיהוי ואימות משתמשים	מי אתה?	Authentication (אימות)
רמה 15 או רק show; גישה ל-VLAN 10 בלבד; מותר reload?	ניהול הרשאות	מה מותר לך לעשות?	Authorization (הרשאה)
נכנס ב-08:12, הקליד reload ב-08:14, ניתק ב-08:15; 2GB תעבורה	רישום למעקב של פעולות המשתמש	מה עשית, מתי וכמה?	Accounting (רישום/חיוב)

שאלת תלמיד: "מה ההבדל בין Authentication ל-Authorization? זה נשמע אותו דבר"

המשל שעובד: שדה תעופה. **אימות** = בדיקת הדרכון בכניסה - מוודאים שאתה מי שאתה טוען. **הרשאה** = כרטיס הטיסה - גם אחרי שידוע מי אתה, מותר לך לעלות רק לטיסה שלך ולא לכל מטוס. Accounting = רישום הנוסעים - מי עלה, מתי, עם כמה מזוודות. אי אפשר לעשות הרשאה בלי אימות קודם, אבל אימות לבד לא אומר שמותר לך הכול.

גורמי אימות (Authentication factors)

- **משהו שאתה יודע** - סיסמה, PIN.
- **משהו שיש לך** - טלפון (OTP/SMS), טוקן, כרטיס חכם.
- **משהו שאתה** - ביומטריה: טביעת אצבע, פנים.

סיפור מהחיים: מנהל הרשת שפוטר ביום שלישי

בחברת שירותי אינטרנט בינונית פיטרו מנהל רשת. המנכ"ל ביקש מה-IT לבטל לו את הגישה". ה-IT מחק את חשבון ה-Windows שלו. אבל ב-40 הנתבים והמתגים היו חשבונות מקומיים (username בקונפיג) – שהוא עצמו יצר. שלושה ימים אחר כך, ב-2 בלילה, כל הנתבים "אבדו" את הקונפיג. אף אחד לא ידע מי עשה את זה – כי לא היה Accounting, ובלוג היה רק "admin עם AAA מבוסס שרת: לחיצה אחת ב-ISE הייתה מנתקת אותו מכל הציוד, וה-accounting היה מראה שם מלא, שעה ופקודה. זה בדיוק "למה. AAA".

3.2 שני מצבי AAA: מקומי ומבוסס-שרת

AAA מבוסס שרת (Server-based)	AAA מקומי (Local / Self-contained)	
בשרת מרכזי, (Cisco ISE / ACS, FreeRADIUS, Windows NPS)	בקונפיג של הנתב (username)	איפה המשתמשים
RADIUS או TACACS+ בין הנתב לשרת	-	פרוטוקול
ארגונים: ניהול מרכזי, מדיניות אחידה, לוג מרכזי	רשתות קטנות, גיבוי (fallback) כשהשרת לא זמין	מתאים ל

בטרמינולוגיה: הנתב/מתג/ASA שפונה לשרת נקרא NAS (Network Access Server) או AAA client. השרת מחזיק את מסד המשתמשים – או פונה בעצמו ל-Active Directory / LDAP.

3.3 AAA מקומי – הפקודות

```
! 1. הפעלת המודל – מרגע זה כל ה-lines משתמשות ב-AAA (ולא ב-login / login local)
R1(config)# aaa new-model
! 2. משתמש מקומי
R1(config)# username admin privilege 15 secret Adm1n-P@ss
! 3. רשימת שיטות אימות ברירת מחדל: local
R1(config)# aaa authentication login default local
! 4. רשימה בשם – למשל לקונסול: ללא אימות (זהירות!) או enable password
R1(config)# aaa authentication login CONSOLE-LIST local-case
R1(config)# line console 0
R1(config-line)# login authentication CONSOLE-LIST
```

הטעות המסוכנת ביותר בפרק

aaa new-model משנה מיד את התנהגות כל הקווים. אם הקלדתם אותה בלי משתמש מקומי ובלי aaa authentication login default (ברירת המחדל אחרי aaa new-model היא local, ואם אין username – אין כניסה). כלל ברזל: קודם username, אחר כך aaa new-model, ותמיד להשאיר חלון SSH אחד פתוח עד שבדקים בחלון שני.

שיטות אימות (methods) אפשריות ברשימה: local, local-case (תלוי רישיות), enable (סיסמת en-able), group radius, group tacacs+, group none (ללא אימות – רק לקונסול בבדיקות). ניתן לשרשר: הנתב מנסה את הראשונה; **רק אם היא לא זמינה** (שרת לא עונה) הוא עובר לבאה. תשובת "סיסמה שגויה" מהשרת אל גורמת למעבר לשיטה הבאה.

3.4 RADIUS מול TACACS+ – הטבלה שחייבים לדעת

	RADIUS	+TACACS
מי פיתח / תקן	תקן פתוח (IETF, RFC 2865)	Cisco (קנייני, אך מפורסם)

	RADIUS	+TACACS
שכבת תעבורה	UDP - פורטים 1812 (אימות) ו-1813 (accounting); ישן: 1645/1646	TCP - פורט 49
הצפנה	רק שדה הסיסמה מוצפן בבקשת הגישה (Access-Request); שם המשתמש ושאר המידע גלויים	כל גוף החבילה מוצפן (רק הכותרת גלויה)
הפרדת השירותים	אימות והרשאה משולבים בתגובה אחת (Access-Accept) מכיל גם את ההרשאות. לא ניתן לבצע הרשאה ללא אימות	שלושת השירותים נפרדים - ניתן לבצע אימות מול AD והרשאה מול +TACACS
הרשאה לכל פקודה	לא נתמך	נתמך - כל פקודה ש-המנהל מקליד נשלחת לאישור בשרת קיים, לרוב לרישום פקודות
Accounting	מפורט וחזק - פותח לחיוב (ISP)	קיים, לרוב לרישום פקודות
ריבוי פרוטוקולים	IP בלבד (בעיקר)	תומך גם ב-AppleTalk, NetBIOS וכו' (היסטורי)
שימוש אופייני	גישת משתמשים לרשת: Wi-Fi/802.1X, VPN מרחוק, דיאל-אפ	ניהול ציוד (device administration): מנהלי רשת שמתחברים לנתבים ולמתגים

בבגרות (שאלה 4) - נכון/לא נכון

1. RADIUS מצפין רק את הסיסמה כשהוא שולח "בקשת גישה" - נכון.
2. RADIUS מבצע אימות משתמשים ולא מתייחס לניהול הרשאות - נכון (במובן שאין הפרדה/הרשאה עצמאית; ההרשאות מגיעות רק כחלק מתשובת האימות).
3. TACACS+ משתמש רק ב-UDP - לא נכון. (TCP 49).
4. TACACS+ מספק שירות AAA - נכון.

שאלת תלמיד: "למה RADIUS על UDP אם TCP אמין יותר?"

RADIUS תוכנן ב-1991 לשרתי דיאל-אפ עם אלפי חיבורים; UDP קל, ללא לחיצת יד, והלקוח פשוט שולח שוב אם לא קיבל תשובה. TACACS+ בחר TCP כי הוא מנהל שיחה רב-שלבית (שאלה-תשובה-שאלה) ורוצה לדעת מיד אם השרת נפל. שניהם עובדים היום; ההבדל המעשי החשוב הוא ההצפנה והפרדת השירותים.

שיחה אופיינית - RADIUS

משתמש → NAS (נתב) → שרת RADIUS

1. המשתמש מקליד שם וסיסמה. 2. הנתב שולח Access-Request (הסיסמה מוצפנת עם ה-shared secret + MD5). 3. השרת עונה Access-Accept (עם VLAN - attributes, רמת הרשאה) / Access-Reject (נדרש גורם נוסף). 4. הנתב שולח Accounting-Request (start), ובסוף (stop).

שיחה אופיינית - TACACS+

שלוש שיחות נפרדות

Authentication: START → REPLY (GETPASS) → CONTINUE (שם) → REPLY (GETUSER) → CONTINUE (סיסמה) → REPLY (PASS/FAIL). Authorization: REQUEST → REPLY (הפקודה שהוקלדה) → SPONSE (PASS_ADD/FAIL). Accounting: REQUEST (start/stop/watchdog)

סיפור מהחיים: למה ה-Wi-Fi באוניברסיטה שואל שם משתמש - ובבית קפה סיסמה

ברשת eduam (שפועלת גם באוניברסיטאות בישראל) סטודנט מחיפה מתחבר ל-Wi-Fi באוניברסיטה בברלין עם החשבון של הטכניון. איך? המחשב שולח שם משתמש ל-Access Point (802.1X), ה-AP

הוא רק Authenticator ומעביר את הבקשה לשרת RADIUS בברלין, שרואה "@technion.ac.il" ומעביר לשרת RADIUS בטכניון, שמאמת ומחזיר Access-Accept. שרת RADIUS אחד לא צריך להכיר את כל המשתמשים בעולם – רק לדעת למי להעביר. זו הסיבה ש-RADIUS הוא "פרוטוקול גישה המשתמשים לרשת", ו-TACACS+ נשאר לניהול הציוד.

3.5 Cisco ACS ו-ISE

ACS (Access Control Server) – שרת ה-AAA ההיסטורי של סיסקו (התכנית מזכירה אותו). תמך ב-RADIUS וב-TACACS+, עם GUI לניהול משתמשים, קבוצות ומדיניות. הוחלף ב-ISE (Identity Services Engine) – שרת מדיניות שעושה AAA, 802.1X, NAC, פרופילינג של מכשירים ו-BYOD. חלופות חינוכיות: FreeRADIUS, TACACS+ daemon, ו-RADIUS Windows NPS (על Windows Server). Packet Tracer יש שרת AAA מובנה שתומך בשניהם.

3.6 הגדרת AAA מבוסס-שרת ב-CLI

+TACACS

```
R1(config)# aaa new-model
! תחביר חדש (IOS 15+)
R1(config)# tacacs server ISE1
R1(config-server-tacacs)# address ipv4 10.0.0.5
R1(config-server-tacacs)# key T@cacK3y shared secret ! חייב להיות זהה בשרת
R1(config-server-tacacs)# single-connection ! חיבור TCP אחד לכל השיחות
R1(config-server-tacacs)# exit
! תחביר ישן (וב-Packet Tracer)
R1(config)# tacacs-server host 10.0.0.5 key T@cacK3y
! אימות: קודם TACACS+, ואם השרת לא זמין – מקומי
R1(config)# aaa authentication login default group tacacs+ local
```

RADIUS

```
R1(config)# radius server NPS1
R1(config-radius-server)# address ipv4 10.0.0.6 auth-port 1812 acct-port 1813
R1(config-radius-server)# key R@diusK3y
R1(config-radius-server)# exit
! תחביר ישן (וב-Packet Tracer)
R1(config)# radius-server host 10.0.0.6 key R@diusK3y
R1(config)# aaa authentication login default group radius local
```

קבוצת שרתים (server group) – כמה שרתים, ולפי סדר

```
R1(config)# aaa group server tacacs+ MY-TACACS
R1(config-sg-tacacs)# server name ISE1
R1(config-sg-tacacs)# server name ISE2
R1(config)# aaa authentication login default group MY-TACACS local
```

שאלת תלמיד: "מה זה ה-key? זה הסיסמה של המשתמש?"

לא. ה-key (shared secret) הוא סוד משותף בין הנתב לשרת, שמשמש להצפנת התקשורת ביניהם ולאימות שהנתב הוא באמת לקוח מורשה של השרת. סיסמאות המשתמשים נמצאות בשרת. שני מפתחות שונים לגמרי: המפתח בין הציוד לשרת, והסיסמה של האדם. "מפתחות מוצפנים" בתכנית הלימודים = ה-key הזה.

3.7 Authorization – הרשאות

```

! מי רשאי לקבל (EXEC) shell ובאיזו רמה
R1(config)# aaa authorization exec default group tacacs+ local
! אישור כל פקודה ברמה 15 מול השרת (TACACS+) (בלבד)
R1(config)# aaa authorization commands 15 default group tacacs+ local
! הרשאות לשירותי רשת (PPP, VPN) - בדרך כלל RADIUS
R1(config)# aaa authorization network default group radius
! שהפקודות בקונפיג עצמו (config mode) גם יאושרו
R1(config)# aaa authorization config-commands

```

שימו לב: אחרי `aaa authorization exec default group tacacs+ local`, אם השרת מחזיר 15 privilege - המשתמש נכנס ישירות ל-R1# בלי enable. זה נוח ומאובטח (אין סיסמת enable משותפת).

Accounting 3.8 - רישום

```

! רישום התחלה וסיום של כל session
R1(config)# aaa accounting exec default start-stop group tacacs+
! רישום כל פקודה ברמה 15 - "מי הקליד reload"?
R1(config)# aaa accounting commands 15 default start-stop group tacacs+
! חיבורי רשת (VPN/PPP) - חיוב לפי זמן/נפח
R1(config)# aaa accounting network default start-stop group radius

```

אפשרויות: start-stop (רשומה בהתחלה ובסוף), stop-only (רק בסיום, עם סיכום), none.

802.1X AAA - לפורט של מתג (הצצה לפרק 6)

RADIUS משמש גם לאימות מכשירים לפני שמקבלים גישה לרשת: תקן IEEE 802.1X. שלושה תפקידים: Sup- plicant (המחשב/הטלפון), Authenticator (המתג או ה-Access Point - חוסם את הפורט עד לאימות), Authentication Server (RADIUS). ה-Authentication Server (RADIUS) הפרוטוקול בין ה-supplicant למתג: EAP over LAN (EAPOL); בין המתג ל-RADIUS. זה הבסיס ל-NAC (פרק 6) ול-WPA2-Enterprise.

```

S1(config)# aaa new-model
S1(config)# radius-server host 10.0.0.6 key R@diusK3y
S1(config)# aaa authentication dot1x default group radius
S1(config)# dot1x system-auth-control
S1(config)# interface f0/1
S1(config-if)# switchport mode access
S1(config-if)# authentication port-control auto
S1(config-if)# dot1x pae authenticator

```

3.10 בדיקה ופתרון תקלות

```

R1# show aaa sessions
R1# show aaa user all
R1# show tacacs
R1# show radius statistics
R1# test aaa group tacacs+ admin AdmIn-P@ss legacy ! בודק אימות מול השרת בלי להתחבר
R1# debug aaa authentication
R1# debug tacacs
R1# debug radius

```

תסמין	סיבה נפוצה
הנתב "נתקע" 10-20 שניות ואז מקבל את המשתמש המקומי	השרת לא נגיש (IP/ACL)/שירותי כבוי - ה-fallback ל-local עבד. בדקו ping לשרת ו-tacacs debug.

תסמין	סיבה נפוצה
Authentication failed" גם עם סיסמה נכונה	ה-key לא תואם בין הנתב לשרת; או שהשרת לא מכיר את ה-IP של הנתב כלקוח (AAA client). ב-Packet Tracer: בדקו ב-Server → AAA → Client Name/IP/Secret.
המשתמש נכנס אבל לא מקבל רמה 15	חסר aaa authorization exec attribute (shell:priv-lvl=15 לא מחזיר את ה- TACACS+; Service-Type / cisco-avpair ב-RADIUS).
הקונסול דורש אימות שרת ואין שרת	שכחו רשימה נפרדת לקונסול. תמיד: aaa authentication login CONSOLE local login authentication CONSOLE + con 0.

3.11 מדריך פקודות מרוכז - פרק 3

תפקיד	פקודה
הפעלת AAA (בבגרות: "הפקודה שתגרום לנתב לעבוד עם מודל AAA")	aaa new-model
רשימת אימות: שרת ואז מקומי	aaa authentication login default group tacacs+ local
רשימה בשם לקו ספציפי	+ aaa authentication login NAME ... login authentication NAME (ב-line)
הגדרת שרת TACACS+	tacacs/tacacs-server host IP key K server NAME
הגדרת שרת RADIUS	radius/radius-server host IP key K server NAME
קבוצת שרתים	aaa group server tacacs+ G
הרשאת shell	aaa authorization exec default ...
הרשאה לכל פקודה	aaa authorization commands 15 default ...
רישום	aaa accounting exec/commands/network default start-stop ...
בדיקה	debug aaa, show aaa sessions test aaa, authentication

3.12 תרגילים לתלמידים

תרגיל 1 - איזה A?

לכל משפט - Authentication, Authorization או Accounting: א. "המשתמש dana ניסתה להקליד configure terminal ונדחתה". ב. "החשבון של yossi נעול אחרי 3 ניסיונות". ג. "בדוח החודשי: 4,200 חיבורי VPN, ממוצע 38 דקות". ד. "המשתמש הזדהה עם טביעת אצבע". ה. "המורה יכולה לראות ציונים אבל לא לשנות".

א. Authorization ב. Authentication ג. Accounting ד. Authentication ה. Authorization

תרגיל 2 - מה יקרה?

נתב עם: aaa authentication login default group tacacs+ group radius local none. תארו את סדר הפעולות כאשר: (א) שרת ה-TACACS+ עונה "FAIL" (ב) שרת ה-TACACS+ לא עונה, ושרת ה-RADIUS עונה. Accept (ג) שני השרתים לא עונים ואין username בקונפיג.

(א) המשתמש נדחה – לא עוברים לשיטה הבאה אחרי דחייה. (ב) אחרי timeout של TACACS + הנתב פונה ל-RADIUS ומקבל את המשתמש. (ג) TACACS + timeout → RADIUS → local (אין משתמשים → השיטה "לא זמינה", לא "דחייה") → none ⇒ המשתמש נכנס בלי אימות! לכן none מסוכן.

תרגיל 3 – בחירת פרוטוקול

לכל תרחיש בחרו RADIUS או TACACS + ונמקו במשפט:
א. אימות 2,000 תלמידים ל-Wi-Fi של בית הספר. ב. 5 מנהלי רשת שמנהלים 60 מתגים, ורוצים שמתמחה יוכל להקליד רק show. ג. ספק אינטרנט שמחייב לקוחות לפי נפח. ד. חברה שהרגולטור דורש ממנה תיעוד של כל פקודות קונפיגורציה.

א. RADIUS (גישת משתמשים, 802.1X). (הרשאה לכל פקודה). ג. RADIUS (accounting).
מפורט לנפח). ד. TACACS + (command accounting).

תרגיל 4 – תקלה

מנהל הקליד `aaa authentication login default group tacacs+` ואז `aaa new-model` (בלי `local`). השרת נפל. המנהל מתנתק. מה קרה, ואיך מתקנים?

ננעל בחוץ – אין שיטת גיבוי. תיקון: גישה פיזית לקונסול (אם לקונסול לא הוגדרה רשימה אחרת – גם הוא נעול!) ⇒ `password recovery` דרך `ROMMON (register 0x2142)`, ואז להוסיף `local` לרשימה ומשתמש מקומי. לקח: תמיד `local` ... בסוף, ורשימה נפרדת לקונסול.

3.13 שאלות בסגנון בגרות

שאלה 1

התאימו: (1) רישום הפקודות שהקליד המנהל (2) בדיקה אם מותר למשתמש להקליד (3) `reload` בדיקת שם משתמש וסיסמה. אפשרויות: Authentication / Authorization / Accounting.

(1) Accounting (2) Authorization (3) Authentication

שאלה 2

מנהל הגדיר: `aaa authentication login default group radius local`. שרתה-RADIUS זמין ומשיב "סיסמה שגויה". מה יקרה?

המשתמש יידחה. המעבר ל-`local` קורה רק כשרתה-RADIUS לא זמין (`timeout`), לא כשהוא דוחה.

שאלה 3

איזה פרוטוקול מתאים יותר לניהול ציוד רשת (`device administration`) עם אישור לכל פקודה, ומדוע?
TACACS + – מפריד בין אימות להרשאה ותומך בהרשאה לכל פקודה (`per-command authorization`);
RADIUS משלב אימות והרשאה ואינו תומך בכך.

שאלה 4

השלימו: פרוטוקול _____ משתמש ב-TCP פורט _____ ומצפין את _____ החבילה; פרוטוקול _____ משתמש ב-UDP פורטים _____ ומצפין רק את _____.

TACACS + • 49 • כל גוף • RADIUS • 1812/1813 • הסיסמה

שאלה 5

כתבו את הפקודות שמגדירות שרת TACACS + בכתובת 192.168.1.10 עם מפתח Key123, ואימות ברירת מחדל מולו עם גיבוי מקומי.

`aaa authentication tacacs-server host 192.168.1.10 key Key123`
`aaa new-model`

שאלה 6

ב-802.1X - מה תפקיד המתג?

Authenticator - חוסם את הפורט עד שה-supPLICANT מאומת מול שרת ה-RADIUS, ומתווך בין EAPOL ל-RADIUS.

3.14 מעבדה (3 שעות) - AAA ב-Packet Tracer

1. טופולוגיה: PC-Admin — SW — R1 — Server (AAA). בשרת: AAA → Services → Client Name: On; R1, Client IP כתובת: R1, Secret Key123, ServerType: Tacacs (ואחר כך. Radius) הוסיפו User: admin / cisco123.
2. ב-R1: משתמש מקומי גיבוי, aaa new-model, aaa key Key123, tacacs-server host ... authentication login default group tacacs+ local לפי פרק 2.
3. התחברו ב-SSH מה-PC עם admin/cisco123 - הצליח? כבו את שירות ה-AAA בשרת ונסו שוב - ה-fallback למשתמש המקומי אמור לעבוד אחרי השהיה.
4. שנו את ה-secret בשרת בלבד - ראו את הכישלון; הריצו debug aaa authentication וקראו את הפלט.
5. חזרו על התרגיל עם RADIUS. השוו ב-Simulation mode את החבילות: ב-RADIUS רואים UDP; ב-TACACS+ רואים TCP.
6. הוסיפו רשימה בשם לקונסול עם local בלבד, וודאו שהקונסול לא פונה לשרת.

בנק שאלות שתלמידים שואלים - ותשובות מוכנות

שאלות נפוצות בפרק ה-AAA, עם תשובות מוכנות.

מושגי יסוד

ש: "אימות והרשאה נשמעים אותו דבר - מה ההבדל?"

ת: משל שדה התעופה: **אימות** = בדיקת הדרכון (מי אתה). **הרשאה** = כרטיס הטיסה (לאיזה מטוס מותר לך לעלות). קודם מוודאים מי אתה, ורק אז קובעים מה מותר לך. אי אפשר הרשאה בלי אימות.

ש: "ה-key בין הנתב לשרת - זו הסיסמה של המשתמש?"

ת: לא! ה-key הוא סוד משותף בין הנתב לשרת (מצפין ומאמת את הקשר ביניהם). סיסמאות המשתמשים נמצאות בשרת. שני דברים שונים לגמרי.

ש: "MFA ו-2FA זה אותו דבר?"

ת: 2FA (שני גורמים) הוא מקרה פרטי של MFA (רב-גורמי). העיקרון: שילוב גורמים מפינוש סיגוס - משהו שאתה יודע (סיסמה) + משהו שיש לך (טלפון) + משהו שאתה (טביעת אצבע). שתי סיסמאות אינן MFA.

מקומי מול שרת, ותקלות

ש: "אם שרת ה-AAA נופל, ננעלנו החוצה מכל הנתבים?"

ת: לא, אם הגדרתם נכון: רשימת השיטות מסתיימת ב-local (למשל local group tacacs+ ...). כשהשרת לא זמין, הנתב עובר אוטומטית לאימות מול משתמש מקומי. לכן דימת משאירים גיבוי מקומי.

ש: "מה קורה אם הקלדתי aaa new-model בטעות בלי משתמש מקומי?"

ת: אתם עלולים להינעל החוצה - כי מרגע הפקודה כל הקווים עוברים ל-AAA, ואם אין משתמש ואין רשימת ברירת מחדל, אין כניסה. כלל ברזל: קודם username, אחר כך aaa new-model, ולהשאיר חלון פתוח עד שבדקים בחלון שני.

ש: "אם השרת עונה 'סיסמה שגויה', הנתב עובר לאימות מקומי?"

ת: לא! מעבר לשיטה הבאה קורה רק כשהשרת נִימז אל (timeout). דחייה מפורשת מהשרת = המשתמש נדחה, בלי מעבר. זו נקודה שנשאלת בבגרות.

RADIUS מול TACACS+

ש: "אז איזה מהם 'יותר טוב', RADIUS או TACACS+?"
 ת: תלוי במשימה. לדו"צ לווהינ (מנהלים שמתחברים לנתבים, עם אישור לכל פקודה) - TACACS+ עדיף. לתשרל סישמתשמ תשיג (Wi-Fi/802.1X, VPN) - RADIUS. בפועל ארגונים משתמשים בשניהם, כל אחד לתפקידו.

ש: "למה RADIUS על UDP אם TCP אמין יותר?"
 ת: RADIUS תוכנן ב-1991 לשרתי דיאל-אפ עם אלפי חיבורים; UDP קל ומהיר, והלקוח פשוט שולח שוב אם אין תשובה. TACACS+ בחר TCP כי הוא מנהל שיחה רב-שלבית ורוצה לדעת מיד אם השרת נפל. שניהם עובדים היום.

ש: "אומרים ש-'RADIUS לא עושה הרשאה' - אבל הוא כן מחזיר הרשאות, לא?"
 ת: נכון, זו נקודה עדינה. RADIUS כן נושא attributes של הרשאה (VLAN), רמה) בתוך תשובת ה-Accept, אבל הוא בלשם אימות והרשאה בצעד אחד ואינו תומך באישור הדוקף לכל דרפנ כמו TACACS+. בבגרות "אינו מתייחס לניהול הרשאות" מתקבל כנכון במובן הזה.

ש: "מה זה 802.1X במשפט אחד?"
 ת: תקן שבו המתג/נקודת הגישה טרופה תא סימסוח עד שהמכשיר מאמת את עצמו מול שרת RADIUS. זה מה שמונע ממישהו לחבר מחשב לשקע ולקבל גישה, וזה הבסיס ל-Wi-Fi ארגוני (WPA2-Enterprise).

ש: "אפשר לחבר AAA ל-Active Directory של בית הספר?"
 ת: כן - זה בדיוק מה שעושים בארגונים. שרת ה-(ISE/NPS/FreeRADIUS) AAA מקבל את הבקשה מהנתב ומאמת מול ה-AD/LDAP כך המורים משתמשים באותם שם וסיסמה בכל מקום.

מילון מונחים - הגדרות

הגדרות תמציתיות של המונחים המרכזיים בפרק. שימושי גם כדף עזר לבחינה (מותר מילון מונחים).

מונח	הגדרה
AAA	מסגרת של שלושה שירותים: Authentication, Authorization, Accounting.
Authentication (אימות)	קביעת זהות המשתמש - מי אתה.
Authorization (הרשאה)	קביעת מה מותר למשתמש לעשות אחרי שאומת.
Accounting (רישום)	תיעוד פעולות המשתמש: מתי נכנס, אילו פקודות הקליד.
AAA מקומי	אימות מול מסד משתמשים בקונפיג של הנתב עצמו.
AAA מבוסס-שרת	אימות מול שרת מרכזי (ISE/ACS) בפרוטוקול RADIUS או TACACS+.
NAS / AAA client	ההתקן (נתב/מתג) שפונה לשרת ה-AAA בשם המשתמש.
RADIUS	פרוטוקול AAA פתוח, (1812/1813) UDP; מצפין רק את הסיסמה; לגישת משתמשים.
+TACACS	פרוטוקול AAA של סיסקו, TCP 49; מצפין את כל החבילה; מפריד שירותים; לניהול ציוד.
key / shared secret	סוד משותף בין הנתב לשרת המצפין ומאמת את הקשר ביניהם (לא סיסמת המשתמש).
ACS / ISE	שרתי ה-AAA של סיסקו (ACS) ישן, ISE מודרני).
aaa new-model	הפקודה שמפעילה את מסגרת ה-AAA בנתב.
method list	רשימת שיטות אימות מסודרת; עוברים לשיטה הבאה רק אם הקודמת לא זמינה.
802.1X	תקן שבו המתג/AP חוסם פורט עד לאימות מול שרת RADIUS.
Supplicant / Authenticator	ב-802.1X: המכשיר המבקש גישה (supplicant) והמתג שחוסם (authenticator).
MFA / 2FA	אימות רב-שלבי - שילוב גורמים מסוגים שונים (יודע/יש/הוא).

פרק 4 – חומות אש ברשת הבינונית והרחבה

11 שעות עיוני + 2 מעשי · שבועות 10-12

מטרות: ACL סטנדרטי/מורחב · ACL מבוסס זמן · עצירת התקפות ב-ACL · CBAC · ZPF
בבגרות: ACL סטנדרטי (חסימת רשת), מיקום ACL וכיוון in/out, ACL מורחב עם host

לפני שמתחילים – איך תעבורה "עוברת" בנתב? (למי שאין רקע)

חומת אש מחליטה אילו חבילות לעבור. כדי להבין זאת צריך שני מושגים: **כיוון תעבורה** – לכל ממשק (פורט) בנתב יש שני כיוונים: in = חבילות שנכנסות לנתב דרך הפורט, out = חבילות שיוצאות מהנתב דרך הפורט. תמיד חושבים מנקודת המבט של **נתב**, לא של המשתמש. **סינון לפי כותרת החבילה** – כל חבילה נושאת בכותרת שלה: כתובת מקור, כתובת יעד, סוג פרוטוקול (TCP/UDP/ICMP), ופורט. חומת אש קוראת את הכותרת ומחליטה permit (לעבור) או deny (לחסום). Wildcard mask – דרך לומר "התאם רק חלק מהכתובת". נסביר לעומק בהמשך; רק דעו שזה ההפך ממסכת רשת רגילה: "0 בדוק את הביט הזה", "1 = לא אכפת לי". **אנלוגיה:** חומת אש היא כמו שומר בכניסה לבניין עם רשימה. כל אדם (חבילה) שמגיע – השומר בודק ברשימה (ACL) לפי הזהות שלו (כתובת/פורט), ומחליט להכניס או לא. הרשימה נבדקת הטמל הלעמל, והשומר עוצר בהתאמה הראשונה.

4.1 מהי חומת אש

חומת אש (Firewall) היא מערכת – חומרה, תוכנה או שילוב – שעומדת בין רשתות ברמות אבטחה שונות ומחליטה לפי מדיניות אילו חבילות לעבור ואילו לחסום. המונח מגיע מקיר בטון שמונע התפשטות שריפה בין דירות. המאפיינים: **עמידה בפני התקפות** (היא עצמה מוקשחת), **נקודת מעבר יחידה** (כל התעבורה חייבת לעבור דרכה – אחרת אין טעם), **ואכיפת מדיניות**.

סיפור מהחיים: הקצינו שנפרץ דרך האקווריום (2017)

קצינו בלאס וגאס התקין אקווריום חכם עם חיישן טמפרטורה המחובר לאינטרנט. התוקפים פרצו לחיישן (סיסמת ברירת מחדל), ומכיוון שהאקווריום היה מחובר לאותה רשת של שאר הקצינו – עברו ממנו למסד הנתונים של "השחקנים הגדולים" ושאו 10GB החוצה דרך... החיישן. אם היה ACL אחד שאומר "מהאקווריום מותר רק לשרת הבקרה שלו" – הסיפור היה נגמר בחיישן. חומת אש היא לא רק בין "הפנים" ל"אינטרנט"; היא גם בין חלקי הפנים.

4.2 סוגי חומות אש

סוג	איך זה עובד	יתרונות	חסרונות
סינון חבילות (Packet filtering, stateless) – ACL	בודקת כל חבילה לבד לפי כותרות שכבה 3-4: IP מקור/יעד, פרוטוקול, פורט	מהיר, זול, בכל נתב	לא מבינה "שיחה": כדי לאפשר תשובות חייבים לפתוח פורטים לכיוון פנימה; ניתנת לעקיפה ב-spoofing
Stateful (בדיקת מצב)	שומרת טבלת חיבורים (state table). תעבורה שיוצאת מהפנים נרשמת; רק התשובות שתואמות לרשומה מורשות להיכנס	מאובטחת הרבה יותר, פשוטה להגדרה; הסטנדרט היום (ASA, ZPF, CBAC)	לא מבינה את תוכן האפליקציה; "UDP/ICMP חסרי מצב" מטופלים לפי timeout
Application gateway / Proxy	מסיימת את החיבור, קוראת את תוכן שכבה 7 (HTTP, FTP) ופותחת חיבור חדש ליעד	מבינה תוכן, יכולה לסנן URL, וירוסים	איטית, צריך proxy לכל פרוטוקול
NAT כ"חומת אש"	מסתירה כתובות פנימיות	חינם	אינה חומת אש אמיתית – רק מסתירה

סוג	איך זה עובד	יתרונות	חסרונות
NGFW (דור הבא)	Stateful + זיהוי אפליקציה (Facebook מול YouTube על אותו פורט + 443) + IPS זהות משתמש + בדיקת TLS	מקיפה	יקרה, דורשת כוונן
Host-based (Windows Firewall)	על המחשב עצמו	מגנה גם מפני מחשבים באותה רשת	מנוהלת בנפרד בכל מחשב
Transparent	בשכבה 2 - ללא כתובת IP, "IP שקופה"	מוסיפים בלי לשנות כתובות	

4.3 ACL - רשימות בקרת גישה

ACL (Access Control List) היא רשימה סדורה של משפטי permit/deny שהנתב עובר עליה **מלמעלה למטה** עבור כל חבילה; **בהתאמה הראשונה** הוא מבצע את הפעולה ומפסיק. אם אף שורה לא תואמת - יש deny any **סמוי** (implicit deny) בסוף כל ACL שלוש החוקים האלה מסבירים 90% מהטעויות.

ACL יכולה לשמש לא רק לסינון

גם לזהות תעבורה עבור VPN, route-map, QoS, NAT (פרק 8), ו-class access על קווי VTY. בפרק זה - סינון.

מסכת wildcard - הדבר שתלמידים הכי מתבלבלים בו

ב-ACL לא כתובים subnet mask אלא wildcard mask: ביט 0 = **חייב להתאים**, ביט 1 = **לא אכפת לי**. במסכת רשת רגילה זה הפוך. הדרך המהירה: $\text{subnet mask} - \text{wildcard} = 255.255.255.255$.

רשת	Subnet mask	Wildcard	משמעות
192.168.1.0/24	255.255.255.0	0.0.0.255	3 האוקטטים הראשונים חייבים להתאים
172.16.16.0/28	255.255.255.240	0.0.0.15	172.16.16.15-172.16.16.0
10.0.0.0/8	255.0.0.0	0.255.255.255	כל מה שמתחיל ב-10
מארח בודד 10.1.1.7	32/	host = 0.0.0.0 10.1.1.7	הכול חייב להתאים
כל כתובת	-	= 255.255.255.255 any	0.0.0.0 255.255.255.255
רשתות זוגיות 192.168.0.0, .2.0,4.0		192.168.0.0 0.0.254.255	ביט אחרון באוקטט השלישי חייב 0 - טריק לבחינות

בבגרות (חלק א, שאלה 1ט)

"נתונה 135.8.267/26 - מהי ה-subnet mask ומהי ה-wildcard? Subnet: 255.255.255.192 Wildcard: 0.0.0.63. (שימו לב: 267 אינו אוקטט חוקי - טעות בשאלון; מתעלמים).

ACL סטנדרטית - רק לפי מקור

מספרים 1-99 ו-1300-1999 בודקת **רק את כתובת המקור**. לכן ממקמים אותה **קרוב ליעד** - אחרת היא תחסום את המקור מלהגיע גם ליעדים שלא התכוונו אליהם.

```
R1(config)# access-list 10 deny 20.20.20.0 0.0.0.255 24/ חסימת רשת 24 - ! בבגרות שאלה 1ט
R1(config)# access-list 10 permit any (implicit deny) הכול נחסם בלי זה - !
```

```
R1(config)# interface g0/1
R1(config-if)# ip access-group 10 out
```

ACL מורחבת - מקור, יעד, פרוטוקול ופורט

מספרים 199-100 ו-2000-2699 תחביר: access-list N {permit|deny} PROTOCOL SRC [op PORT] DST [op PORT] [established] [log] SRC-WC [op PORT] DST-WC [op PORT] [established] [log] ממקמים קרוב למקור - כדי לא להעביר תעבורה שתיחסם ממילא דרך כל הרשת.

```
! רשת (172.18.1.0/24) IT רשאית ל-DNS ול-DHCP, אך לא ל-10.0.0.190 web - בבגרות חלק א שאלה 3
R1(config)# access-list 101 deny ip 172.18.1.0 0.0.0.255 host 10.0.0.190
R1(config)# access-list 101 permit ip any any
R1(config)# interface g0/0/1
R1(config-if)# ip access-group 101 in
! דוגמאות לפורטים
R1(config)# access-list 110 permit tcp 192.168.1.0 0.0.0.255 any eq 80
R1(config)# access-list 110 permit tcp 192.168.1.0 0.0.0.255 any eq 443
R1(config)# access-list 110 permit udp 192.168.1.0 0.0.0.255 host 8.8.8.8 eq 53
R1(config)# access-list 110 deny icmp any any echo ping חסימת !
R1(config)# access-list 110 permit tcp any any established state-" - (דלוק) ! (רק תשובות ACK/RST)
ful לעניים"
R1(config)# access-list 110 deny ip any any log ! רשום מה נחסם (רק בסוף) !
```

אופרטורים: eq שווה, neq, gt, lt, range. פורטים ניתן לכתוב בשם (eq www, eq ftp, eq do - , eq (main).

ACL בשם (Named) - הדרך המומלצת

```
R1(config)# ip access-list extended BLOCK-WEB
R1(config-ext-nacl)# remark IT may not reach the web server
R1(config-ext-nacl)# 10 deny tcp 172.18.1.0 0.0.0.255 host 10.0.0.190 eq 80
R1(config-ext-nacl)# 20 permit ip any any
R1(config-ext-nacl)# exit
R1(config)# interface g0/0/1
R1(config-if)# ip access-group BLOCK-WEB in
! עריכה: מוחקים/מוסיפים שורה לפי מספר רצף - בלי למחוק את כל הרשימה
R1(config)# ip access-list extended BLOCK-WEB
R1(config-ext-nacl)# no 10
R1(config-ext-nacl)# 15 deny tcp 172.18.1.0 0.0.0.255 host 10.0.0.190 eq 443
! סטנדרטית בשם - זה מה שמופיע בבגרות (config-std-nacl)
R1(config)# ip access-list standard BLOCK_LAN2
R1(config-std-nacl)# deny 192.168.2.0 0.0.0.255
R1(config-std-nacl)# permit any
```

כיוון: in או out?

הכיוון הוא מנקודת מבטו של הנתב על ממשק מסוים. in = חבילות שנכנסות לנתב דרך הממשק הזה (לפני ניתוב). out = חבילות שיוצאות מהנתב דרך הממשק הזה (אחרי ניתוב). ACL אחת לכל ממשק, לכל כיוון, לכל פרוטוקול.

בבגרות (שאלה 7) - הדוגמה המושלמת

R1 עם שלוש רשתות: G0/2→192.168.1.0, G0/1→192.168.2.0, Re→192.168.3.0 (stricted חוסמים את 192.168.2.0 ל-192.168.3.0 בלבד. ACL סטנדרטית ⇒ קרוב ליעד ⇒ G0/2. כיוון: התעבורה יוצאת מהנתב לרשת 3 ⇒ out. סדר: 192.168.2.0 deny ואז permit any. תשובה

2. אם היינו שמים in על G0/1 - רשת 2 הייתה נחסמת גם לרשת 1 ולאינטרנט. אם permit any היה ראשון - ה-deny לעולם לא היה מגיע.

טעויות נפוצות ב-ACL

- שוכחים permit בסוף ⇒ הכול נחסם. תלמידים מגדירים ""X deny ומתפללים שאין אינטרנט.
- סדר הפוך - שורה כללית לפני ספציפית.
- wildcard כ-255.255.255.0 (subnet mask במקום 0.0.0.255).
- ACL מוגדרת אך לא הוחלה על ממשק (ip access-group) - ב-show ip interface רואים "Out-going access list is not set".
- ACL סטנדרטית שממוקמת קרוב למקור - חוסמת הרבה יותר מהמתוכנן.
- ACL על VTY: לא ip access-group אלא in access-class 10 תחת line vty.
- ה-ACL לא בודקת תעבורה שהנתב עצמו יוצר (ping) מהנתב - רק תעבורה שעוברת דרכו.

ורפיקציה

```
R1# show access-lists ! כולל מונה התאמות (matches) לכל שורה - הכלי הכי טוב לדיבוג
R1# show ip access-lists 101
R1# show ip interface g0/1 ! איזו ACL מוחלת ובאיזה כיוון
R1# show running-config | section access-list
R1# clear access-list counters
```

ACL 4.4 מורכבות: מבוססות זמן, דינמיות ורפלקסיביות

Time-based ACL

מאפשרת כלל שתקף רק בזמנים מסוימים. דורש שעון נכון (NTP) - פרק 2).

```
R1(config)# time-range WORK-HOURS
R1(config-time-range)# periodic weekdays 8:00 to 17:00
R1(config-time-range)# exit
R1(config)# access-list 120 permit tcp 192.168.1.0 0.0.0.255 any eq 80 time-range WORK-
HOURS
R1(config)# access-list 120 deny ip any any
periodic Monday Wednesday 9:00 to 12:00 / absolute start 08:00 1 Jan 2026 end 17:00 31 Jan
2026 ! אפשרויות:
```

Dynamic ACL (Lock-and-Key)

המשתמש מבצע Telnet/SSH לנתב ומזדהה; רק אז נפתחת לו דלת זמנית דרך הנתב. "מנעול ומפתח".

```
R1(config)# username student password 0 pass
R1(config)# access-list 101 permit tcp any host 10.0.0.1 eq telnet
R1(config)# access-list 101 dynamic OPEN-DOOR timeout 15 permit ip any any
R1(config)# interface g0/0
R1(config-if)# ip access-group 101 in
R1(config)# line vty 0 4
R1(config-line)# login local
R1(config-line)# autocmd access-enable host timeout 5
```

Reflexive ACL

"מראה": כשתעבורה יוצאת החוצה, הנתב יוצר אוטומטית שורה זמנית שמאפשרת רק את התשובה (IP)/(פורט הפוכים) להיכנס. זה מנגנון stateful פשוט ב-ACL, ועדיף על established כי עובד גם ל-UDP ו-ICMP.

```

R1(config)# ip access-list extended OUTBOUND
R1(config-ext-nacl)# permit tcp any any reflect TCP-TRAFFIC
R1(config-ext-nacl)# permit udp any any reflect UDP-TRAFFIC
R1(config)# ip access-list extended INBOUND
R1(config-ext-nacl)# evaluate TCP-TRAFFIC
R1(config-ext-nacl)# evaluate UDP-TRAFFIC
R1(config-ext-nacl)# deny ip any any
R1(config)# interface s0/0/0
R1(config-if)# ip access-group OUTBOUND out
R1(config-if)# ip access-group INBOUND in

```

4.5 עצירת התקפות בעזרת ACL

Anti-spoofing – מה לחסום בכניסה מהאינטרנט (ingress)

```

R1(config)# ip access-list extended ANTI-SP00F
! כתובות פרטיות (RFC 1918) לא אמורות להגיע מהאינטרנט – מישור מזיף
R1(config-ext-nacl)# deny ip 10.0.0.0 0.255.255.255 any
R1(config-ext-nacl)# deny ip 172.16.0.0 0.15.255.255 any
R1(config-ext-nacl)# deny ip 192.168.0.0 0.0.255.255 any
! הרשת שלנו כמקור מבחץ – זיוף ודאי
R1(config-ext-nacl)# deny ip 203.0.113.0 0.0.0.255 any
R1(config-ext-nacl)# deny ip 127.0.0.0 0.255.255.255 any loopback !
R1(config-ext-nacl)# deny ip 0.0.0.0 0.255.255.255 any
R1(config-ext-nacl)# deny ip 224.0.0.0 15.255.255.255 any multicast !
! ICMP – לאפשר רק מה שצריך, לחסום echo מבחץ (נגד ping sweep ו-Smurf)
R1(config-ext-nacl)# permit icmp any any echo-reply
R1(config-ext-nacl)# permit icmp any any unreachable
R1(config-ext-nacl)# permit icmp any any time-exceeded traceroute !
R1(config-ext-nacl)# deny icmp any any
! שירותי ניהול לא נגישים מבחץ
R1(config-ext-nacl)# deny tcp any any eq 23
R1(config-ext-nacl)# deny udp any any eq 161
! רק תשובות ל-TCP שהפנים פתח + שירותי DMZ
R1(config-ext-nacl)# permit tcp any any established
R1(config-ext-nacl)# permit tcp any host 203.0.113.10 eq 80
R1(config-ext-nacl)# permit tcp any host 203.0.113.10 eq 443
R1(config-ext-nacl)# deny ip any any log
R1(config)# interface g0/0
R1(config-if)# ip access-group ANTI-SP00F in

```

Egress filtering – גם ביציאה: לאפשר רק את כתובות המקור שלנו; כך הרשת שלנו לא תשמש ל-DDoS עם כתובות מזויפות.

4.6 CBAC Context-Based Access Control – (חומת אש "קלאסית" ב-IOS)

ACL היא stateless. CBAC (נקראת גם Classic Firewall) מוסיפה מצב: היא בוחנת (inspect) תעבורה שיוצאת מהפנים, זוכרת את השיחה בטבלת state, ופותחת אוטומטית וזמנית חור ב-ACL הנכנסת לתשובות בלבד. היא גם מבינה פרוטוקולים עם פורטים דינמיים (FTP active) ומגנה מ-TCP intercept SYN flood (like).

```

! ACL 1 שחוסמת הכול מבחץ (התשובות ייפתחו על ידי CBAC)
R1(config)# ip access-list extended OUTSIDE-IN

```

```

R1(config-ext-nacl)# permit icmp any any echo-reply
R1(config-ext-nacl)# deny ip any any
R1(config)# interface s0/0/0
R1(config-if)# ip access-group OUTSIDE-IN in
2. כלל בדיקה
R1(config)# ip inspect name FW tcp
R1(config)# ip inspect name FW udp
R1(config)# ip inspect name FW http
R1(config)# ip inspect name FW ftp
3. החלה בכיוון שבו התעבורה "מתחילה" - יוצאת החוצה
R1(config)# interface s0/0/0
R1(config-if)# ip inspect FW out
R1# show ip inspect sessions
R1# show ip inspect config

```

CBAC היא "מבוססת ממשק": ככל שיש יותר ממשקים, ההגדרה מסתבכת. לכן סיסקו החליפה אותה ב-ZPF.

Zone-Based Policy Firewall – 4.7 ZPF

הגישה המודרנית ב-IOS: במקום לחשוב על ממשקים, מגדירים **אזורים** (zones) ומדיניות **בין זוגות אזורים** (zone-pair), בכיוון אחד. חוקים:

- ממשק שייך לאזור אחד לכל היותר.
- תעבורה בין ממשקים **באותו אזור** – מותרת תמיד.
- תעבורה בין ממשק באזור לממשק שלא באזור – **נחסמת**.
- תעבורה בין שני אזורים – **נחסמת כברירת מחדל**, אלא אם יש zone-pair עם מדיניות.
- אזור מיוחד self = הנתב עצמו (תעבורה אל הנתב וממנו – SSH, OSPF, ברירת המחדל ל-self: הכול מותר).

שלוש פעולות

פעולה	משמעות
inspect	בדיקה stateful – מאפשר את התעבורה ואת התשובות חזרה אוטומטית. זה מה שרוצים כמעט תמיד.
pass	מאפשר את התעבורה בכיוון הזה בלבד, בלי מעקב (כמו permit ב-ACL). לתשובה צריך pass בזוג ההפוך.
drop	חוסם (ברירת מחדל, אפשר להוסיף log).

ההגדרה – C3PL (Cisco Common Classification Policy Language) בחמישה שלבים

```

1. ! אזורים
R1(config)# zone security INSIDE
R1(config)# zone security OUTSIDE
2. class-map (איזו תעבורה = match-any; מספיק תנאי אחד; match-all = כולם)
R1(config)# class-map type inspect match-any WEB-DNS
R1(config-cmap)# match protocol http
R1(config-cmap)# match protocol https
R1(config-cmap)# match protocol dns
R1(config-cmap)# match protocol icmp
R1(config-cmap)# exit
! (אפשר גם match access-group 101 לשלב ACL)
3. policy-map – מה עושים עם התעבורה

```

```

R1(config)# policy-map type inspect IN-T0-OUT
R1(config-pmap)# class type inspect WEB-DNS
R1(config-pmap-c)# inspect
R1(config-pmap-c)# exit
R1(config-pmap)# class class-default ! כל השאר
R1(config-pmap-c)# drop log
R1(config-pmap-c)# exit
zone-pair 4. - מקור, יעד, ומדיניות
R1(config)# zone-pair security IN-OUT source INSIDE destination OUTSIDE
R1(config-sec-zone-pair)# service-policy type inspect IN-T0-OUT
R1(config-sec-zone-pair)# exit
! 5. שיוך ממשקים לאזורים - ברגע זה החסימה מתחילה!
R1(config)# interface g0/1
R1(config-if)# zone-member security INSIDE
R1(config)# interface s0/0/0
R1(config-if)# zone-member security OUTSIDE
! וריפיקציה
R1# show zone security
R1# show zone-pair security
R1# show policy-map type inspect zone-pair IN-OUT sessions
R1# show class-map type inspect

```

שאלת תלמיד: "הגדרתי OUTSIDE→INSIDE עם inspect. איך התשובות חוזרות, הרי אין zone-pair "INSIDE→OUTSIDE"

זה בדיוק מה ש-inspect עושה: הנתב רושם את השיחה בטבלת state, וכשמגיעה תשובה מ-OUTSIDE שתואמת לשיחה קיימת - היא עוברת, בלי צורך ב-zone-pair הפוך. תעבורה חדשה מ-OUTSIDE (למשל מישהו מבחוץ מנסה SSH למחשב פנימי) - נחסמת. אם היינו משתמשים ב-pass במקום inspect, התשובות היו נחסמות.

שאלת תלמיד: "אחרי שהגדרתי ZPF, אני לא מצליח לעשות SSH לנתב מבחוץ / OSPF נפל"

תעבורה אל הנתב עצמו שייכת לאזור self. ברירת המחדל ל-self היא permit, אז SSH אמור לעבוד. אם הגדרתם zone-pair שמערב self עם מדיניות - עכשיו רק מה שהוגדר עובר. יש להוסיף class ל-SSH/OSPF עם pass/inspect. גם בדקו ש-CBAC (ip inspect) לא מוגדרת על אותו ממשק - אסור לשלב.

4.8 תכנון חומת אש ברשת - שיטות עבודה

- DMZ: שלושה אזורים - INSIDE, DMZ, OUTSIDE. מדיניות: INSIDE→DMZ inspect; DMZ→DMZ inspect; OUTSIDE→DMZ inspect; OUTSIDE→OUTSIDE inspect; (אם שרת ה-web נפרץ - התוקף לא ממשיך פנימה). INSIDE→OUTSIDE - כלום.
- **מינימום הרשאות** (least privilege): מתחילים מ-deny all ופותחים רק מה שיש לו הצדקה עסקית.
- **תיעוד**: כל שורת ACL עם remark; מי ביקש, מתי, למה.
- **ביקורת**: פעם ברבעון - show access-lists; שורות עם 0 matches - כנראה מיותרות.
- Logging - Log על deny בסוף, אבל לא על permit (עומס).

סיפור מהחיים: 32 מיליון שורות ACL

בחברת ביטוח גדולה, בדיקת ביקורת מצאה חומת אש עם 8,000 כללים, מתוכם 3,200 שלא התאימו לאף חבילה במשך שנה - "כללים זומבי" שאף אחד לא העז למחוק כי "אולי משהו ישבר". בין הזומבים: כלל מ-2009 שפתח RDP לכל האינטרנט לשרת שכבר לא קיים - אך הכתובת שלו הוקצתה מחדש לשרת HR. הלקח: חומת אש שלא מתחזקים היא לא חומת אש; והשוואת מוני matches היא לא רק לדיבוג.

4.9 מדריך פקודות מרוכז - פרק 4

פקודה	תפקיד
access-list 1-99 {permit deny} SRC WC	ACL סטנדרטית ממוספרת
access-list 100-199 {permit deny} PROTO SRC WC [eq P] DST WC [eq P]	ACL מורחבת ממוספרת
ip access-list {standard extended} NAME	ACL בשם, עם מספרי רצף
ip access-group N {in out} (ממשק)	החלת ACL
(line vty) access-class N in	ACL על גישת ניהול
any / host A	קיצורים ל- 0.0.0.0 / 255.255.255.255 wildcard
,time-range ,log ,established dynamic ,evaluate/reflect	מילות מפתח מתקדמות
show ip interface , show access-lists	ורפיקציה
ip inspect + ip inspect name N PROTO N out	CBAC
class-map type → zone security → policy-map type inspect → inspect zone-member → zone-pair security security	ZPF, בסדר הזה
show , show zone-pair security policy-map type inspect zone-pair sessions	ורפיקציה ZPF

4.10 תרגילים לתלמידים

תרגיל 1 - wildcard

כתבו את ה-wildcard: א. 192.168.10.0/25 ב. 10.10.0.0/16 ג. 172.16.4.0/22 ד. המארח 8.8.8.8 ה. כל הכתובות 192.168.0.0 עד 192.168.7.255

א. 0.0.0.127 ב. 0.0.255.255 ג. 0.0.3.255 ד. 0.0.0.0 (host 8.8.8.8) ה. 192.168.0.0 0.0.7.255

תרגיל 2 - מה עובר?

access-list 105 permit tcp 192.168.1.0 0.0.0.255 any eq 443 access-list 105 deny tcp 192.168.1.0 0.0.0.255 any eq 80 access-list 105 permit udp any host 8.8.8.8 eq 53 interface g0/0 (LAN 192.168.1.0/24) ip access-group 105 in מ-192.168.1.20: א. HTTPS ל-1.1.1.1 ב. HTTP ל-1.1.1.1 ג. DNS ל-8.8.8.8 ד. DNS ל-1.1.1.1 ה. ping ל-1.1.1.1 ו. SSH לנתב עצמו

א. עובר (שורה 1). ב. נחסם (שורה 2). ג. עובר (3). ד. נחסם (implicit deny). ה. נחסם (implicit deny) - אין שורה ל-. (icmp ו. נחסם - גם תעבורה אל הנתב עוברת דרך ACL נכנסת. תלמידים רבים חושבים שרק "מה שכתוב deny נחסם - זו הנקודה.

תרגיל 3 - תכנון ACL

נתב עם G0/0 → רשת תלמידים G0/1, 10.1.0.0/16 → רשת מורים G0/2, 10.2.0.0/16, שרתים 10.3.0.0/24 (שרת ציונים 10.3.0.10, שרת קבצים. 10.3.0.20 דרישות: תלמידים לא ניגשים לשרת הציונים אך כן לשרת הקבצים; מורים ניגשים להכול; תלמידים לא רשאים ל-Telnet/SSH לשום מקום. כתבו ACL מורחבת בשם, ובחרו ממשק וכיוון.

ip access-list extended STUDENTS deny ip 10.1.0.0 0.0.255.255 host 10.3.0.10 deny tcp

10.1.0.0 0.0.255.255 any eq 22 deny tcp 10.1.0.0 0.0.255.255 any eq 23 permit ip any
 מורים לא G0/0 in. ⇒ קרוב למקור ⇒ any interface g0/0 ip access-group STUDENTS in
 מופיעים - permit any (הם ממילא לא נכנסים ב-G0/0).

תרגיל 4 - ZPF

ציירו טבלה של אזורים (INSIDE / DMZ / OUTSIDE וכתבו לכל זוג 6) כיוונים) איזו מדיניות תגדירו ומדוע.

DMZ: inspect http,→DMZ: inspect. OUT→IN (הכול/רשימת פרוטוקולים).
zone-pair (drop). IN→OUT (ל-match access-group עם ה-IP של השרתים).
OUT: inspect dns, ntp, http→DMZ. "שרת נפרץ לא ממשיך פנימה".
DDoS. בלבד - ולא הכול, כדי ששרת נפרץ לא ישמש ל-.

4.11 שאלות בסגנון בגרות

שאלה 1

איזו פקודה חוסמת את המארח 10.5.5.5 בלבד ב-ACL סטנדרטית?

```
access-list 10 deny 2. access-list 10 deny 10.5.5.5 255.255.255.255 1.
access-list 10 4. access-list 100 deny 10.5.5.5 0.0.0.0 3. host 10.5.5.5
deny 10.5.5.0 0.0.0.255
```

2. 1) wildcard של 3; any - מספר של מורחבת ותחביר חסר; 4 - חוסם רשת שלמה.)

שאלה 2

מנהל הגדיר ACL עם שורה אחת: `access-list 20 deny 192.168.5.0 0.0.0.255` והחיל אותה. אף אחד לא מצליח לצאת. מדוע?

```
.access-list 20 permit any חסר implicit deny any
```

שאלה 3

היכן נכון למקם ACL מורחבת - קרוב למקור או ליעד? ומדוע?

קרוב למקור - היא מזהה בדיוק את התעבורה (מקור+יעד+פורט), ולכן אפשר לחסום אותה מוקדם ולא לבזבז רוחב פס. סטנדרטית - קרוב ליעד, כי היא בודקת רק מקור ותחסום יותר מדי אם תמוקם קרוב אליו.

שאלה 4

ב-ZPF, ממשק G0/0 באזור INSIDE וממשק G0/1 לא שויך לאף אזור. מה יקרה לתעבורה ביניהם?

תיחסם. ממשק באזור לא מתקשר עם ממשק שאינו באזור.

שאלה 5

מה ההבדל בין הפעולות inspect ו-pass ב-ZPF?

inspect - מעקב stateful, התשובות מורשות אוטומטית. pass - מעבר בכיוון אחד בלבד ללא מעקב; לתשובות נדרש pass בזוג ההפוך.

שאלה 6

R1(con- · R1(config)# access-list 101 deny ip _____ host _____ : השלימו:
IT רשתות - R1(config-if)# _____ · fig)# access-list 101 permit _____
172.18.1.0/16 (לפי הטבלה) יקבלו DNS ו-DHCP אך לא. (10.0.0.190) WEB

```
ip · ip any any · 10.0.0.190 · (0.0.0.255 :24/ לפי 172.18.1.0 0.0.255.255  
access-group 101 in
```

4.12 מעבדה (2 שעות) – ACL ו-ZPF ב-Packet Tracer

1. ACL: בנו את הטופולוגיה משאלה 7 בבגרות R1 עם 3 רשתות). הגדירו את BLOCK_LAN2 והחילו out על G0/2. בדקו ping מרשת 2 לרשת 3 (נכשל) ולרשת 1 (מצליח). הריצו show access-lists וראו את המונים עולים.
2. הזיזו את אותה ACL ל-G0/1 in. מה נשבר? (רשת 2 מאבדת הכול). הסבירו.
3. ACL מורחבת: אפשרו לרשת 2 רק HTTP לשרת ברשת 3 וחסמו ping בדקו בדפדפן של ה-PC.
4. ZPF: טופולוגיה R1-INSIDE(PC) - R1-OUTSIDE(Server). הגדירו class-map, zone-pairs, http+icmp, inspect, zone-pair IN-OUT. דפדפן לשרת עובד, ping עובד. מהשרת: ping ל-PC נכשל. הריצו show policy-map type inspect zone-pair sessions ותוך כדי גלישה.
5. החליפו inspect ב-pass. מה קרה לגלישה? הסבירו בעזרת מושג ה-state.

בנק שאלות שתלמידים שואלים – ותשובות מוכנות

שאלות נפוצות בפרק חומות האש וה-ACL, עם תשובות מוכנות.

הבנת ACL

ש: "הגדרתי רק שורת deny אחת ופתאום שום דבר לא עובד. למה?"

ת: בגלל ה-deny any הסמוי בסוף כל ACL. ברגע שיש ACL, כל מה שלא הותר במפורש – נחסם. חייבים להוסיף permit מפורש למה שרוצים לאפשר, אחרת הכול נחסם.

ש: "למה wildcard הפוך ממסכת רשת רגילה? זה מבלבל."

ת: כי הוא עונה על שאלה אחרת. מסכת רשת אומרת "איזה חלק הוא הרשת". Wildcard אומרת ל-ACL אילו ביטים לבדוק: 0 = חייב להתאים, 1 = לא אכפת לי. טריק: wildcard = 255.255.255.255 פחות מסכת הרשת.

ש: "איך אני יודע אם ה-ACL בכלל עובד?"

ת: show access-lists – ליד כל שורה יש תומאתה הנומ (matches). אם שולחים תעבורה והמונה לא עולה, ה-ACL לא נתפס (כנראה לא הוחל על ממשק, או בכיוון הלא נכון). זה כלי הדיבוג מספר 1.

ש: "למה סטנדרטי קרוב ליעד, ומורחב קרוב למקור?"

ת: סטנדרטי בודק רוקמ קר, אז אם נמקם אותו קרוב למקור הוא יחסום את המקור מלהגיע לכל יעד – יותר מדי. לכן קרוב ליעד. מורחב מזהה בדיוק מקור + יעד + פורט, אז אפשר לחסום מוקדם (קרוב למקור) בלי לפגוע בתעבורה אחרת.

ש: "מה ההבדל בין in ל-out? אני מתבלבל."

ת: תמיד מנקודת המבט של הנתב: in = נכנס לנתב דרך הממשק (לפני שהנתב מנתב). out = יוצא מהנתב דרך הממשק (אחרי הניתוב). ציירו נתב עם חצים – זה מתבהר מיד.

ש: "האם ACL חוסם גם תעבורה שהנתב עצמו שולח (למשל ping מהנתב)?"

ת: לא. ACL בודק תעבורה שקרד תרבוה הנתב, לא תעבורה שהנתב עצמו יוצר. לכן ping מהנתב עצמו יעבור גם אם יש ACL חוסם.

חומות אש מתקדמות

ש: "מה ההבדל בין חומת אש stateless ל-stateful?"

ת: ACL Stateless (רגיל) בודקת כל חבילה בנפרד – לא "זוכרת" שיחות, אז צריך לפתוח ידנית פורטים לתשובות. Stateful (ZPF/CBAC) זוכרת שיחות שיצאו, ומאפשרת רק את התשובות התואמות להיכנס – בטוח וקל בהרבה.

ש: "ב-ZPF הגדרתי OUTSIDE→INSIDE עם inspect. איך התשובות חוזרות אם אין zone-pair בכיוון ההפוך?"

ת: זה בדיוק מה ש-inspect עושה: הנתב זוכר את השיחה בטבלת state, וכשמגיעה תשובה תואמת – היא עוברת אוטומטית, בלי צורך ב-zone-pair הפוך. תעבורה השדח מבחוץ עדיין נחסמת.

ש: "מה ההבדל בין inspect ל-pass ב-ZPF?"

ת: inspect עוקב אחרי השיחה ומאפשר תשובות אוטומטיות. (stateful) pass רק מעביר בכיוון אחד בלי מעקב - לתשובה צריך pass נפרד בכיוון ההפוך. כמעט תמיד רוצים inspect.

ש: "מה זה DMZ ולמה צריך אותו?"

ת: אזור "מפורז" בין הרשת הפנימית לאינטרנט, שבו יושבים השרתים הציבוריים (אתר, מייל). הרעיון: אם שרת ב-DMZ נפרץ, התוקף עדיין לא נמצא ברשת הפנימית - יש חומת אש נוספת בין ה-DMZ לפנים.

ש: "אם יש לי חומת אש, אני מוגן לגמרי?"

ת: לא. חומת אש בודקת כתובות ופורטים, אבל התקפה יכולה להגיע בפורט שפתחת (SQL injection) דרך פורט (80) לכן צריך גם IPS (פרק 5) שבודק תוכן, וגם הגנות בשכבה 2 (פרק 6). (להגנה לעומק).

מילון מונחים - הגדרות

הגדרות תמציתיות של המונחים המרכזיים בפרק. שימושי גם כדף עזר לבחינה.

מונח	הגדרה
חומת אש (Firewall)	מערכת שמסננת תעבורה בין רשתות לפי מדיניות (permit/deny).
ACL (Access Control List)	רשימה סדורה של כללי permit/deny; נסרקות מלמעלה למטה, עצירה בהתאמה ראשונה.
implicit deny	חסימה סמויה של כל מה שלא הותר במפורש, בסוף כל ACL.
Stateless	סינון כל חבילה בנפרד, ללא זכירת שיחות (ACL רגיל).
Stateful	זכירת שיחות שיצאו והתרת התשובות התואמות (ZPF/CBAC/ASA). בלבד.
ACL סטנדרטי	מספרים 1-99; בודק רק כתובת מקור; ממקמים קרוב ליעד.
ACL מורחב	מספרים 100-199; בודק מקור, יעד, פרוטוקול ופורט; ממקמים קרוב למקור.
Wildcard mask	מסכה הפוכה למסכת רשת: 0=חייב להתאים, 1=לא אכפת. $255.255.255.255 =$ פחות המסכה.
in / out	כיוון החלת ACL מנקודת מבט הנתב: נכנס לממשק (in) או יוצא ממנו (out).
host / any	קיצורי wildcard: host=כתובת בודדת (0.0.0.0), any=כל כתובת (255.255.255.255).
established	מילת מפתח ב-ACL המתירה רק חבילות תשובה של חיבור TCP קיים.
Time-based ACL	כלל ACL שתקף רק בזמנים מוגדרים (דורש שעון NTP).
Reflexive ACL	'ACL מראה' שיוצר אוטומטית התר זמנית לתשובות של תעבורה שיצאה.
Dynamic ACL (Lock-and-Key)	דלת זמנית שנפתחת רק לאחר שהמשתמש מזדהה בנתב.
CBAC	חומת אש stateful קלאסית ב-IOS; בוחנת תעבורה יוצאת ופותחת התר לתשובות.
ZPF (Zone-Based Firewall)	חומת אש מודרנית ב-IOS מבוססת אזורים ומדיניות בין זוגות אזורים.
Zone / Zone-pair	אזור אבטחה שממשקים משויכים אליו; מדיניות מוגדרת בין זוג אזורים בכיוון אחד.
inspect / pass / drop	פעולות ZPF: inspect=stateful (תשובות אוטומטיות), pass=מעבר חד-כיווני, drop=חסימה.
DMZ	אזור מפורז לשרתים ציבוריים, מבודד מהרשת הפנימית.

מונח	הגדרה
Anti-spoofing	חסימת כתובות מקור מזויפות (פרטיות/פנימיות) בכניסה מהאינטרנט.

פרק 5 – מניעת חדירה לרשת המקומית והרחבה (IDS / IPS)

11 שעות עיוני + 3 מעשי · שבועות 13-16

מטרות: מערכות זיהוי פלישה (IDS) · מערכות מניעת פלישה (IPS) · הגדרה ב-CLI · ניטור ופתרון תקלות
בבגרות: ההבדל IDS/IPS (ניטור+התראה מול ניטור+חסימה אוטומטית)

לפני שמתחילים – במה זה שונה מחומת אש? (למי שאין רקע)

חומת אש (פרק 4) בודקת סימנים תובנות – "מי מדבר עם מי ובאיזו דלת". היא לא מסתכלת מה בתוך החבילה. IDS/IPS מסתכלות על נכותה של החבילה ועל תוגהנתה – ומחפשות סימנים של התקפה, גם אם הפורט מותר. **אנלוגיה:** חומת אש = שומר שבדק תעודת זהות בכניסה. IDS/IPS = מצלמות אבטחה + מאבטח בתוך הבניין שמזהים התנהגות חשודה גם של מי שנכנס חוקית. IDS (Detection) = מצלמה שהעירתם אם רואה משהו חשוד (אבל לא עוצרת). IPS (Prevention) = מאבטח שרצוץ את החשוד במקום. **חתימה** (Signature) = "תמונת מבוקש" – תבנית ידועה של התקפה שהמערכת מחפשת.

5.1 למה חומת אש לא מספיקה

חומת אש (פרק 4) מחליטה לפי כתובות ופורטים. אבל התקפה יכולה להגיע בדיוק בפורט שפתחנו: SQL injection בתוך בקשת HTTP לפורט 80, ניצול חולשה בשרת המייל בפורט 25, או תולעת שמתפשטת דרך SMB שאנחנו מאפשרים בין סניפים. חומת האש רואה "TCP 80 ל-web server – מותר" ולא מסתכלת מה בתוך החבילה. כאן נכנסות מערכות IDS/IPS: הן מסתכלות על **התוכן** וההתנהגות ומחפשות סימנים של התקפה.

סיפור מהחיים: 10 דקות של Slammer (2003)

תולעת SQL Slammer הייתה חבילת UDP אחת בגודל 376 בתים לפורט (Microsoft SQL) 1434 כל שרת נגוע שלח אותה לכתובות אקראיות בקצב מרבי. תוך 10 דקות נדבקו 75,000 שרתים; כספומטים של Bank of America הפסיקו לעבוד, חלק מטיסות Continental בוטלו, ו-911 בסיאטל נפל. מי שהיה עם IPS מעודכן – חתימה אחת ("UDP 1434, גודל 376, המחרוזת הזו") חסמה את זה מיד. מי שהיה רק עם חומת אש שאיפשרה SQL בין הסניפים – נדבק. ומה שמדהים: מיקרוסופט פרסמה תיקון 6 חודשים קודם.

IDS 5.2 מול IPS – ההבדל המהותי

	Intrusion Detection – IDS System	Intrusion Prevention – IPS System
הגדרה (כמו בבגרות)	מערכת ניטור שנועדה לספק התראות בעת ניסיונות חדירה	מערכת ניטור שמאפשרת זיהוי וחסימה אוטומטית של ניסיונות חדירה
מיקום	מחוץ לנתיב (out-of-band, promiscuous); מקבלת עותק של התעבורה דרך SPAN/TAP	בתוך הנתיב (inline): התעבורה עוברת דרכה, חבילה אחר חבילה
תגובה	התראה (syslog), מייל, רישום; יכולה לבקש מחומת אש/נתב לחסום אחרי שהחבילה הראשונה כבר עברה, או לשלוח TCP reset	מפילה את החבילה הזדונית עוד לפני שהגיעה ליעד; חוסמת את החיבור/התוקף
השפעה על הרשת	אפס השהיה; אם ה-IDS נופל – הרשת ממשיכה	מוסיפה השהיה (latency); אם ה-IPS נופל – או שהרשת נופלת (fail-closed) או שעוברים ללא הגנה (fail-open)
מחיר של טעות (false positive)	התראה מיותרת – מטריד	תעבורה לגיטימית נחסמת – פוגע בעסק. לכן IPS דורש כוונן קפדני
מה היא רואה	יכולה לפספס חבילות בעומס (עותק)	רואה הכול, כולל חבילות שהיא עצמה מפילה

	Intrusion Detection - IDS System	Intrusion Prevention - IPS System
מקרי שימוש	ניטור, forensics, סביבה שלא סובלת חסימה בטעות	הגנה בזמן אמת בקצה ובין אזורים

שאלת תלמיד: "אז למה שמישהו יבחר IDS, אם IPS גם מזהה וגם חוסם?"

שלוש סיבות: (1) **סיכון של false positive** - בבית חולים או בבורסה, לחסום תעבורה לגיטימית בטעות גרוע יותר מלהחמיץ התקפה; מתחילים ב-IDS, מכווננים, ורק אז עוברים ל-IPS. (2) **ביצועים** - IPS inline על קו 100Gbps הוא ציוד יקר מאוד; IDS על עותק יכול לדגום. (3) **נראות** - IDS פנימי (על SPAN של המתג המרכזי) רואה תנועה רוחבית בין מחשבים שלא עוברת דרך שום חומת אש. בפועל ארגונים מפעילים את שניהם. ורוב מוצרי ה-IPS ניתנים להגדרה במצב IDS (monitor-only).

5.3 מבוסס-מארח (HIPS) מול מבוסס-רשת (NIPS)

	Host-based - HIPS	Network-based - NIPS
איפה	תוכנה על השרת/המחשב עצמו (agent)	מכשיר/מודול בנתיב הרשת (ASA עם מודול IPS, Firepower, IOS IPS, Snort/Suricata)
מה רואה	הכול במחשב: קריאות מערכת, קבצים, registry, זיכרון, ותעבורה מוצפנת אחרי הפענוח	תעבורת רשת בלבד; לא רואה לתוך TLS בלי SSL inspection
יתרון	מגן גם כשהמחשב מחוץ לרשת (לפטופ בבית); מבין את ההקשר (איזו אפליקציה)	מכשיר אחד מגן על מאות מחשבים; לא צורך מערכת ההפעלה; רואה סריקות ו-DoS
חסרון	התקנה ותחזוקה בכל מחשב; צורך משאבים; תלוי במערכת ההפעלה	עיוור למה שקורה בתוך המארח ולתעבורה מוצפנת
דוגמה	Cisco Security Agent (CSA) - מוזכר בתכנית; הופסק ב-2010 Cisco Secure Endpoint (היום: AMP), CrowdStrike, Microsoft Defender EDR - התחום נקרא EDR	Cisco Firepower NGIPS, Snort (קוד פתוח, שנרכש על ידי סיסקו), Palo Alto Suricata, Threat Prevention

CSA עבד לפי גישה התנהגותית ולא לפי חתימות: הוא יירט קריאות מערכת (system calls) ועצר התנהגות חשודה - "תוכנה שהגיעה במייל מנסה לשנות את ה-registry ולפתוח פורט" - גם בלי להכיר את הנוזקה. זה הרעיון של HIPS מודרני.

5.4 שיטות זיהוי

שיטה	איך	יתרון	חסרון
מבוססת חתימות (Signature / pattern)	השוואה לתבניות ידועות של התקפות (מחרוזת, רצף חבילות)	מדויקת, מעט false positive, קלה להבנה	לא מזהה התקפה חדשה (zero-day); דורשת עדכונים
מבוססת אנומליה (Anomaly / profile)	לומדת "מה נורמלי" (baseline) ומתריעה על חריגה - פתאום 500 חיבורי SSH בדקה	מזהה התקפות לא מוכרות	הרבה false positive; אם ה-baseline נלמד בזמן התקפה - היא "נורמלית"
מבוססת מדיניות (Policy)	המנהל מגדיר כללים: "אסור Telnet מרשת X"	פשוט, מדויק לארגון	מוגבל למה שחשבו עליו

שיטה	איך	יתרון	חסרון
מבוססת פיתיון (Honeypot)	מערכת "מזמינה" שאין לה שימוש לגיטימי - כל גישה אליה חשודה	אפס false positive; לומדים על התוקף	לא מגן ישירות; דורש תחזוקה
מוניטין (Reputation)	רשימות של IP/דומיינים (Cisco זדוניים ידועים Talos)	מהיר	תוקף חדש לא ברשימה

5.5 חתימות (Signatures)

חתימה היא תיאור של תבנית התקפה שה-IPS מחפש. חתימות מקובצות ב**קובץ חתימות** (Signature pack- age / SDF) שסיסקו מעדכנת; לכל חתימה מזהה (ID) ותת-מזהה (subsig), ולכל אחת **מנוע** (micro-engine) שמתאים לסוג - atomic-ip, service-http, string-tcp, multi-string ועוד.

אטומית מול מורכבת - נשאל בתכנית

	חתימה אטומית (Atomic)	חתימה מורכבת (Composite / Stateful)
מה בודקת	חבילה אחת ובודדת - למשל: "ICMP echo עם גודל < 1000" או "TCP עם דגלי SYN+FIN יחד" (לא חוקי)	רצף של חבילות/אירועים לאורך זמן - למשל: "יותר מ-100 SYN לפורטים שונים באותו מארח תוך 5 שניות" (port scan), או מחרוזת שמפוצלת בין כמה חבילות
זיכרון/מצב	לא צריך לשמור מצב - מהיר וזול	חייבת לזכור (state), עד "חלון אירועים" (event horizon)
דוגמה	Ping of Death, LAND attack (מקור = יעד)	SYN flood, סריקת פורטים, brute force

תכונות של חתימה

- Enabled / Disabled - פעילה או לא (מושבבת = טעונה בזיכרון אך לא בודקת).
- Retired / Unretired - בפנסיה = לא טעונה לזיכרון כלל (חוסך משאבים). כדי להשתמש בחתימה היא צריכה להיות unretired וגם enabled.
- Severity - informational / low / medium / high.
- Fidelity rating (SFR) - עד כמה החתימה מדויקת (0)-(100).
- Action - מה לעשות כשיש התאמה (ראו 5.6).
- **קטגוריות** - ב-IPS IOS: ios_ips basic (חתימות בסיסיות, לנתב עם זיכרון מועט) ו- ios_ips ad-vanced.

5.6 פעולות (Actions) ואזהקות (Alarms)

מה IPS יכול לעשות כשחתימה תואמת

פעולה	משמעות
produce-alert	שלח התראה. (syslog / SDEE) ברירת מחדל ברוב החתימות.
produce-verbose-alert	התראה + עותק של החבילה (לניתוח).
deny-packet-inline	הפל את החבילה הזו.
deny-connection-inline	הפל את כל החבילות של החיבור (TCP flow) הזה.

פעולה	משמעות
deny-attacker-inline	הפל כל תעבורה מכתובת התוקף לזמן מוגדר - החזק ביותר, והמסוכן ביותר ב-false positive.
reset-tcp-connection	שלח TCP RST לשני הצדדים - היחידה שגם IDS (מחוץ לנתיב) יכולה לבצע.

ארבעה סוגי תוצאות - חובה להבין

לא הייתה התקפה	הייתה התקפה	המערכת התריעה
False Positive - אזעקת שווא; מטריד, וב-IPS חוסם משהו לגיטימי	True Positive - מצוין	המערכת התריעה
True Negative - מצוין	False Negative - הכי גרוע: התקפה עברה בשקט	המערכת שתקה

שאלת תלמיד: "מה יותר גרוע - false positive או false negative?"

תלוי במערכת. ב-IDS false positive זה רק רעש; false negative זה פריצה שלא ראינו - גרוע. ב-IPS false positive חוסם עסק (הזמנות לא נכנסות, טלפוניה נופלת) - זה מה שמפחיד מנהלים ולכן הם מעדיפים לפעמים לכבות חתימות; ואז מגיע ה-false negative. האיזון נקרא **כוונון** (tuning) - מכבים חתימות לא רלוונטיות (חתימות ל-IIS ברשת של Linux, מעלים סף, ומחריגים כתובות מהימנות. אין תשובה אחת; זה מה שעושים אנשי SOC כל היום.

5.7 ניטור IPS

- Syslog - ההתראות נשלחות כהודעות (Sig:2004 Subsig:0 Sev:25) %IPS-4-SIGNATURE: (ICMP Echo Request [10.1.1.5:0 -> 10.2.2.2:0]).
- SDEE (Security Device Event Exchange) - פרוטוקול מבוסס HTTPS/XML שסיסקו יצרה כדי שתחנת ניהול תשלוק אירועים מה-IPS (pull) בצורה מאובטחת. דורש http secure-server ip.
- **תחנות ניהול:** בעבר IEV / IME / MARS (מוזכרים בחומרים ישנים); היום Firepower Management Center (FMC), או SIEM כללי (Splunk, QRadar, ELK) שמקבל syslog מכל המערכות ומבצע **קורלציה** - "אותו IP הופיע ב-IPS, בחומת האש וב-AD תוך דקה".

5.8 הגדרת IOS IPS ב-CLI

נתב סיסקו יכול לתפקד כ-IPS (מוגבל) בעצמו. התהליך המלא בציוד אמיתי:

1. הורדת חבילת חתימות (IOS-Sxxx-CLI.pkg) ומפתח ציבורי (realm-cisco.pub.key.txt) מ-Cisco.com.
2. יצירת תיקייה ב-flash לחתימות.
3. הגדרת המפתח הציבורי (כדי שהנתב יודא שהחבילה חתומה על ידי סיסקו).
4. הגדרת IPS: שם, מיקום, התראות, קטגוריות.
5. החלה על ממשק וטעינת החבילה.

! שלב 2 - תיקייה

```
R1# mkdir ipsdir
```

! שלב 3 - מפתח ציבורי של סיסקו (מעתיקים מהקובץ; קטע מקוצר)

```
R1(config)# crypto key pubkey-chain rsa
```

```
R1(config-pubkey-chain)# named-key realm-cisco.pub signature
```

```
R1(config-pubkey-key)# key-string
```

```
R1(config-pubkey)# 30820122 300D0609 2A864886 ...
```

```
R1(config-pubkey)# quit
```

```

! שלב 4 - הגדרת ה-IPS
R1(config)# ip ips config location flash:ipsdir
R1(config)# ip ips name MYIPS ACL - רק תעבורה שתואמת ל-101 MYIPS list ip - אפשר !
R1(config)# ip ips notify log syslog - ל-התראות !
R1(config)# ip http secure-server
R1(config)# ip ips notify sdee ! ולתחנת ניהול
R1(config)# ip ips signature-category
R1(config-ips-category)# category all
R1(config-ips-category-action)# retired true ! קודם - הכול בפנסיה
R1(config-ips-category-action)# exit
R1(config-ips-category)# category ios_ips basic
R1(config-ips-category-action)# retired false ! ואז - רק הבסיסיות פעילות
R1(config-ips-category-action)# exit
R1(config-ips-category)# exit
! שלב 5 - החלה על ממשק (בכיוון שממנו מגיעה התעבורה החשודה)
R1(config)# interface g0/0
R1(config-if)# ip ips MYIPS in
! טעינת חבילת החתימות (מ-TFTP/USB) - ב-Packet Tracer שלב זה לא קיים
R1# copy tftp://10.0.0.5/IOS-S416-CLI.pkg idconf

```

שינוי חתימה בודדת - הדוגמה הקלאסית: התראה + חסימה על ping

```

R1(config)# ip ips signature-definition
R1(config-sigdef)# signature 2004 0 2004/0 = ICMP Echo Request !
R1(config-sigdef-sig)# status
R1(config-sigdef-sig-status)# retired false
R1(config-sigdef-sig-status)# enabled true
R1(config-sigdef-sig-status)# exit
R1(config-sigdef-sig)# engine
R1(config-sigdef-sig-engine)# event-action produce-alert
R1(config-sigdef-sig-engine)# event-action deny-packet-inline
R1(config-sigdef-sig-engine)# exit
R1(config-sigdef-sig)# exit
R1(config-sigdef)# exit
Do you want to accept these changes? [confirm]

```

טיפ: מה עובד ב-Packet Tracer

Packet Tracer תומך בתת-קבוצה: ip ips config location, ip ips name, ip ips no-, ושינוי log tify, signature-category, (all retired / ios_ips basic), ip ips NAME in|out, ושינוי חתימה (ICMP echo) 2004 0 עם produce-alert ו-deny-packet-inline אין טעינת חבילה ואין SDEE. תרגיל ה-ping הוא התרגיל שעובד - ורואים בשרת ה-syslog את ההתראה ואת ה-ping נכשל. זה מספיק להמחשה.

5.9 וריפיקציה ופתרון תקלות

```

R1# show ip ips all ! סיכום: שם, ממשקים, קטגוריות, מספר חתימות טעונות
R1# show ip ips configuration
R1# show ip ips interfaces
R1# show ip ips signatures [count] ! אילו חתימות פעילות
R1# show ip ips statistics ! כמה חבילות נבדקו, כמה התראות
R1# clear ip ips statistics
R1# show ip ips sessions

```

תסמין	סיבה נפוצה ופתרון
אין התראות בכלל	ה-IPS לא מוחל על הממשק / בכיוון הלא נכון. תעבורה נכנסת מהאינטרנט ⇒ in על הממשק החיצוני. בדקו <code>show ip ips interfaces</code> .
0 signatures loaded"	קטגוריה all retired ולא unretired כלום; או חבילת חתימות לא נטענה (<code>copy ... idconf</code>); או מפתח ציבורי חסר/שגוי - הנתב דוחה חבילה לא חתומה.
CPU 100% / הנתב איטי	יותר מדי חתימות (advanced) על נתב קטן). השאירו <code>ios_ips basic</code> , השתמשו ב- <code>list ACL</code> כדי לבדוק רק תעבורה רלוונטית.
יש התראה אך החבילה עוברת	ה-action הוא <code>produce-alert</code> בלבד; הוסיפו <code>deny-packet-inline</code> או שהחתימה <code>enabled</code> או <code>retired</code> .
תעבורה לגיטימית נחסמת	<code>false positive</code> . זהו את החתימה ב- <code>syslog</code> . ובטלו/כווננו אותה; או השתמשו ב- <code>ip ips name</code> <code>list ACL</code> X להחריג.

5.10 מדריך פקודות מרוכז - פרק 5

פקודה	תפקיד
<code>mkdir ipsdir</code>	תיקייה לחתימות
<code>→ crypto key pubkey-chain rsa named-key realm-cisco.pub signature</code>	מפתח לאימות חבילה
<code>ip ips config location flash:ipsdir</code>	מיקום
<code>ip ips name NAME [list ACL]</code>	כלל IPS
<code>ip ips notify log sdee</code>	יעד התראות
<code>category → ip ips signature-category retired true → all</code>	כיבוי כל החתימות
<code>retired → category ios_ips basic false</code>	הפעלת הבסיסיות
<code>ip ips NAME in out</code> (ממשק)	החלה
<code>copy tftp://...pkg idconf</code>	טעינת חתימות
<code>→ ip ips signature-definition engine/status → signature ID SUB</code>	עריכת חתימה
<code>show ip ips all configuration signatures statistics</code>	ורפיקציה

5.11 תרגילים לתלמידים

תרגיל 1 - True/False Positive/Negative

סווגו: א. ה-IPS חסם עדכון Windows לגיטימי כי הוא "נראה כמו הורדת קובץ הרצה חשוד". ב. תולעת
עברה דרך ה-IDS בלי התראה כי החתימה לא עודכנה. ג. ה-IDS התריע על סריקת Nmap שאכן בוצעה. ד.
תעבורת Zoom עברה כרגיל ללא התראה.

א. False Positive. ב. False Negative. ג. True Positive. ד. True Negative.

תרגיל 2 – אטומית או מורכבת?

א. חבילת TCP עם כל 6 הדגלים דלוקים ("Xmas scan ב. 50 ניסיונות כניסה כושלים ל-SSH מאותו IP תוך דקה. ג. חבילת IP שבה כתובת המקור שווה לכתובת היעד. ד. מחרוזת /etc/passwd שמפוצלת בין שתי חבילות HTTP.

א. אטומית ב. מורכבת ג. אטומית (LAND) ד. מורכבת (דורשת הרכבת זרם)

תרגיל 3 – בחירת פעולה

לכל מצב בחרו את ה-action המתאים ביותר ונמקו: א. חתימה עם fidelity 30 (לא מדויקת) לפעילות חשודה קלה. ב. חתימה ל-SQL injection ודאית (fidelity 95) לשרת ה-web. ג. תוקף ששולח 10,000 SYN בשנייה. ד. IDS מחוץ לנתיב שזיהה session זדוני.

א. produce-alert בלבד – סיכון false positive גבוה. ב. deny-connection-inline (או deny-packet) + alert. ג. deny-attacker-inline – לחסום את המקור לזמן. ד. reset-tcp-connection – היחיד שזמין ל-IDS מחוץ לנתיב.

תרגיל 4 – תכנון פריסה

ציירו רשת: אינטרנט – נתב קצה – חומת אש – מתג מרכזי – (שרתים, משתמשים). סמנו היכן תמקמו IPS והיכן IDS, ונמקו. היכן תתקימו HIPS?

IPS inline בין חומת האש למתג המרכזי (או כמודול בחומת האש) – מגן על הכול מהאינטרנט. IDS על SPAN של המתג המרכזי – רואה תנועה רוחבית פנימית. HIPS/EDR על השרתים (בעיקר web, DB, DC) ועל מחשבי המשתמשים (ניידים).

5.12 שאלות בסגנון בגרות

שאלה 1

התאימו: מערכת _____ היא מערכת ניטור שמאפשרת זיהוי וחסמה אוטומטית של ניסיונות חדירה. מערכת _____ היא מערכת ניטור שנועדה לספק התראות בעת ניסיונות חדירה. (IDS / IPS / DNS / RADIUS / TACACS)

IDS · IPS

שאלה 2

מהו ההבדל במיקום ברשת בין IDS ל-IPS, ומה המשמעות לגבי השהיה?
IDS – מחוץ לנתיב (promiscuous), מקבל עותק ⇒ אין השהיה. IPS – בתוך הנתיב (inline), התעבורה עוברת דרכו ⇒ מוסיף השהיה.

שאלה 3

מה ההבדל בין חתימה אטומית לחתימה מורכבת?
אטומית – בודקת חבילה בודדת, ללא שמירת מצב. מורכבת – בודקת רצף חבילות לאורך זמן, שומרת מצב.

שאלה 4

מנהל הגדיר IOS IPS ו-true category all retired בלבד. אילו חתימות פעילות?
אף אחת – חייבים לבצע unretire (retired false) לקטגוריה כלשהי, למשל ios_ips basic.

שאלה 5

איזו מהפעולות הבאות אינה זמינה ל-IDS שנמצא מחוץ לנתיב התעבורה? 1. produce-alert 2. deny- packet-inline 3. reset-tcp-connection 4. produce-verbose-alert

2 - אי אפשר להפיל חבילה שכבר עברה; ה-IDS רואה רק עותק.

שאלה 6

מהו HIPS ומה יתרונו המרכזי על פני IPS רשתי?

Host-based IPS - תוכנה על המארח עצמו. יתרון: רואה תעבורה מוצפנת אחרי הפענוח ואת ההתנהגות בתוך המחשב (קבצים, זיכרון), ומגן גם כשהמחשב מחוץ לרשת הארגון.

5.13 מעבדה (3 שעות) - Packet Tracer IOS IPS

1. טופולוגיה: PC-A (10.1.1.10) — R1 — PC-B (10.2.2.10); שרת Syslog ברשת של PC-B. הגדירו log- ging לשרת.
2. ב-R1: ip ips name IOSIPS, ip ips config location flash:ipsdir, mkdir ipsdir, ip ips notify log all retired, ios_ips basic unretired. קטגוריות: produce-alert + deny-packet-inline.
3. שנו חתימה 2004 0: retired false, enabled true, event-action produce-alert + deny-packet-inline.
4. החילו ip ips IOSIPS out על הממשק לכיוון PC-B (או in על הממשק מ-PC-A).
5. מ-PC-A: ping ל-PC-B ⇒ נכשל. בשרת ה-syslog: הודעת 2004-SIGNATURE: Sig: IPS-4. מ-PC-B: ping ל-PC-A ⇒ מצליח (הכיוון!). הסבירו.
6. הסירו את deny-packet-inline והשאירו ping. produce-alert. עובר אך יש התראה - זו התנהגות IDS. דונו בהבדל.
7. show ip ips statistics, show ip ips all - כמה חבילות נבדקו?

בנק שאלות שתלמידים שואלים - ותשובות מוכנות

שאלות נפוצות בפרק IDS/IPS, עם תשובות מוכנות.

ש: "אם IPS גם מזהה וגם חוסם, למה שמישהו יבחר IDS?"

ת: שלוש סיבות: (1) סיכון של false positive - בבית חולים או בבורסה, לחסום תעבורה לגיטימית בטעות גרוע מלהחמיץ התקפה. (2) ביצועים - IPS inline על קו מהיר יקר מאוד. IDS (3) פנימי (על SPAN רואה תנועה רוחבית בין מחשבים שלא עוברת בשום חומת אש. בפועל מפעילים את שניהם.

ש: "מה ההבדל בין IDS/IPS לאנטי-וירוס?"

ת: אנטי-וירוס מגן על דחא בשחמב מיצבק. IPS מגן על תשרה תרובעת בין מחשבים. HIPS (host-based) מטשטש את הגבול - הוא IPS שרץ על המחשב עצמו.

ש: "מה יותר גרוע - false positive או false negative?"

ת: תלוי במערכת. ב-IDS, false positive הוא רק רעש; false negative (התקפה שעברה בשקט) גרוע יותר. ב-IPS, false positive קסע מסוח (הזמנות לא נכנסות) - ולכן מנהלים לפעמים מכבים חתימות, וזה מוביל ל-false negatives. האיוון הזה נקרא "כוונון" (tuning) וזו עבודת ה-SOC.

ש: "מה ההבדל בין חתימה אטומית למורכבת?"

ת: אטומית בודקת תחא הליב (למשל Ping of Death - חבילה גדולה מדי) - מהירה, בלי זיכרון. מורכבת בודקת פצור של חבילות לאורך זמן (למשל סריקת פורטים או SYN flood - חייבת לזכור מצב.

ש: "אם IPS מבוסס חתימות, איך הוא תופס התקפה חדשה שאין לה חתימה?"

ת: הוא לא, אם הוא רק מבוסס-חתימות - זו החולשה. לכן קיימות שיטות נוספות: זיהוי אנומליה (חריגה מ"נורמלי") ומוניטין (רשימות IP זדוניים). מערכות מודרניות משלבות כמה שיטות.

ש: "מה זה SPAN ולמה IDS צריך אותו?"

ת: SPAN הוא "שיקוף פורט" - המתג מעתיק את כל התעבורה לפורט שאליו מחובר ה-IDS. כך ה-IDS מקבל קתוע של הכול בלי לשבת בנתיב עצמו - ולכן אם ה-IDS נופל, הרשת ממשיכה לעבוד.

ש: "אילו פעולות IPS יכול לבצע כשהוא מזהה התקפה?"

ת: מ-alert בלבד (produce-alert), דרך הפלת החבילה (deny-packet-inline), הפלת כל החיבור (deny-connection-inline), חסימת התוקף לזמן (deny-attacker-inline), ועד שליחת TCP reset - הפעולה היחידה שגם IDS מחוץ לנתיב יכול לבצע.

ש: "מה זה CSA שמופיע בתכנית?"

ת: Cisco Security Agent - תוכנת HIPS ישנה שהותקנה על תחנות קצה וזיהתה התנהגות חשודה (לא רק חתימות). היא הופסקה ב-2010; היום התחום נקרא EDR (כמו Microsoft Defender, CrowdStrike).

מילון מונחים - הגדרות

הגדרות תמציתיות של המונחים המרכזיים בפרק. שימושי גם כדף עזר לבחינה.

מונח	הגדרה
IDS (Intrusion Detection System)	מערכת שמנטרת ומתריעה על ניסיונות חדירה, אך אינה חוסמת.
IPS (Intrusion Prevention System)	מערכת שמזהה וגם חוסמת אוטומטית ניסיונות חדירה.
inline / out-of-band	IPS יושב בנתיב התעבורה (inline); IDS (out-of-band). עותק מחוץ לנתיב.
HIPS	IPS מבוסס-מארח - תוכנה על המחשב/שרת עצמו; רואה גם תעבורה מוצפנת.
NIPS	IPS מבוסס-רשת - מכשיר בנתיב שמגן על מארחים רבים.
CSA (Cisco Security Agent)	תוכנת HIPS ישנה של סיסקו; היום התחום נקרא EDR.
חתימה (Signature)	תבנית ידועה של התקפה שהמערכת מחפשת בתעבורה.
חתימה אטומית	בודקת חבילה בודדת, ללא שמירת מצב (למשל Ping of Death).
חתימה מורכבת	בודקת רצף חבילות לאורך זמן, שומרת מצב (למשל סריקת פורטים).
זיהוי מבוסס-אנומליה	זיהוי חריגה מ'התנהגות נורמלית' שנלמדה (baseline).
Honeypot	מערכת פיתיון שאין לה שימוש לגיטימי; כל גישה אליה חשודה.
False Positive	אזעקת שווא - התראה על תעבורה לגיטימית.
False Negative	החמצה - התקפה אמיתית שלא זוהתה (המצב הגרוע ביותר).
True Positive / Negative	זיהוי נכון של התקפה (positive) או של תעבורה תקינה (negative).
Tuning (כוונון)	התאמת חתימות והחרגות כדי לצמצם false positives; עבודת ה-SOC.
Action (פעולה)	מה שה-IPS עושה בהתאמה: alert, deny-packet/connection/attacker, TCP reset.
SDEE	פרוטוקול מאובטח (HTTPS/XML) שדרכו תחנת ניהול שולפת אירועי IPS.
SPAN	שיקוף פורט - העתקת תעבורה לפורט שאליו מחובר IDS/מנתח.

פרק 6 – אבטחת הרשת המקומית (LAN Security)

11 שעות עיוני + 2 מעשי · שבועות 17-19

מטרות: התקפות שכבה 2 · port security · STP/VLAN · DHCP/ARP · storm control · SPAN · NAC · VoIP/SAN ·
בבגרות: VLAN hopping, BPDU Guard, Evil Twin, root→port security, DTP→MAC overflow, bridge

לפני שמתחילים – מה קורה ב"שכבה 2"? (למי שאין רקע)

עד עכשיו דיברנו על כתובות IP (שכבה 3). אבל בתוך רשת מקומית, המכשירים מדברים ביניהם דרך **מתג** לפי **כתובות MAC** (שכבה 2). כמה מושגים: **מתג** (Switch) – מחבר את כל המחשבים ברשת המקומית. הוא לומד איזו כתובת MAC נמצאת באיזה פורט, ושומר זאת ב**טבלת** MAC. VLAN – "רשת וירטואלית". מפצל מתג פיזי אחד לכמה רשתות נפרדות ומבודדות (למשל VLAN למחלקת כספים ו-VLAN לאורחים) בלי לקנות עוד מתגים. Trunk – קישור בין מתגים שנושא כמה VLANים יחד. Broadcast – הודעה שנשלחת ל**לכ** המכשירים ברשת בבת אחת ("שידור"). STP – פרוטוקול שמונע "לולאות" בין מתגים (נסביר בהמשך למה לולאה מפילה רשת). **למה זה קריטי לאבטחה?** אם תוקף כבר מחובר לרשת המקומית (חיבר מחשב לשקע, פרץ ל-Wi-Fi), הוא פועל בשכבה 2 – תחתם לכל ההגנות של שכבה 3 (חומת אש, IP) לכן צריך להגן גם כאן.

6.1 למה שכבה 2 היא "הבטן הרכה"

כל מנגנוני האבטחה שלמדנו עד כה עובדים בשכבה 3 ומעלה (ACL, IPS, VPN) אבל אם התוקף כבר **ברשת המקומית** – חיבר לפטופ לשקע, פרץ ל-Wi-Fi, או השתלט על מחשב עובד – הוא פועל בשכבה 2, מתחת לכל ההגנות האלה. עיקרון קריטי: **מודל OSI הוא שרשרת – אם שכבה 2 נפרצת, כל השכבות מעליה נפגעות**. מתג "בוטח" בכל מה שמחובר אליו כברירת מחדל, וזו הבעיה.

סיפור מהחיים: השקע בחדר הישיבות

בבדיקת חדירה נפוצה, הבודק מגיע כ"טכניקאי", מבקש להמתין בחדר ישיבות, ומחבר מכשיר קטן (Rasp-berry Pi) לשקע רשת מתחת לשולחן. המכשיר מבצע ARP spoofing ומקליט תעבורה, או מריץ Responder hashes של סיסמאות. הוא יוצא אחרי חצי שעה, והמכשיר ממשיך לשדר דרך LTE. אף חומת אש לא ראתה כלום – הכול קרה בשכבה 2, בתוך ה-VLAN. ההגנות בפרק הזה (port security, DHCP snooping, DAI, 802.1X) הן בדיוק מה שהיה עוצר אותו.

6.2 מפת ההתקפות וההגנות בשכבה 2

התקפה	מה מנצלת	הגנה עיקרית
MAC table overflow (CAM flooding)	גודל מוגבל של טבלת ה-MAC	Port Security
VLAN hopping (switch spoofing)	DTP – משא-ומתן trunk אוטומטי	switchport mode access
VLAN hopping (double tagging)	Native VLAN	Native VLAN ייעודי ולא בשימוש
STP manipulation	בחירת root bridge לפי priority	BPDU Guard, Root Guard
DHCP starvation / spoofing (rogue DHCP)	אין אימות ל-DHCP	DHCP Snooping
ARP spoofing / poisoning (MITM)	ARPs חסר אימות	Dynamic ARP Inspection (DAI) (מסתמך על DHCP snooping)
MAC/IP spoofing	אין קשירת כתובת לפורט	IP Source Guard
CDP reconnaissance	CDP משדר דגם, IP, IOS	no cdp enable על פורטי קצה

Port Security-1 6.3 MAC Table Overflow

מתג לומד כתובות MAC ורושם אותן בטבלת CAM (Content Addressable Memory) יחד עם הפורט. הטבלה מוגבלת (למשל 8,000 רשומות). כלי כמו macof מציף את המתג באלפי כתובות MAC מזויפות בשנייה; הטבלה מתמלאת, והמתג עובר ל-fail-open - מתחיל לשדר כל מסגרת לכל הפורטים (כמו hub). עכשיו התוקף רואה את תעבורת כולם. זהו "MAC flooding".

Port Security – ההגנה

```
S1(config)# interface f0/1
S1(config-if)# switchport mode access ! חובה - port security לא עובד על trunk דינמי
S1(config-if)# switchport port-security
S1(config-if)# switchport port-security maximum 2 ! עד 2 MAC (מחשב + טלפון IP)
S1(config-if)# switchport port-security mac-address sticky ! לומד את הכתובת ושומר בקונפיג
S1(config-if)# switchport port-security violation shutdown
S1(config-if)# switchport port-security aging time 60
! וריפיקציה
S1# show port-security
S1# show port-security interface f0/1
S1# show port-security address
```

שלושה מצבי הפרה (violation)

מונה	התראה	מה קורה בהפרה	מצב
לא	לא	מפיל מסגרות מ-MAC לא מוכרות; הפורט נשאר up	protect
כן	כן (syslog/SNMP)	מפיל מסגרות; הפורט up	restrict
כן	כן	הפורט עובר ל-err-disabled - מושב ל-gmri	shutdown (ברירת מחדל)

שאלת תלמיד: "הפורט נכבה (err-disabled) איך מחזירים אותו?"

ידינית: shutdown ואז no shutdown על הממשק. אוטומטית אחרי זמן: errdisable recovery
show interfaces status err-disabled. הערה: sticky נדבק ל-running-config - אל תשכחו
write אחרת הכתובת תיעלם ב-reload.

טעות נפוצה

מגדירים port security ושוכחים switchport mode access. אם הפורט במצב dynamic, port security לא נכנס לתוקף כראוי. וגם: maximum 1 עם טלפון IP + מחשב מאחוריו ⇒ הפרות מיידיות; להגדיר maximum 2 או להשתמש ב-voice VLAN.

VLAN 6.4 – והתקפת VLAN Hopping

VLAN מפצל מתג פיזי אחד לכמה רשתות לוגיות מבודדות. מעבר בין VLANים דורש ניתוב (router / L3 switch). קישור בין מתגים שנושא כמה VLANים נקרא trunk ומשתמש בתיוג 802.1Q (מוסיף תג של 4 בתים עם מספר ה-VLAN לכל מסגרת). Native VLAN - ה-VLAN היחיד שעובר ב-trunk בלי תג (ברירת מחדל VLAN 1).

התקפה א': Switch Spoofing (ניצול DTP)

DTP (Dynamic Trunking Protocol) מאפשר לשני מתגים "לסכם" אוטומטית אם הקישור ביניהם יהיה trunk. הבעיה: פורט קצה במצב ברירת מחדל (dynamic desirable / dynamic auto) יסכים להפוך ל-trunk גם

מול מחשב של תוקף שמתחזה למתג ושולח DTP. ברגע שהקישור trunk – התוקף מקבל גישה לכל ה-VLANים. זו התשובה בבגרות: "השבתת DTP מונעת". VLAN hopping

התקפה ב': Double Tagging

התוקף (ב-VLAN של ה-native שולח מסגרת עם שני תגים: החיצוני = native VLAN (המתג הראשון מסיר אותו), הפנימי = ה-VLAN של הקורבן. המתג השני רואה את התג הפנימי ומעביר ל-VLAN הקורבן. חד-כיווני, אך מסוכן. הגנה: native VLAN שאינו בשימוש ואינו VLAN 1.

ההגנה על פורטים

```
! פורט קצה (למחשב) - מפורש access, כיבוי DTP
S1(config)# interface range f0/1 - 20
S1(config-if-range)# switchport mode access
S1(config-if-range)# switchport access vlan 10
S1(config-if-range)# switchport nonegotiate DTP לא לשלוח !
S1(config-if-range)# spanning-tree portfast
S1(config-if-range)# spanning-tree bpduguard enable
! פורט trunk, native מפורש, ייעודי
S1(config)# interface g0/1
S1(config-if)# switchport mode trunk
S1(config-if)# switchport nonegotiate
S1(config-if)# switchport trunk native vlan 999 "VLAN שחור", לא בשימוש
S1(config-if)# switchport trunk allowed vlan 10,20,30 ! רק מה שצריך
! פורטים לא בשימוש - לכבות ולשים ב-VLAN מבודד
S1(config)# interface range f0/21 - 24
S1(config-if-range)# switchport access vlan 999
S1(config-if-range)# shutdown
```

STP 6.5 והתקפות עליו

STP (Spanning Tree Protocol, 802.1D) מונע **לולאות** בשכבה 2. למה לולאות מסוכנות? למסגרת שכבה 2 אין TTL (בניגוד ל-IP) אם יש לולאה פיזית בין מתגים, מסגרת broadcast תסתובב לנצח, תשוכפל בכל סיבוב, ותייצר broadcast storm שמשתק את הרשת תוך שניות. STP חוסם באופן לוגי פורטים כדי להשאיר מסלול יחיד, ופותח אותם אם קישור נופל.

בבגרות (שאלה 13)

"פרוטוקול STP מונע לולאות מיתוג במודל ה-OSI בשכבה מספר ____ - 2". (Data Link) הפעולה של מניעת הלולאות נעשית על ידי ____ - Port blocking (חסימת יציאות).

איך נבחר ה-Root Bridge (נשאל בבגרות!)

המתג עם Bridge ID הנמוך ביותר הופך ל-Root. Bridge ID = Priority (2 = root) + MAC address. ברירת מחדל priority = 32768. אם ה-priority שווה - מכריע ה-MAC הנמוך ביותר.

בבגרות (שאלה 13)

4 מתגים, priority ברירת מחדל זהה. MACים: SW1=0C:0E:15:22:05:97, SW2=0C:E0:38:00:36:75, SW3=0C:E0:18:A1:B3:19, SW4=0C:0E:15:1A:3C:9D. מי ה-root? משווים בית-בית: SW1 ו-SW4 מתחילים ב-0C:0E:15, השאר ב-0C:E0. הבית הרביעי: SW1=22, SW4=1A. 22 > 1A ⇒ SW4 הוא ה-root bridge. הסיבה: "כי כתובת ה-MAC שלו היא הנמוכה ביותר" (וה-priority זהה).

OSPF DR/BDR - רקע לשאלה 2 (שכבה 3, אך נשאל)

בבחירת DR/BDR ב-OSPF: קודם priority הגבוה ביותר, ואם שווה - Router-ID הגבוה ביותר. בשאלת הבגרות. R1(pri 2, RID 1.1.1.1), R2(pri 1), R3(pri 2, RID 3.3.3.3), R4(pri 1). priority 2: R3

$R3 = DR \Rightarrow (RID\ 3.3.3.3) > R1$ (RID 1.1.1.1) - R1 הוא הגבוה מבין הנותרים בעלי priority 2. $R3 = DR, R1 = BDR$ תשובה: $R3 = DR, R1 = BDR$ (שימו לב: ההיגיון הפוך מ-STP - שם נמוך מנצח, כאן גבוה).

הגנות STP

מנגנון	מה עושה	איפה
PortFast	פורט קצה עובר מיד ל-forwarding (לא מחכה 30 שניות)	פורטי access למחשבים
BPDU Guard	אם פורט PortFast מקבל BPDU (כלומר חובר אליו מתג/תוקף) - err-disable מידי	פורטי קצה
Root Guard	מונע ממתג בפורט זה להפוך ל-root (אם ישלח BPDU עדיף - הפורט נחסם)	פורטים למתגי גישה מתחת
Loop Guard	מגן מלולאה כשפורט מפסיק לקבל BPDU	קישורים redundant

```
! פר-ממשק
S1(config-if)# spanning-tree portfast
S1(config-if)# spanning-tree bpduguard enable
! גלובלי - על כל פורטי PortFast (זו התשובה בבגרות שאלה 7)
S1(config)# spanning-tree portfast default
S1(config)# spanning-tree portfast bpduguard default
! שהמתג שלנו יהיה root בוודאות
S1(config)# spanning-tree vlan 10 root primary 24576 priority ל-
S1(config)# spanning-tree vlan 10 priority של 4096 4096 חייב כפולה
S1# show spanning-tree
```

DHCP Snooping, Spoofing ו-DHCP Starvation - 6.6

DHCP starvation: תוקף מבקש את כל הכתובות ב-pool (עם MACים מזויפים) - משתמשים אמיתיים לא מקבלים כתובת. DHCP spoofing (rogue server) (DoS): התוקף מקים שרת DHCP משלו שעונה מהר יותר, ומחלק לקורבנות default gateway = **הכתובת שלו** ו-DNS **שלו** $\Rightarrow$ MITM על כל התעבורה.

DHCP Snooping - ההגנה

המתג מסמן פורטים כ-trusted (לכיוון שרת ה-DHCP הליגיטימי) / uplink או untrusted (פורטי קצה, ברירת מחדל). הודעות שרת (OFFER, ACK) מפורט untrusted - נחסמות. המתג בונה DHCP Snooping Binding (MAC Table) $\leftrightarrow$ IP $\leftrightarrow$ פורט $\leftrightarrow$ VLAN - בסיס ל-DAI ו-IP Source Guard.

```
S1(config)# ip dhcp snooping
S1(config)# ip dhcp snooping vlan 10,20
! לכיוון שרת DHCP הליגיטימי
S1(config)# interface g0/1
S1(config-if)# ip dhcp snooping trust
! פורטי קצה 20 - f0/1
S1(config-if-range)# ip dhcp snooping limit rate 6 starvation נגד !
S1# show ip dhcp snooping binding
```

6.7 ARP Spoofing ו-Dynamic ARP Inspection (DAI) - 6.7

ARP ממפה IP ל-MAC, וחוסר כל אימות: כל מחשב יכול לשלוח "Gratuitous ARP" שאומר "אני ה-gateway" - והקורבנות יעדכנו את הטבלה שלהם ויתחילו לשלוח את התעבורה לתוקף. DAI (MITM) בודק כל הודעת ARP מול טבלת ה-DHCP Snooping: אם ה-MAC $\leftrightarrow$ IP לא תואם לרשומה - ההודעה נזרקת.

```
S1(config)# ip arp inspection vlan 10,20
S1(config)# interface g0/1
S1(config-if)# ip arp inspection trust ! uplink מהימן
! לפורטים סטטיים בלי DHCP - מגדירים ACL של ARP ידני
S1(config)# arp access-list STATIC-HOSTS
S1(config-arp-nacl)# permit ip host 10.0.0.5 mac host aaaa.bbbb.cccc
S1# show ip arp inspection
```

המשלים: IP Source Guard - מוודא שכתובת ה-IP במסגרת תואמת לפורט לפי טבלת ה-snooping (נגד IP spoofing).

6.8 Storm Control

מגביל את אחוז התעבורה מסוג broadcast / multicast / unknown-unicast על פורט; אם עוברים סף - המתג מפיל את העודף (ומתריע). מגן מ-broadcast storms (גם מלולאה וגם מתקלה/התקפה). התכנית מציינת "Storm Control (SC)".

```
S1(config-if)# storm-control broadcast level 5.00 ! מעל 5% מרוחב הפס - הגבל
S1(config-if)# storm-control multicast level pps 1k
S1(config-if)# storm-control action shutdown trap או !
S1# show storm-control
```

6.9 SPAN - שיקוף פורטים (הבסיס ל-IDS)

SPAN (Switched Port Analyzer, "port mirroring") מעתיק את כל התעבורה מפורט/VLAN מקור לפורט יעד - שאליו מחובר Wireshark או IDS. זה החיבור לפרק "IDS: 5 מחוץ לנתיב" מקבל את התעבורה דווקא דרך SPAN. RSPAN - שיקוף בין מתגים דרך VLAN ייעודי; ERSPAN - מעל IP (GRE).

```
S1(config)# monitor session 1 source interface f0/1 - 10 both
S1(config)# monitor session 1 destination interface f0/24 ! כאן ה-Wireshark/IDS
S1# show monitor session 1
```

שאלת תלמיד: "אם ה-IDS רק מקבל עותק דרך SPAN, למה שלא נחבר אותו inline ונחסום?"

כי אז הוא IPS, לא IDS - והוא מוסיף השהיה ונקודת כשל בנתיב. SPAN מאפשר לנטר בלי לגעת בזרימה: הפורט המשקף יכול אפילו ליפול בלי להשפיע על הרשת. זה בדיוק ה-trade-off מפרק 5.

6.10 NAC ו-802.1X

NAC (Network Access Control) - "בקרת בריאות": לפני שמחשב מקבל גישה מלאה, בודקים שהוא עומד בתנאים (אנטי-וירוס מעודכן, patch, אין תוכנות אסורות). מחשב שנכשל מועבר ל-"VLAN הסגר" (quarantine) לתיקון. הבסיס הטכני: 802.1X (פרק 3) - המתג/AP חוסם את הפורט עד אימות מול RADIUS. שילוב: 802.1X מאמת מי, NAC בודק באיזה מצב המכשיר.

6.11 מערכות קצה: IronPort, CSA, ומיילים/אתרים

- Cisco IronPort - משפחת מכשירים לאבטחת תוכן בקצה: ESA (Email Security Appliance) - סינון spam, phishing, ווירוסים במייל; WSA (Web Security Appliance) - proxy שמסנן אתרים זדוניים, URL filtering, בדיקת הורדות. סיסקו רכשה את IronPort ב-2007.
- CSA (Cisco Security Agent) - HIPS על התחנה (פרק 5).
- היום התחום נקרא CASB / Secure Web / Secure Email / SWG, ולרוב בענן. (Cisco Umbrella)

6.12 אבטחת VoIP ו-SAN

VoIP (טלפוניה על IP)

איומים: האזנה לשיחות (sniffing), toll fraud (שימוש לא מורשה בקווים לחיוב יקר), התחזות caller-ID (spoofing על ה-spam), SPIT (PBX קולי), הגנות: Voice VLAN **נפרד** (הפרדה מתעבורת הנתונים), DoS (בידוד לוגי), אימות TLS/SIP-TLS (ליתות), אימות מכשירי טלפון, ACL בין voice ל-data.

```
S1(config-if)# switchport access vlan 10 ! נתונים
S1(config-if)# switchport voice vlan 20 ! קול - מתייג בנפרד
```

SAN (רשת אחסון)

SAN מחברת שרתים לאחסון בלוקים (Fibre Channel / iSCSI) איומים: גישה לא מורשית ל-WWN, LUN spoofing. הגנות: Zoning (מי מדבר עם מי ב-fabric - מקביל ל-VLAN, LUN masking (איזה שרת רואה איזה נפח), VSAN (בידוד לוגי), אימות FC-SP / CHAP (ל-iSCSI, והצפנת נתונים במנוחה. חשיבות: כל הנתונים הקריטיים של הארגון נמצאים שם.

Wi-Fi 6.13 ו-Evil Twin

Evil Twin: התוקף מקים Access Point עם **אותו** SSID כמו הרשת החוקית, בעוצמה חזקה יותר. מכשירים מתחברים אליו אוטומטית (הם זוכרים את השם), והתוקף מבצע MITM - רואה הכול, מציג דף התחברות מזויף (captive portal) לגניבת סיסמה. הגנות: 802.1X WPA2/WPA3-Enterprise - המכשיר מאמת את השרת, לא רק להיפך), WIPS (Wireless IPS) שמזהה AP מתחזים, אימות הדדי.

בבגרות (שאלה 6)

"מהם מתכנני התקפת Evil Twin?" - **לשתול נקודת גישה זדונית, בעלת SSID זהה לנקודת גישה חוקית, לצורך גניבת מידע.**

6.14 מדריך פקודות מרוכז - פרק 6

פקודה	הגנה מפני
+ maximum + switchport port-security mac-address sticky + violation	MAC overflow
switchport + switchport mode access nonegotiate	VLAN hopping (DTP)
switchport trunk native vlan 999	double tagging
bpduguard + spanning-tree portfast ... default/enable	STP manipulation
/spanning-tree vlan N root primary priority	קיבוע root
limit rate + trust + ip dhcp snooping	DHCP spoofing/starvation
trust + ip arp inspection vlan	ARP poisoning
storm-control broadcast level	broadcast storm
monitor session	IDS ל-SPAN
switchport voice vlan	הפרדת VoIP
show, show port-security show ip dhcp snooping, spanning-tree binding	ורפיקציה

6.15 תרגילים לתלמידים

תרגיל 1 - התאמת התקפה להגנה

חברו: (1) MAC flooding (2) rogue DHCP (3) ARP poisoning (4) כל ה-VLANים (5) מתג מזויף שמנסה להיות root. הגנות: DAI / port security / BPDU Guard+Root

Guard / switchport nonegotiate / DHCP snooping.

· switchport nonegotiate (access)→4 · DAI→3 · DHCP snooping→2 · port security→1
BPDU Guard/Root Guard→5

תרגיל 2 - מי ה-root?

4 מתגים, SW1=32768, SW2=32768, SW3, SW4=32768. priority: 4096, MAC, SW1

SW3 - ה-priority נבדק ראשון והוא הנמוך. (4096) ה-MAC נבדק רק בתיקו. לו כולם היו 32768 - SW1 (MAC נמוך).

תרגיל 3 - ניתוח קונפיג

פורט f0/5 הוגדר: switchport port-security, maximum 1, violation shutdown. עובר חיבר אליו מתג קטן (switch) עם 3 מחשבים. מה יקרה, ומה ההודעה בלוג?

המתג הקטן יעביר מסגרות מ-MAC 3ים ⇒ בהפרה הראשונה (MAC שני) הפורט עובר ל-err-disabled ונכבה. בלוג: Fa0/5 ... psecure-violation ... PM-4-ERR_DISABLE: shut/no shut. שחזור:

תרגיל 4 - תכנון הקשחת מתג גישה

כתבו 8 פקודות הקשחה שתחילו על מתג גישה של קומה בבניין (24 פורטים למשתמשים, uplink אחד).

דוגמה: על פורטי הקצה: mode access, access vlan 10, nonegotiate, port-security max 2 sticky violation restrict, portfast, bpduguard enable, ip dhcp snooping (untrusted, limit uplink: mode trunk, nonegotiate, native vlan 999, allowed-ה-rate), no cdp enable. ip dhcp snooping + vlan, ip arp גלובלי: vlan list, dhcp snooping trust, arp inspection trust. vlan 999 + shutdown. inspection vlan, portfast bpduguard default. כיבוי פורטים לא בשימוש ל-

6.16 שאלות בסגנון בגרות

שאלה 1

מה הדרך למנוע מתקפת MAC Table overflow במתג?

Port security על כל הפורטים שאינם trunk, עם הגבלת מספר כתובות MAC.

שאלה 2

איזו התקפת שכבה 2 אפשר לסכל על ידי השבתת פרוטוקול DTP? 1. DHCP spoofing 2. ARP spoofing 3. VLAN hopping 4. ARP poisoning
(switch spoofing). 3. VLAN hopping

שאלה 3

באיזו פקודה מפעילים BPDUGuard על כל פורטי ה-PortFast במתג?

spanning-tree portfast bpduguard default (במצב config גלובלי).

שאלה 4

STP פועל בשכבה ___ של OSI ומונע ___ על ידי ___.

(Data Link) 2 · לולאות (broadcast storm) · חסימת פורטים. (port blocking)

שאלה 5

מהי מתקפת Evil Twin ואיזו טכנולוגיית Wi-Fi מסייעת למנוע אותה?

נקודת גישה זדונית עם SSID זהה לחוקית לצורך MITM/גניבת מידע. מניעה: WPA2/WPA3-Enterprise עם 802.1X (אימות הדדי - המכשיר מוודא את זהות השרת) ו-WIPS.

שאלה 6

מהו תפקיד DHCP Snooping ואיזה מנגנון אבטחה נוסף מסתמך על הטבלה שהוא בונה?

חוסם הודעות שרת DHCP מפורטים לא-מהימנים (rogue server) ומגביל קצב Dynamic (starvation). ARP Inspection ו-IP Source Guard מסתמכים על טבלת ה-binding שלו.

6.17 (מעבדה 2 שעות) - הקשחת מתג ב-Packet Tracer

1. Port security: 2 מחשבים על פורט אחד (דרך hub/מתג קטן), maximum 1, violation shutdown. הוסיפו מחשב שני ⇒ err-disabled שחזרו עם shut/no shut והעלו ל-2 maximum.
2. BPDUGuard: הגדירו portfast+bpduguard על פורט קצה; חברו אליו מתג נוסף ⇒ err-disabled.
3. Root bridge: 3 מתגים בטבעת; הגדירו את המרכזי כ-root primary spanning-tree; show - ודאו מי root ואיזה פורט blocking.
4. DTP: הגדירו trunk מפורש + nonegotiate בין המתגים; פורטי קצה access + nonegotiate.
5. DHCP snooping: הפעילו, סמנו את פורט השרת trusted; הוסיפו "שרת DHCP" תוקף על פורט un-trusted וראו שההצעות שלו נחסמות.

בנק שאלות שתלמידים שואלים - ותשובות מוכנות

שאלות נפוצות בפרק אבטחת הרשת המקומית, עם תשובות מוכנות.

ש: "אם יש חומת אש בכניסה לרשת, למה בכלל צריך להגן על המתגים בפנים?"

ת: כי חומת האש מגנה מפני האינטרנט (מבחוץ), אבל אם תוקף כבר פינפב (חיבר מחשב לשקע, פרץ ל-Wi-Fi, השתלט על מחשב עובד) - הוא פועל בשכבה 2, מתחת לחומת האש. שם צריך DHCP, port security, ו-snooping וכו'.

ש: "הפורט עבר ל-err-disabled ונכבה. איך מחזירים אותו?"

ת: ידנית: shutdown ואז no shutdown על הממשק. אוטומטית אחרי זמן: errdisable recovery cause psecure-violation. show interfaces status err-disabled.

ש: "למה לולאה בין מתגים כל כך מסוכנת?"

ת: כי למסגרת בשכבה 2 TTL היא (בניגוד ל-IP) אם יש לולאה פיזית, הודעת broadcast מסתובבת לנצח ומשוכפלת בכל סיבוב - "סופת broadcast" שמשתקת את הרשת תוך שניות. STP מונע זאת על ידי חסימת פורט.

ש: "איך בוחרים את ה-root bridge ב-STP?"

ת: לפי ה-Bridge ID הנמוך ביותר = Priority (ברירת מחדל 32768 ואז כתובת MAC. אם ה-priority זהה אצל כולם - מנצח ה-MAC). שימו לב: ב-STP נמוך מנצח, ב-OSPF (פרק רשתות) גבוה מנצח - הפוך!

ש: "מה זה VLAN hopping ואיך DTP קשור?"

ת: DTP הוא פרוטוקול שמנהל אוטומטית אם קישור יהיה trunk. תוקף יכול להתחזות למתג, "לשכנע" את הפורט להפוך ל-trunk, ואז לקבל גישה לכל ה-VLANים. הפתרון: לכבות DTP (switchport nonegotiate) ולהגדיר פורטי קצה כ-access מפורש.

ש: "מה זה rogue DHCP ולמה זה מסוכן?"

ת: תוקף מקים שרת DHCP משלו שעונה מהר יותר מהאמיתי, ומחלק לקורבנות default gateway ו-DNS ולש - וכך כל התעבורה שלהם עוברת דרכו. (MITM) ההגנה: DHCP snooping, שמסמן פורטים "מהימנים" וחוסם הצעות משרתים לא מורשים.

ש: "מה זה Evil Twin ואיך מתגוננים?"

ת: נקודת גישה זדונית עם (SSID) תשר שש ותוא כמו החוקית, בעוצמה חזקה יותר - מכשירים מתחברים אליה

אוטומטית והתוקף מבצע MITM. הגנה: WPA2/WPA3-Enterprise עם 802.1X (אימות הדדי - המכשיר מוודא שהשרת אמיתי) ו-WIPS.

ש: "מה ההבדל בין port security ל-802.1X?"

ת: port security מגביל MAC תובות וליא/המכ מותרות בפורט (הגנה מפני (802.1X MAC flooding) דורש רישכמ/שמתשמ תומיא מלא מול שרת RADIUS לפני שנותנים גישה. 802.1X חזק בהרבה אך דורש תשתית שרת.

מילון מונחים - הגדרות

הגדרות תמציתיות של המונחים המרכזיים בפרק. שימושי גם כדף עזר לבחינה.

מונח	הגדרה
שכבה 2 (Data Link)	שכבת הקישור; עובדת בכתובות MAC, מתגים ומסגרות. (frames)
מתג (Switch)	מכשיר שמחבר מכשירים ברשת מקומית ולומד כתובות MAC לכל פורט.
טבלת MAC (CAM)	טבלה במתג הממפה כתובת MAC לפורט; מוגבלת בגודלה.
MAC flooding / overflow	הצפת המתג בכתובות MAC מזויפות עד שהוא משדר לכולם (כמו hub).
Port Security	הגבלת מספר/זהות כתובות MAC בפורט; הגנה מפני MAC flooding.
violation (protect/restrict/shutdown)	תגובת port security להפרה: התעלמות, התראה, או כיבוי הפורט. (err-disabled)
VLAN	רשת לוגית מבודדת בתוך מתג פיזי; מעבר בין VLANים דורש ניתוב.
Trunk (802.1Q)	קישור הנושא כמה VLANים בין מתגים, עם תיוג של מספר ה-VLAN.
DTP	פרוטוקול שמנהל אוטומטית trunk; יש לכבותו כדי למנוע VLAN hopping.
VLAN hopping	קבלת גישה ל-VLANים אחרים בניצול DTP או תיוג כפול.
STP (Spanning Tree)	פרוטוקול שמונע לולאות בשכבה 2 על ידי חסימת פורטים.
Root Bridge	המתג המרכזי ב-STP; נבחר לפי Bridge ID הנמוך (priority), ואז (MAC).
BPDU Guard	מכבה פורט קצה שמקבל BPDU (חובר אליו מתג/תוקף).
DHCP starvation / spoofing	דלדול כתובות ה-DHCP, או הקמת שרת DHCP מזויף ל-MITM.
DHCP Snooping	סימון פורטים מהימנים וחסימת הצעות DHCP מפורטים לא מורשים.
ARP spoofing / poisoning	זיוף הודעות ARP כדי להפנות תעבורה לתוקף (MITM).
DAI (Dynamic ARP Inspection)	בדיקת הודעות ARP מול טבלת ה-DHCP snooping; חוסם זיופים.
Storm Control	הגבלת אחוז תעבורת broadcast/multicast בפורט; מונע סופות.
NAC	בקרת גישה שבודקת 'בריאות' מכשיר לפני מתן גישה (מבוסס 802.1X).
Evil Twin	נקודת גישה זדונית עם SSID זהה לחוקית, ל-MITM ברשת אלחוטית.

פרק 7 – מערכות הצפנה וקריפטולוגיה

11 שעות עיוני + 3 מעשי · שבועות 20-23

מטרות: קריפטולוגיה · הצפנה, קידוד, hashing · סימטרי מול א-סימטרי · חתימה דיגיטלית · PKI
בבגרות: Diffie-Hellman, צופן קיסר ו-26 mod, מפתח ציבורי/פרטי, AES מול hash (סודיות)

לפני שמתחילים – שלושה מושגים שמבלבלים (למי שאין רקע)

כל הפרק בנוי על הבחנה בין שלושה דברים שנראים דומים אבל שונים לגמרי: **קידוד** (Encoding) – שינוי הביתכה תרוע של מידע לנוחות, דוס ילב. כל אחד יכול להחזיר. דוגמה: מורס, Base64. **זו אינה אבטחה**.
הצפנה (Encryption) – ערבוב המידע בעזרת ידוס חתפמ, כך שרק מי שיש לו המפתח יכול לפענח. הפיך חתפמה מע. מטרה: **סודיות**. **גיבוב** (Hashing) – "טביעת אצבע" של המידע: פונקציה תינוויכ-דח שאי אפשר להפוך. מטרה: לבדוק שהמידע לא שונה (שלמות). **אנלוגיה:** קידוד = לכתוב מילה הפוך (כל אחד קורא). הצפנה = כספת עם מפתח (רק בעל המפתח פותח). גיבוב = לטחון פרי לשייק (אי אפשר להחזיר את הפרי, אבל אותו פרי תמיד נותן אותו שייק).
מושג מפתח: "מפתח" (Key) בהצפנה = מספר/מחרוזת סודית שקובעת איך המידע יעורבב. בלי המפתח הנכון, המידע המוצפן נראה כג'יבריש.

7.1 מושגי יסוד – ולמה קידוד אינו הצפנה

קריפטוגרפיה	מדע כתיבת ההצפנות (יצירת צפנים)
קריפטואנליזה	מדע שבירת ההצפנות
קריפטולוגיה	שם כולל לשתייהן
Plaintext	הטקסט הגלוי, לפני הצפנה
Ciphertext	הטקסט המוצפן
Cipher / אלגוריתם	שיטת ההצפנה (קיסר, AES)
Key (מפתח)	הסוד שמשנה את פעולת האלגוריתם

שלושה מושגים שמבלבלים – חשוב מאוד להבחין

קידוד (Encoding) – המרת ייצוג לנוחות/תאימות, דוס אלל. Base64, ASCII, Morse. כל אחד יכול לפענח – זו לא אבטחה!
הצפנה (Encryption) – המרה הכיפה בעזרת מפתח סודי; רק מי שיש לו המפתח מפענח. מטרה: **סודיות**.
גיבוב (Hashing) – פונקציה תינוויכ-דח, ללא מפתח, פלט קבוע-אורך. אי אפשר להפוך. מטרה: **שלמות**.

טעות נפוצה מסוכנת

תלמידים (ומתכנתים!) חושבים ש-Base64 היא "הצפנה". ("password" btoa) אינו מאבטח דבר. אם רואים "==" בסוף מחרוזת – זה כמעט תמיד Base64 (קידוד), ופענוח לוקח שנייה. השאלה המבחינה: "האם צריך סוד כדי לחזור?" קידוד – לא. הצפנה – כן.

עקרון קרקהופס (Kerckhoffs)

"מערכת צריכה להיות מאובטחת גם אם הכול ידוע חוץ מהמפתח." המשמעות: לא סומכים על סודיות האלגוריתם ("security through obscurity זה רע), אלא על סודיות המפתח בלבד. לכן AES פורסם לכל העולם – וזו דווקא הסיבה שסומכים עליו: מיליוני מומחים ניסו לשבור ולא הצליחו.

7.2 היסטוריה – מקיסר עד אניגמה

צופן קיסר (Caesar) – נשאל בבגרות

הזת כל אות במספר קבוע. יוליוס קיסר השתמש בהזזה של A → B, B → C, ... E → D (עבור אנגלית, 26 אותיות, A=0)

הצפנה: $C = (P + K) \bmod 26$ (פענוח: $K = C - P \bmod 26$)

דוגמה עם $K=10$: האות $C = (7+10) \bmod 26 = 17 = R \Rightarrow H (=7)$ האות $Z (=25) \Rightarrow C = (25+10) \bmod 26 = 9 = J$.
 האות J היא $35 \bmod 26 = 9$ חזרה להתחלה.

בבגרות (שאלה 5)

"בצופן קיסר $C = P + 10 \bmod 26$ מה תפקידו של $\bmod 26$?" - מספר האותיות (האפשרויות) בשפה האנגלית; ה- $\bmod$ מבטיח שהתוצאה תישאר בטווח 0-25 ו"תתגלגל" מ-Z חזרה ל-A. לא מספר הפעולות ולא גרסת האלגוריתם.

צפנים היסטוריים נוספים

חולשה	רעיון	סוג	צופן
26 מפתחות בלבד; ניתוח תדירות	הזזה קבועה	החלפה (substitution), חד-אלפביתי	Caesar / ROT13
ניתוח תדירות אותיות (E הכי נפוצה)	כל אות $\leftrightarrow$ אות אחרת (26! מפתחות)	החלפה	Monoalphabetic
נשבר (Kasiski) אך חזק בהרבה	קיסר עם מפתח מתחלף לפי מילה	החלפה רב-אלפביתית	reèVigen
סדר בלבד - ניתן לניתוח	שינוי סדר האותיות	שחלוף	Transposition (Rail Fence)
נשברה ע"י טיורינג בבלצ'לי פארק	מכונת רוטורים גרמנית (WWII)	רוטורי	Enigma
לא מעשי - מפתח באורך ההודעה, פעם אחת	המפתח היחיד שהוכח מתמטית כבלתי שביר	XOR עם מפתח אקראי באורך ההודעה	One-Time Pad

סיפור מהחיים: אלן טיורינג ואניגמה

בזמן מלחמת העולם השנייה הצי הגרמני הצפין הודעות במכונת Enigma - 158 מיליון מיליון הגדרות אפשריות. אלן טיורינג וצוותו בבלצ'לי פארק בנו מכונה חשמלית ("The Bombe שניצלה חולשה: אות לעולם לא מוצפנת לעצמה, ומילים צפויות ("Wetter=מזג אוויר) הופיעו כל בוקר. ההערכה: שבירת Enigma קיצרה את המלחמה בכשנתיים. הלקח לכיתה: אלגוריתם עם מרחב מפתחות ענק עדיין נשבר אם יש בו חולשה מבנית או שימוש לא נכון - בדיוק העיקרון של קרקוהופס.

7.3 מטרות האבטחה ואיזה כלי קריפטוגרפי נותן מה

מטרה	הכלי הקריפטוגרפי
סודיות (Confidentiality)	הצפנה - סימטרית (AES) או א-סימטרית (RSA)
שלמות (Integrity)	Hash (SHA-256)
אימות (Authentication) + שלמות עם מפתח משותף	HMAC
אימות + אי-הכחשה (Non-repudiation)	חתימה דיגיטלית (hash) מוצפן במפתח פרטי

בבגרות (שאלה 5)

"איזה אלגוריתם מבטיח סודיות של מידע מוצפן?" 1. MD5 2. WPA-2 3. AES 4. HASH - התשובה AES 3. MD5 ו-HASH נותנים שלמות (לא סודיות); WPA-2 הוא פרוטוקול אבטחת Wi-Fi, לא אלגוריתם הצפנה.

7.4 גיבוב (Hashing)

פונקציית גיבוב מקבלת קלט בכל אורך ומחזירה פלט קבוע (digest). תכונות נדרשות: **חד-כיווניות** (אי אפשר לשחזר קלט), **דטרמיניסטיות** (אותו קלט → אותו פלט), **אפקט מפולת** (שינוי ביט אחד → פלט שונה לגמרי), **עמידות להתנגשויות** (קשה למצוא שני קלטים עם אותו hash).

אלגוריתם	אורך פלט	מצב
MD5	128 ביט	שבור - התנגשויות ידועות. לא לאבטחה. (מוזכר בתכנית)
SHA-1	160 ביט	שבור . ("SHATTERED", 2017). לא לשימוש. (מוזכר בתכנית)
SHA-2 (SHA-256/512)	256/512 ביט	הסטנדרט הנוכחי
SHA-3	משתנה	חלופה מודרנית

שימושים

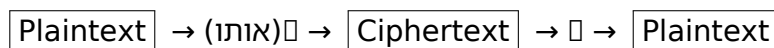
- **שלמות קבצים** - מורידים ISO ומשווים SHA-256 לזה שבאתר; אם שונה - הקובץ שונה/פגום.
- **אחסון סיסמאות** - שומרים hash, לא את הסיסמה. בכניסה מגבבים ומשווים. חובה salt (מלח - ערך אקראי לכל סיסמה) נגד rainbow tables, ופונקציה איטית (bcrypt/Argon2/PBKDF2) נגד brute force.
- בסיס ל-HMAC ולחתימה דיגיטלית.

שאלת תלמיד: "אם hash חד-כיווני, איך אתרים 'שוברים' MD5?"

הם לא "הופכים" אותו - הם מנחשים. מחשבים מראש hash של מיליארדי סיסמאות נפוצות (rainbow table) ומחפשים התאמה. לכן: salt (1) - הופך כל טבלה מוכנה ללא רלוונטית; (2) פונקציה איטית - אם כל ניחוש לוקח 0.5 שניות, מיליארד ניחושים = 15 שנה. MD5 מהיר מדי בדיוק בגלל זה.

7.5 הצפנה סימטרית

מפתח אחד משמש גם להצפנה וגם לפענוח, ומשותף לשני הצדדים.



אלגוריתם	אורך מפתח	הערכה
DES	56 ביט	שבור (מפתח קצר מדי, נפרץ ב-1998)
3DES	112/168 ביט	מיושן אך נסבל; DES שלוש פעמים
AES	128/192/256	הסטנדרט העולמי (Rijndael, 2001). מאובטח, בחומרה.
RC4	משתנה (זרם)	שבור - היה ב-WEP/SSL
SEAL, Blowfish		מוזכרים בתכנית; פחות בשימוש היום

שני סוגים: AES block cipher - מצפין בלוקים של 128 ביט; מצבי פעולה (CBC, GCM, stream cipher ו-RC4) - ביט אחר ביט.

יתרונות סימטרי	חסרונות סימטרי
מהיר מאוד (פי 1000 מא-סימטרי); מתאים לכמויות מידע גדולות; מפתחות קצרים יחסית	בעיית חלוקת המפתח - איך מעבירים את המפתח בבטחה? בעיית מדרגיות - ל-N משתמשים צריך $N(N-1)/2$ (מפתחות 100 איש = 4,950 מפתחות)

7.6 הצפנה א-סימטרית (מפתח ציבורי)

לכל צד **זוג מפתחות** מתמטית קשורים: **ציבורי** (מפרסמים לכולם) ו**פרטי** (סוד מוחלט). מה שאחד מצפין - רק השני מפענח. זה פותר את בעיית חלוקת המפתח.

שני שימושים הפוכים - חובה להבין

לסודיות: מצפינים בנעמנה לש ירוביץ $\Rightarrow$ רק הנמען (בעל הפרטי) יפענח. (בבגרות 14 + 15)
לחתימה/אימות: מצפינים בחלושה לש יטרפ $\Rightarrow$ כל אחד מפענח בציבורי שלו, ובכך מוכיח שהשולח אכן שלח (רק לו יש את הפרטי).

בבגרות (שאלה 15)

"האלגוריתם הא-סימטרי משתמש במפתח הציבורי להצפנה - איזה מפתח לפענוח?" - 1. **מפתח פרטי**.

אלגוריתם	שימוש
RSA	הצפנה + חתימה; הנפוץ ביותר. בנתב סיסקו: מפתחות RSA ל-SSH (פרק 2!)
Diffie-Hellman (DH)	החלפת מפתחות - מסכימים על מפתח סודי משותף בערוץ ציבורי, בלי לשלוח אותו
DSA	חתימה דיגיטלית בלבד (מוזכר בתכנית)
ECC	עקומים אליפטיים - אבטחה זהה במפתח קצר בהרבה (מודרני)

Diffie-Hellman במשל הצבעים (הכי טוב לכיתה)

אליס ובוב רוצים סוד משותף מול מאזין. 1. מסכימים בפומבי על צבע בסיס (צהוב). 2. כל אחד בוחר צבע סודי ומערבב עם הצהוב. 3. מחליפים את התערובות **בפומבי** (המאזין רואה אותן). 4. כל אחד מוסיף את הסוד שלו לתערובת שקיבל. שניהם מגיעים לאותו צבע סופי - **אבל המאזין לא יכול**, כי הפרדת צבעים היא "בלתי הפיכה" (כמו לוגריתם דיסקרטי במתמטיקה). זה בדיוק DH.

בבגרות (שאלה 14)

"איזה אלגוריתם מאפשר לצדדים להסכים על מפתח פרטי על גבי ערוץ ציבורי?" - 2. Diffie-Hellman.
(NOBLE, Dijkstra, Caesar) - מסיחים; הוא אלגוריתם מסלולים, לא הצפנה.

7.7 הצפנה היברידית - איך זה באמת עובד (TLS/HTTPS)

המערכות האמיתיות משלבות: א-סימטרי לפתיחה, סימטרי לתעבורה - "טוב משני העולמות".

HTTPS - מה קורה כשנכנסים לאתר בנק

1. הדפדפן והשרת מבצעים DH (או שהדפדפן מצפין מפתח ב-RSA הציבורי של השרת) כדי להסכים על **מפתח סימטרי** (session key). 2. השרת מציג **תעודה** חתומה על ידי CA שמוכיחה שהוא באמת הבנק. 3. (7.9) מכאן כל התעבורה מוצפנת ב-AES (מהיר) עם ה-session key הא-סימטרי שימש רק לשנייה הראשונה. זו הסיבה שרואים □.

HMAC 7.8 וחתימה דיגיטלית

HMAC (Hash-based Message Authentication Code)

hash לבדו נותן שלמות, אבל תוקף MITM יכול לשנות גם את ההודעה וגם את ה-hash = HMAC hash (ההודעה + מפתח סודי משותף). עכשיו רק מי שיש לו המפתח יכול לחשב HMAC תקין $\Rightarrow$ **שלמות + אימות** **מקור**. משמש ב-IPsec (פרק 8), ב-API, ו-JWT.

חתימה דיגיטלית

התהליך

חתימה (השולח): 1. מחשב hash של המסמך. 2. מצפין את ה-hash בולש יטרפה חתפמ = החתימה. שולח מסמך + חתימה.
אימות (המקבל): 1. מפענח את החתימה בחלושה לש ירוביצה חתפמ $\Rightarrow$ מקבל את ה-hash המקורי. 2. מחשב hash של המסמך שקיבל. 3. משווה. תואם $\Rightarrow$ המסמך לא שונה (שלמות) **וגם** נשלח באמת על ידו (אימות + אי-הכחשה - רק לו יש את הפרטי).

למה מצפינים את ה-hash ולא את כל המסמך? כי א-סימטרי איטי; ה-hash קטן וקבוע.

7.9 PKI ותעודות דיגיטליות

בעיית DH ו-RSA: איך אני יודע שהמפתח הציבורי "של הבנק" באמת שייך לבנק ולא לתוקף MITM? הפתרון: PKI (Public Key Infrastructure) - מערכת של גורמים מהימנים שמאשרים "מפתח ציבורי X שייך לישות Y".

מסמך שקושר זהות למפתח ציבורי, חתום דיגיטלית על ידי CA . תקן: X.509.	תעודה דיגיטלית (Certificate)
הגורם המהימן שמנפיק וחותם תעודות (DigiCert, Let's Encrypt).	CA (Certificate Authority)
מאמת את זהות המבקש לפני הנפקה.	RA (Registration Authority)
רשימת/בדיקת תעודות שבוטלו (למשל אם מפתח פרטי נגנב).	CRL / OCSP
ה-CA העליון; התעודה שלו מובנית במערכת ההפעלה/דפדפן ("trust anchor").	Root CA

שרשרת אמון (Chain of Trust) - היררכיה

Root CA (סומכים עליו מראש) $\rightarrow$ חותם על $\rightarrow$ Intermediate CA $\rightarrow$ חותם על $\rightarrow$ תעודת השרת (bank.com). הדפדפן בודק את השרשרת עד ל-root שהוא מכיר. אם חוליה חסרה או פגה - אזהרה. זו ה"היררכיית סטנדרטים ואישורי סטנדרטים" שבתכנית.

סיפור מהחיים: DigiNotar - כש-CA נפרץ (2011)

תוקף פרץ ל-CA ההולנדי DigiNotar והנפיק לעצמו תעודה מזויפת ל-google.com. עם התעודה הזו, המודיעין האיראני (ככל הנראה) ביצע MITM על Gmail של 300,000 אזרחים איראנים - הדפדפן שלהם הציג ירוק ולא חשד בכלום, כי התעודה הייתה "חתומה כדין". כשהתגלה, הדפדפנים הסירו את DigiNotar מרשימת ה-root המהימנים, והחברה פשטה רגל תוך חודש. הלקח: כל מודל האמון של האינטרנט נשען על כך שה-CA-ים ישרים ומאובטחים - חוליה אחת שבורה מפילה הכול.

7.10 חוזק מפתחות ומדיניות NSA/NIST

- **מפתח ארוך = מרחב חיפוש גדול יותר.** סימטרי 128 ביט 2^{128} אפשרויות - מעבר להישג יד גם למחשבי-על. אבל אורך מפתח א-סימטרי אינו בר-השוואה ישירה: $AES\ 112 \approx RSA\ 2048$ בערך.
- המלצות AES-128 (NIST SP 800) ומעלה, RSA-2048 ומעלה (רצוי SHA-256, 3072 ומעלה, ECC-256).
- Suite B של ה-NSA (מוזכר "חוקי SHA-2, ECDH, ECDSA, AES": NSA) - לתקשורת ממשלתית.
- **ניהול מפתחות** (הנושא "ניהול מפתחות ע"י שינוי אחסון וריפיקציה"): יצירה, אחסון מאובטח (HSM), החלפה תקופתית (rotation), ביטול, גיבוי. מפתח שנחשף = כל מה שהוצפן בו חשוף.
- איום עתידי: **מחשוב קוונטי** יאיים על RSA/DH $\Rightarrow$ קריפטוגרפיה פוסט-קוונטית (NIST בחר אלגוריתמים ב-2024).

7.11 תרגילים לתלמידים

תרגיל 1 - צופן קיסר

עם $K=3$: הצפינו את המילה NET. עם $K=5$: פענחו את MJQQT. $(A=0, Z=25) \dots$
 $K=5$: $M(12)-5=H$, $J(9)-5=E$, עם MJQQT. $QHW = W \rightarrow H$, $T(19) \rightarrow Q$, $E(4) \rightarrow NET$: $N(13)$
 $HELLO = L$, $T(19)-5=O \rightarrow Q(16)-5=L$, Q

תרגיל 2 - איזה כלי לאיזו מטרה

לכל דרישה בחרו: hash / הצפנה סימטרית / א-סימטרית / HMAC / חתימה דיגיטלית.
א. לוודא שקובץ שהורד לא שונה. ב. להצפין 10GB גיבוי במהירות. ג. לשלוח מפתח סודי דרך האינטרנט
בבטחה. ד. לוודא שעדכון תוכנה הגיע באמת מהיצרן. ה. לאחסן סיסמאות במסד נתונים.
א. hash. ב. סימטרית (AES). ג. א-סימטרית / DH. ד. חתימה דיגיטלית. ה. hash + salt (פונקציה איטית)

תרגיל 3 - ציבורי או פרטי?

דנה רוצה לשלוח ליוסי הודעה סודית, ולחתום עליה. איזה מפתח היא משתמשת בכל שלב?
א. להצפין את ההודעה כך שרק יוסי יקרא. ב. לחתום כדי שיוסי ידע שזה ממנה. ואצל יוסי: ג. לפענח את
ההודעה. ד. לאמת את החתימה.
א. הציבורי של יוסי. ב. הפרטי של דנה. ג. הפרטי של יוסי. ד. הציבורי של דנה

תרגיל 4 - קידוד/הצפנה/גיבוב

סווגו כל אחד: א. btoa ל-Base64. ב. SHA-256. ג. AES-256-CBC. ד. Morse. ה. bcrypt.
א. קידוד. ב. גיבוב. ג. הצפנה. ד. קידוד. ה. גיבוב (איטי, לסיסמאות)

תרגיל 5 - דיון: התנגשות

הסבירו במילים שלכם מדוע "עמידות להתנגשויות" חשובה לחתימה דיגיטלית. מה תוקף יכול לעשות אם
הוא מוצא שני מסמכים עם אותו hash?
בחתימה חותמים על ה-hash. אם התוקף מוצא מסמך זדוני עם אותו hash כמו מסמך תמים שנחתם -
החתימה "תקפה" גם על הזדוני, והוא יכול להחליף אותם. בדיוק בגלל זה MD5 ו-SHA-1 פסולים לחתימה.

7.12 שאלות בסגנון בגרות

שאלה 1

איזה אלגוריתם מבטיח סודיות של מידע מוצפן? MD5 / WPA-2 / AES / HASH
AES. השאר: MD5/HASH - שלמות; WPA-2 - פרטוקול.

שאלה 2

בצופן $C=(P+K) \bmod 26$, מה תפקיד ה-26 mod?
מספר האותיות בשפה; "מגלגל" את התוצאה חזרה לטווח 0-25.

שאלה 3

כאשר האלגוריתם הא-סימטרי מצפין במפתח ציבורי - באיזה מפתח מפענחים?
במפתח הפרטי (של הנמען).

שאלה 4

איזה אלגוריתם מאפשר לשני צדדים להסכים על מפתח סודי משותף מעל ערוץ ציבורי?

Diffie-Hellman.

שאלה 5

מהו ההבדל העיקרי בין הצפנה סימטרית לא-סימטרית מבחינת מפתחות, ומהו החיסרון המרכזי של כל אחת? סימטרית – מפתח אחד משותף; חיסרון: חלוקת המפתח ומדרגיות. א-סימטרית – זוג מפתחות (ציבורי/פרטי); חיסרון: איטיות מאוד.

שאלה 6

מדוע נדרשת PKI, ומה תפקיד ה-CA?

כדי לוודא שמפתח ציבורי אכן שייך לישות שהוא טוען (נגד. MITM-ה-CA הוא גורם מהימן שמנפיק וחותם תעודות שמקשרות זהות למפתח ציבורי).

7.13 מעבדה (3 שעות)

1. **קיסר:** באתר cryptii.com הצפינו ופענחנו; בדקו כמה מהר brute force על 25 מפתחות שובר אותו.
2. Hash: באתר (או sha256sum | "password" -n echo) חשבו SHA-256 של "hello" ושל "Hello" – ראו את אפקט המפולת. שנו ביט אחד וראו פלט שונה לגמרי.
3. **שלמות:** הורידו קובץ, שנו בו תו אחד, חשבו hash לפני ואחרי – הראו שהשתנה.
4. **סיסמאות:** הראו rainbow table אונליין ששובר MD5 של "123456", ואיך salt מסכל אותו.
5. **תעודות:** בדפדפן, לחצו על של אתר בנק, הציגו את התעודה, את ה-CA ואת שרשרת האמון ותוקף התעודה.
6. RSA ל-Ssh (קישור לפרק 2): ב-Packet Tracer צרו מפתחות RSA בנתב והתחברו ב-Ssh – הדגישו שאלה בדיוק הא-סימטרי בפעולה.

בנק שאלות שתלמידים שואלים – ותשובות מוכנות

שאלות נפוצות בפרק ההצפנה, עם תשובות מוכנות.

ש: "אם גיבוב הוא חד-כיווני, איך אתרים 'שוברים' סיסמאות MD5?"

ת: הם לא הופכים את הגיבוב – הם פישחנמ. מחשבים מראש את הגיבוב של מיליארדי סיסמאות נפוצות (טבלת rainbow) ומחפשים התאמה. לכן: מוסיפים salt (ערך אקראי לכל סיסמה) שהופך טבלה מוכנה לחסרת ערך, ומשתמשים בפונקציה תיטיא (bcrypt) שהופכת ניחוש המוני לבלתי מעשי.

ש: "אז Base64 זו הצפנה?"

ת: לא! Base64 הוא קידוד – שינוי צורת כתיבה בלי סוד. כל אחד מפענח אותו בשנייה (רמז: מחרוזת שמסתיימת ב-'='). קידוד ≠ הצפנה. השאלה המבחינה: "האם צריך מפתח סודי כדי לחזר?".

ש: "אם אני מצפין הכול ב-AES, אני מוגן לגמרי?"

ת: הצפנה נותנת תוידוס בלבד. היא לא מונעת מחיקה של הקובץ (זמינות – כופרה דווקא משתמשת בהצפנה נגדכם!) ולא בהכרח מוודאת שהמידע לא שונה (שלמות – לזה צריך גיבוב). HMAC צריך את שלושתם.

ש: "מה ההבדל בין סימטרי לא-סימטרי, ומתי משתמשים בכל אחד?"

ת: **סימטרי (AES)** = מפתח אחד משותף, מהיר מאוד – טוב לכמויות מידע גדולות, אבל יש בעיה: איך מעבירים את המפתח בבטחה? **א-סימטרי (RSA/DH)** = זוג מפתחות ציבורי/פרטי, פותר את בעיית העברת המפתח, אבל איטי. בפועל סיבילשם: א-סימטרי כדי להסכים על מפתח, ואז סימטרי לתעבורה (כך עובד HTTPS).

ש: "אם המפתח הציבורי גלוי לכולם, איך זה מאובטח?"

ת: כי מה שמוצפן במפתח הציבורי ניתן לפענוח קר במפתח הפרטי התואם, שנשאר סודי אצל הבעלים. גם אם כל העולם מכיר את המפתח הציבורי שלכם – רק אתם יכולים לפענח את מה ששלחו אליכם.

ש: "איך Diffie-Hellman מסכים על מפתח סודי אם המאזין רואה הכול?"

ת: משל הצבעים: כל צד מערבב צבע סודי עם צבע בסיס משותף, מחליפים את התערובות בפומבי, וכל אחד

מוסיף שוב את הסוד שלו. שניהם מגיעים לאותו צבע - אבל המאזין לא יכול, כי "הפרדת צבעים" (לוגריתם דיסקרטי) היא בלתי הפיכה מעשית. DH לא מעביר את המפתח - הוא רציימ אותו בשני הצדדים.

ש: "אם RSA כל כך טוב, למה בכלל צריך תעודות ו-PKI?"

ת: כי RSA לבדו לא אומר ימל שייך המפתח הציבורי. תוקף MITM יכול לתת לכם את המפתח שלו ולטעון שהוא הבנק. תעודה חתומה על ידי CA מהימן מוכיחה "המפתח הזה באמת שייך לבנק". זה מה שקורה כשרואים □ בדפדפן.

ש: "מה ההבדל בין חתימה דיגיטלית להצפנה?"

ת: הצפנה מסתירה תוכן (סודיות), ומשתמשת בןעמנה לש ירוביצה חתפמ. חתימה מוכיחה מי שלח ושהמסמך לא שונה (אימות+שלמות), ומשתמשת בחלושה לש יטרפה חתפמ. שני שימושים הפוכים של אותו זוג מפתחות.

ש: "האם מחשב קוונטי ישבור את כל ההצפנות?"

ת: הוא מאיים בעיקר על התוירטמיס-א (RSA/DH), פחות על סימטריות (AES-256) (נחשב עמיד). לכן NIST כבר בחר (2024) אלגוריתמים "פוסט-קוונטיים". זה איום עתידי שמתכוננים אליו כבר היום.

מילון מונחים - הגדרות

הגדרות תמציתיות של המונחים המרכזיים בפרק. שימושי גם כדף עזר לבחינה.

מונח	הגדרה
קריפטוגרפיה	מדע יצירת ההצפנות.
קריפטואנליזה	מדע שבירת ההצפנות.
Plaintext / Ciphertext	הטקסט הגלוי (לפני) והטקסט המוצפן (אחרי).
מפתח (Key)	סוד שקובע את פעולת ההצפנה; בלעדיו הטקסט המוצפן חסר משמעות.
קידוד (Encoding)	המרת ייצוג ללא סוד (Base64), מורס) - אינו אבטחה.
הצפנה (Encryption)	המרה הפיכה בעזרת מפתח סודי; מטרה: סודיות.
גיבוב (Hashing)	פונקציה חד-כיוונית שמפיקה טביעת אצבע קבועה; מטרה: שלמות.
Salt	ערך אקראי המתווסף לסיסמה לפני גיבוב, נגד טבלאות rainbow.
MD5 / SHA-1	אלגוריתמי גיבוב ישנים ושבירים - לא לשימוש אבטחתי.
SHA-256	אלגוריתם הגיבוב הסטנדרטי כיום.
צופן קיסר (Caesar)	צופן החלפה שמזיז כל אות במספר קבוע: $C = (P + K) \bmod 26$.
הצפנה סימטרית	מפתח אחד משותף להצפנה ולפענוח; מהיר (AES, 3DES, DES).
הצפנה א-סימטרית	זוג מפתחות ציבורי/פרטי; פותר העברת מפתח; איטי (RSA).
AES	תקן ההצפנה הסימטרי המוביל כיום (128/192/256 ביט).
RSA	אלגוריתם א-סימטרי נפוץ להצפנה ולחתימה; משמש גם ל-SSH.
Diffie-Hellman (DH)	שיטה להסכמה על מפתח סודי משותף מעל ערוץ ציבורי.
מפתח ציבורי / פרטי	זוג מפתחות; מה שמוצפן באחד מפוענח רק בשני.
HMAC	גיבוב עם מפתח סודי משותף; נותן שלמות ואימות מקור.
חתימה דיגיטלית	גיבוב המסמך המוצפן במפתח הפרטי של השולח; אימות + אי-הכחשה.
PKI	תשתית מפתח ציבורי - מערכת גורמים מהימנים המנפיקים תעודות.
תעודה דיגיטלית (X.509)	מסמך חתום ע"י CA הקושר זהות למפתח ציבורי.

מונח	הגדרה
CA (Certificate Authority)	גורם מהימן המנפיק וחותם תעודות.
שרשרת אמון (Chain of Trust)	היררכיה: Root CA → Intermediate → תעודת שרת.

מטרות: מערכות VPN · הגדרת VPN · IPsec · הגדרת ב-Cli · GRE · SSL VPN
בבגרות: IPsec מאבטח את חבילת TCP/IP (שכבה 3)

לפני שמתחילים – מה זו "מנהרה מוצפנת"? (למי שאין רקע)

הבעיה: כשמידע עובר באינטרנט, הוא עובר דרך נתבים רבים של חברות שונות. כל אחד בדרך יכול, עקרונית, לראות אותו. זה מסוכן למידע רגיש. VPN = "Virtual Private Network" רשת פרטית וירטואלית". הוא יוצר **מנהרה מוצפנת** דרך האינטרנט הציבורי: המידע מוצפן בצד אחד, עובר את האינטרנט כג'יבריש, ומפוענח רק בצד השני. **אנלוגיה:** במקום לשלוח גלויה שכל דוור קורא (אינטרנט רגיל), שולחים מזוודה נעולה שרק לשולח ולנמען יש מפתח אליה. (VPN) **שני שימושים:** חיבור פניסל (Site-to-Site), כמו לחבר שני משרדים), וחיבור **תיבה** דבוע. (Remote Access) **חשוב:** פרק זה מסתמך ישירות על פרק 7 (הצפנה). כל מה שנלמד שם – מפתח סימטרי, מפתח ציבורי/פרטי, גיבוב – חוזר כאן בפעולה. אם משהו לא ברור, חזרו לפרק 7.

8.1 מהו VPN ולמה הוא נחוץ

VPN (Virtual Private Network) יוצר "מנהרה" מוצפנת דרך רשת ציבורית (האינטרנט), כך שנתונים עוברים כאילו הם על קו פרטי. במקום לשכור קו תקשורת יקר בין סניפים (leased line), משתמשים באינטרנט הזול – והצפנה מספקת את הפרטיות. VPN מספק את שלוש מטרות ה-CIA לתעבורה: **סודיות** (הצפנה), **שלמות** (HMAC), **אימות** (מי הצד השני), ולעיתים anti-replay (מניעת שידור חוזר של חבילה שנלכדה).

סיפור מהחיים: בית הקפה והמנהל שעבד מרחוק

מנהל מכירות יושב בבית קפה, מתחבר ל-Wi-Fi הפתוח, ופותח את מערכת ה-CRM של החברה. בלי VPN, כל מי שיושב בבית הקפה עם Wireshark (או Evil Twin – פרק 6) רואה את הכול. עם VPN: המחשב פותח מנהרת IPsec/SSL מוצפנת אל שער החברה עוד לפני שנשלח ביט אחד של CRM. המאזין רואה רק "תעבורה מוצפנת ל-VPN gateway" – ג'יבריש. זה בדיוק מה שלמדנו בפרק 7 (AES+HMAC+DH), עכשיו ארוז כשירות רשת.

8.2 סוגי VPN

סוג	מי מתחבר למי	דוגמה
Site-to-Site	שער (נתב)/ASA לשער – מחבר שתי רשתות שלמות. שקוף למשתמשים	סניף תל אביב ↔ סניף חיפה
Remote Access	משתמש יחיד (לקוח) ↔ שער החברה	עובד מהבית ↔ המשרד (Cisco AnyConnect)

לפי מי מפעיל	
Enterprise VPN	הארגון מנהל (IPsec, SSL) – מה שנלמד כאן
Service Provider VPN	ספק התקשורת מספק – Metro Ethernet, MPLS (מוזכר בתכנית: MPLS, GRE)

הבהרה חשובה

"VPN מסחרי" (NordVPN וכו') נועד להסתרת זהות/מיקום – שימוש שונה מ-VPN ארגוני שמחבר משתמש/סניף לרשת החברה בבטחה. בקורס מדובר ב-VPN ארגוני.

GRE 8.3 – מנהור בסיסי (בלי הצפנה!)

GRE (Generic Routing Encapsulation) הוא פרוטוקול מנהור של סיסקו שעוטף חבילה בתוך חבילת IP חדשה. יתרון: יכול לשאת multicast ו-broadcast (ולכן פרוטוקולי ניתוב כמו OSPF/EIGRP רצים דרכו) וגם תעבורה שאינה IP. חיסרון קריטי: GRE אינו מצפין כלום – הוא רק עוטף. לכן בפועל: GRE – GRE over IPsec. נותן את הגמישות (multicast, routing), IPsec, נותן את ההצפנה.

```
! מנהרת GRE בין R1 ל-R2
R1(config)# interface tunnel 0
R1(config-if)# ip address 172.16.1.1 255.255.255.252 ! כתובת פנימית של המנהרה
R1(config-if)# tunnel source 200.1.1.1 ! ה-IP הציבורי המקומי
R1(config-if)# tunnel destination 200.2.2.2 ! ה-IP הציבורי המרוחק
R1(config-if)# tunnel mode gre ip ! ברירת מחדל
! עכשיו מנתבים דרך המנהרה
R1(config)# ip route 10.2.2.0 255.255.255.0 172.16.1.2
R1# show ip interface brief | include Tunnel
R1# show interfaces tunnel 0
```

IPsec 8.4 – לב הפרק

IPsec אינו פרוטוקול יחיד אלא מסגרת (framework) של פרוטוקולים שמאבטחת תעבורה בשכבה 3 (IP). זו התשובה בבגרות: "IPsec נועד לאבטח את חבילת הפרוטוקולים TCP/IP כיוון שהוא בשכבה 3, הוא מאבטח כל תעבורה מעליו (TCP, UDP), כל אפליקציה (בשקיפות – בניגוד ל-SSL/TLS שבשכבה גבוהה יותר).

בבגרות (שאלה 6א)

"איזה סוג תקשורת נועדה חבילת הפרוטוקולים IPSEC לאבטח?" – TCP/IP. 2. (שכבה 3). לא SSH, לא Telnet, לא UDP ספציפית.

שני פרוטוקולי ההגנה

	AH (Authentication Header)	ESP (Encapsulating Security Payload)
פרוטוקול IP	51	50
שלמות + אימות	כן (כולל הכותרת החיצונית)	כן (המטען)
סודיות (הצפנה)	לא!	כן
עובד עם NAT	לא (מגן על הכותרת)	כן (עם NAT-T)
שימוש	כמעט לא בשימוש (אין הצפנה)	הבחירה כמעט תמיד

שני מצבי פעולה

- Transport mode – מצפין רק את המטען (payload); הכותרת המקורית נשמרת. בין שני מארחים.
- Tunnel mode – מצפין את כל החבילה המקורית ועוטף בכותרת IP חדשה. בין שערם (site-to-site). הנפוץ.

ארבעת מרכיבי ה-IPsec (מה שהמנהל צריך לבחור)

תפקיד	אפשרויות
הצפנה (סודיות)	AES / DES / 3DES
שלמות (hash)	(HMAC) SHA / MD5
אימות הצדדים	PSK (מפתח משותף מראש) / (תעודות PKI) RSA – פרק 7
החלפת מפתחות	DH (Diffie-Hellman) – קבוצות 1,2,5,14...

שימו לב: כל מה שלמדנו בפרק 7 חוזר כאן - AES לסודיות, SHA-HMAC לשלמות, DH להחלפת מפתחות, RSA/PKI לאימות. IPsec הוא "פרק 7 בפעולה".

IKE 8.5 - ניהול המפתחות והמנהרה

IKE ("Internet Key Exchange") מפתחות אינטרנט משתנים" בתכנית) הוא הפרוטוקול שמקים את מנהרת IPsec: מבצע DH, מאמת את הצדדים, ומסכים על הפרמטרים. פועל בשני שלבים:

IKE Phase 1 - בונים ערוץ ניהול מאובטח (ISAKMP SA)

הצדדים מסכימים על מדיניות (הצפנה/DH/hash/אימות), מבצעים DH, ומאמתים זה את זה (PSK או תעודות). התוצאה: ערוץ מוצפן דו-כיווני אחד שבו ינוהל שלב 2. מצבים: 6 Main mode (הודעות, בטוח) או 3 Aggressive mode, מהיר).

IKE Phase 2 - בונים את מנהרת הנתונים (IPsec SA)

בתוך הערוץ המאובטח משלב 1, מסכימים על ה- transform set (ESP-AES-SHA) ומקימים שני SA חד-כיווניים (אחד לכל כיוון) שדרכם תעבור התעבורה בפועל. מצב: Quick mode.

SA (Security Association) - "הסכם" חד-כיווני שמגדיר איך לאבטח זרם תעבורה מסוים, עם מזהה SPI. Phase 2 מייצר PFS (Perfect Forward Secrecy) אם מפעילים DH מחדש - כך שדליפת מפתח אחד לא חושפת תעבורה עבר.

8.6 הגדרת Site-to-Site IPsec VPN (ב-5 CLI שלבים)

```
===== שלב "ACL 0:מעניין" - איזו תעבורה להצפין =====
R1(config)# access-list 100 permit ip 10.1.1.0 0.0.0.255 10.2.2.0 0.0.0.255

===== שלב 1: מדיניות (ISAKMP) =====
R1(config)# crypto isakmp policy 10
R1(config-isakmp)# encryption aes 256
R1(config-isakmp)# hash sha
R1(config-isakmp)# authentication pre-share
R1(config-isakmp)# group 14 DH group 14 (2048-bit) !
R1(config-isakmp)# lifetime 3600
R1(config-isakmp)# exit
! מפתח משותף מראש + כתובת השכן
R1(config)# crypto isakmp key S3cr3tPSK address 200.2.2.2

===== שלב 2: transform set - הגנת Phase 2 =====
R1(config)# crypto ipsec transform-set TSET esp-aes 256 esp-sha-hmac
R1(cfg-crypto-trans)# mode tunnel
R1(cfg-crypto-trans)# exit

===== שלב 3: crypto map - מקשר הכול =====
R1(config)# crypto map CMAP 10 ipsec-isakmp
R1(config-crypto-map)# set peer 200.2.2.2
R1(config-crypto-map)# set transform-set TSET
R1(config-crypto-map)# match address 100 ! ה-ACL המעניין
R1(config-crypto-map)# set pfs group14
R1(config-crypto-map)# exit

===== שלב 4: החלה על הממשק החיצוני =====
R1(config)# interface g0/0
```

```
R1(config-if)# crypto map CMAP
```

PSK) (R2 ! מוגדר במראה: כתובות ו-ACL הפוכים, אותה מדיניות ואותו

טעויות נפוצות ב-IPsec

- מדיניות Phase 1 לא תואמת בין הצדדים (encryption/hash/group/auth שונים) ⇒ המנהרה לא קמה.
- **שני הצדדים חייבים להסכים.**
- PSK שונה משני הצדדים.
- ה-"ACL המעניין" לא מראה (R1: 10.1 → R2: 10.2; R2: 10.2 → R1: 10.1) אם לא הפוך – תעבורה לא נכנסת למנהרה.
- שכחו crypto map על הממשק – הכול מוגדר אבל כלום לא קורה.
- יש NAT שמתרגם את התעבורה המעניינת לפני ההצפנה ⇒ ה-ACL לא תואם. פתרון: NAT exemption (ACL עם deny לתעבורת ה-VPN).
- המנהרה קמה רק כשיש "תעבורה מעניינת" – ping אחד לא מספיק לפעמים; שלחו כמה.

ורפיקציה ופתרון תקלות

```
R1# show crypto isakmp sa      הצליח = QM_IDLE מצב Phase 1 !
R1# show crypto ipsec sa      ספירת חבילות encrypted/decrypted Phase 2 !
R1# show crypto map
R1# show crypto session
R1# debug crypto isakmp
R1# debug crypto ipsec
```

שאלת תלמיד: "איך אני יודע שהמנהרה עובדת ולא סתם ה-ping עובר רגיל?"

ב-`show crypto ipsec sa` תראו את המונים `#pkts encrypt` ו-`#pkts decrypt` עולים כשאתם שולחים תעבורה בין הרשתות. אם הם עולים – התעבורה עוברת במנהרה מוצפנת. אם ה-ping עובר אבל המונים 0 – התעבורה עוברת מחוץ למנהרה (בעיה ב-ACL המעניין או ב-NAT). זה הכלי הכי חשוב לדיבוג.

8.7 SSL/TLS VPN

	IPsec VPN	SSL VPN
שכבה	3 (רשת)	4-7 (מעל TCP 443)
לקוח	צריך תוכנת לקוח מותקנת ומוגדרת	Clientless – רק דפדפן (או לקוח קל AnyConnect)
מעבר חומות אש/NAT	לעיתים חסום (פרוטוקולים 50/51, UDP 500)	עובר בקלות – זה "רק" HTTPS על 443
גישה	גישת רשת מלאה	אפליקציות web ספציפיות (portal) או מלא (tunnel)
מתאים ל	site-to-site, גישה קבועה	גישה מרחוק ממחשב לא מנוהל, ספקים, ניידים

SSL VPN משתמש באותו TLS מפרק 7 (תעודות, AES, DH) זו הסיבה שהוא "פשוט עובד" מכל מקום – חומות אש כמעט תמיד מאפשרות 443.

8.8 ציוד וארכיטקטורה

- Cisco ASA 5500 – מכשיר האבטחה המרכזי: חומת אש (IPsec + VPN) ו-IPS. SSL יורשו: Firepower.
- Cisco PIX 500 – חומת האש/VPN ההיסטורית (הוחלפה ב-ASA); מוזכרת בתכנית.
- Cisco VPN 3000 Concentrator – ריכוז VPN מרחוק (הופסק); מוזכר בתכנית.
- SOHO – נתב קטן עם VPN מובנה לעסק/בית.

- האצת חומרה (בתכנית): VAC+, SPA, AIM – מודולי הצפנה שמורידים עומס מה-CPU היום מובנה במעבד.
- Cisco AnyConnect – לקוח ה-VPN המודרני (IPsec/SSL) למחשב ולנייד.

8.9 מדרוך פקודות מרוכז – פרק 8

שלב	פקודה
GRE	tunnel + interface tunnel 0 source/destination
IKE Phase 1	crypto isakmp policy N (encryption/hash/authentication/group)
PSK	crypto isakmp key K address PEER
הגנת Phase 2	crypto ipsec transform-set NAME esp-aes esp-sha-hmac
תעבורה מעניינת	access-list 100 permit ip SRC DST
קישור	(set crypto map NAME N ipsec-isakmp peer / transform-set / match address)
החלה	crypto map NAME (על ממשק)
ורפיקציה Phase 1	show crypto isakmp sa
ורפיקציה Phase 2 (מונים)	show crypto ipsec sa

8.10 תרגילים לתלמידים

תרגיל 1 – מתאים לאיזה VPN?

לכל תרחיש: Site-to-Site או Remote Access ו-IPsec או SSL.

א. חיבור קבוע בין 3 סניפים. ב. עובד שמתחבר מבית קפה מהלפטופ. ג. ספק חיצוני שצריך לגשת לאפליקציית web אחת ממחשב לא מנוהל. ד. שרתי שני מוקדי נתונים שצריכים להעביר גיבויים.

א. Site-to-Site / IPsec ב. Remote Access / IPsec ג. Remote Access / SSL (AnyConnect) ד. SSL clientless Site-to-Site / IPsec

תרגיל 2 – AH או ESP?

א. צריך גם הצפנה. ב. הצדדים מאחורי NAT. ג. רוצים רק לוודא שהחבילה לא שונתה בלי להצפין. מה נבחר בכל מקרה, ולמה בפועל תמיד ESP?

א. ESP (רק הוא מצפין). ב. AH (ESP נשבר עם NAT). ג. תיאורטית AH, אבל בפועל ESP במצב authentication-only תמיד ESP כי AH לא מצפין ולא עובד עם NAT.

תרגיל 3 – זהו את התקלה

המנהל הגדיר IPsec, show crypto isakmp sa מראה QM_IDLE, אבל ping בין הרשתות נכשל ו-0 encrypted. show crypto ipsec sa מראה מה כנראה הבעיה?

Phase 1 הצליח (יש ISAKMP SA), אבל Phase 2 לא מעביר תעבורה: כנראה ה-ACL המעניין לא תואם/לא הפוך בין הצדדים, או ש-NAT מתרגם את התעבורה לפני ההצפנה. בודקים match address ו-NAT exemption.

תרגיל 4 – מיפוי לפרק 7

בקונפיג: aes 256, encryption sha, hash sha, group 14, authentication pre-share. לכל אחד – איזו מטרת CIA/תפקיד הוא ממלא ואיזה מושג מפרק 7 הוא?

aes 256 → סודיות (סימטרי). sha → שלמות group 14 (HMAC). → החלפת מפתחות (Diffie-Hellman).

8.11 שאלות בסגנון בגרות

שאלה 1

איזה סוג תקשורת נועדה חבילת הפרוטוקולים IPsec לאבטח? SSH / TCP/IP / TELNET / UDP
TCP/IP (שכבה 3 - ולכן כל התעבורה מעליו).

שאלה 2

מהו ההבדל בין AH ל-ESP, ומדוע בפועל משתמשים ב-ESP?
AH - שלמות ואימות בלבד, ללא הצפנה. ESP - שלמות, אימות והצפנה. משתמשים ב-ESP כי רק הוא נותן סודיות, וגם עובד עם NAT.

שאלה 3

מה תפקיד Phase 1 IKE לעומת Phase 2?
Phase 1 - בונה ערוץ ניהול מאובטח (ISAKMP SA): DH, אימות הצדדים, הסכמה על מדיניות. Phase 2 - בונה בתוכו את מנהרות הנתונים (IPsec SA) שדרךן עוברת התעבורה.

שאלה 4

מדוע GRE לבדו אינו מספיק לחיבור מאובטח בין סניפים, וכיצד פותרים?
GRE עוטף אך אינו מצפין - התעבורה גלויה. פתרון: GRE over IPsec (GRE לגמישות - multicast/routing), IPsec (להצפנה).

שאלה 5

מתי נעדיף SSL VPN על פני IPsec VPN?
גישה מרחוק ממחשב לא מנוהל / דרך דפדפן בלבד (clientless), וכשצריך לעבור חומות אש/NAT בקלות - SSL על 443 עובר כמעט תמיד.

שאלה 6

השלימו את הפקודה שמגדירה transform set עם AES ו-SHA: crypto ipsec transform-set _____ TSET _____
esp-aes esp-sha-hmac

8.12 מעבדה (3 שעות) - IPsec Site-to-Site ב-Packet Tracer

- טופולוגיה: LAN1 (10.1.1.0/24) — R1 — "אינטרנט" (R-ISP) — R2 — LAN2 (10.2.2.0/24) ודאו ניתוב מקצה לקצה (ping) עובר לפני. VPN).
- ב-R1 ו-R2 הגדירו את 5 השלבים מ-8.6. (במראה). PSK זהה, מדיניות זהה, ACL הפוך.
- מ-PC ב-LAN1 עשו ping ל-PC ב-LAN2 - יופעל "interesting traffic".
- show crypto isakmp sa ⇒ show crypto ipsec sa QM_IDLE ⇒ מונים עולים.
- ב-Simulation mode לכדו חבילה על קו ה"אינטרנט" - ראו שהיא ESP ולא ניתן לקרוא את התוכן.
- GRE (אופציונלי): הקימו מנהרת GRE והריצו OSPF דרכה; ראו ש-multicast של OSPF עובר - מה שלא היה עובד ב-IPsec לבדו.

בנק שאלות שתלמידים שואלים – ותשובות מוכנות

שאלות נפוצות בפרק ה-VPN, עם תשובות מוכנות.

ש: "מה ההבדל בין ה-VPN שאנחנו לומדים ל-VPN מסחרי כמו NordVPN?"
ת: VPN מסחרי נועד להסתיר את הזהות/המיקום שלכם ולעקוף חסימות. VPN ינוגרא (מה שאנחנו לומדים) מחבר בבטחה עובד או סניף אל רשת החברה. אותה טכנולוגיית מנהרה מוצפנת, מטרות שונות.

ש: "אם GRE יוצר מנהרה, למה הוא לא מספיק לחיבור מאובטח?"
ת: כי GRE רק פטוע את החבילה – הוא לא מצפין כלום. כל מי שמאזין בדרך רואה את התוכן. לכן משלבים "GRE: GRE over IPsec" נותן גמישות (מעביר multicast/ניתוב), IPsec נותן את ההצפנה.

ש: "IPsec מצפין – אז מה זה AH ו-ESP?"
ת: שני "אופנים" של IPsec. AH נותן שלמות ואימות בלבד – הנפצה ילב. ESP נותן שלמות, אימות הנפצה סגור. בפועל תמיד משתמשים ב-ESP (רק הוא מצפין, וגם עובד עם NAT).

ש: "למה IKE עובד בשני שלבים? זה נשמע מסובך."
ת: Phase 1 בונה קודם חטבואמ לוהינ פורע אחד (מבצע Diffie-Hellman ומאמת את הצדדים). רק בתוך הערוץ המוגן הזה, Phase 2 בונה את מנהרות הנתונים בפועל. זה כמו קודם לבנות חדר סגור, ואז לנהל בו את המשא-ומתן.

ש: "איך אני יודע שהמנהרה באמת עובדת ולא שה-ping סתם עובר רגיל?"
ת: show crypto ipsec sa – מסתכלים על המונים encrypt/decrypt #pkts. אם הם עולים כששולחים תעבורה, היא באמת עוברת מוצפנת. אם ה-ping עובר אבל המונים 0 – התעבורה עוברת פוחמ למנהרה (בעיה ב-ACL המעניין או ב-NAT).

ש: "מתי עדיף SSL VPN על IPsec?"
ת: כשצריך גישה מרחוק ממחשב להונמ אל או דרך דפדפן בלבד (clientless), וכשרוצים מעבר קל דרך חומות אש – SSL רץ על פורט 443 שכמעט תמיד פתוח. IPsec מתאים יותר לחיבורים קבועים (סניף לסניף).

ש: "המנהרה קמה (QM_IDLE) אבל ה-ping נכשל. מה קורה?"
ת: Phase 1 הצליח (יש ISAKMP SA) אבל Phase 2 לא מעביר תעבורה. הסיבות הנפוצות: ה-"ACL המעניין" לא רופה בין שני הצדדים, או ש-NAT מתרגם את התעבורה לפני ההצפנה. בודקים match address ופטור NAT-מ.

ש: "כל מה שהגדרתי ב-IPsec נראה נכון אבל המנהרה לא קמה בכלל. מה לבדוק?"
ת: מדיניות Phase 1 חייבת להיות ההז בשני הצדדים (encryption/hash/DH group/authentication) וגם ה-PSK זהה. אי-התאמה של אחד מהם מונעת מהמנהרה לקום. בודקים עם show crypto isakmp sa וdebug crypto isakmp-1.

מילון מונחים – הגדרות

הגדרות תמציתיות של המונחים המרכזיים בפרק. שימושי גם כדף עזר לבחינה.

מונח	הגדרה
VPN	רשת פרטית וירטואלית – מנהרה מוצפנת דרך רשת ציבורית.
Site-to-Site	VPN בין שני שערים (סניפים), שקוף למשתמשים.
Remote Access	VPN של משתמש יחיד (עובד מהבית) אל שער החברה.
GRE	פרוטוקול מנהור שעוטף חבילות (כולל multicast) – אך אינו מצפין.
IPsec	מסגרת פרוטוקולים לאבטחת תעבורה בשכבה 3 (TCP/IP).
AH	פרוטוקול IPsec: שלמות ואימות בלבד – ללא הצפנה.
ESP	פרוטוקול IPsec: שלמות, אימות והצפנה; הבחירה המקובלת.
Transport / Tunnel mode	IPsec בין מארחים (transport) או בין שערים עם עטיפה (tunnel).

מונח	הגדרה
IKE	פרוטוקול שמקים את מנהרת ה-IPsec (מבצע DH ואימות).
Phase 1 / Phase 2	IKE: בונה ערוץ ניהול מאובטח (1) ואז את מנהרות הנתונים. (2)
SA (Security Association)	הסכם חד-כיווני המגדיר איך לאבטח זרם תעבורה, עם מזהה SPI.
PSK (Pre-Shared Key)	מפתח משותף מראש לאימות הצדדים ב-IKE (חלופה לתעודות).
Transform set	צירוף אלגוריתמי ההגנה של Phase 2 (למשל esp-aes esp-sha-hmac).
Crypto map	אובייקט שמקשר peer, transform set ו-ACL 'מעניין', ומוחל על ממשק.
interesting traffic	התעבורה (מוגדרת ב-ACL שאמורה לעבור במנהרה המוצפנת).
SSL/TLS VPN	VPN מעל 443 TCP; לרוב clientless (דרך דפדפן); עובר חומות אש בקלות.
Cisco ASA	מכשיר אבטחה המשלב חומת אש, VPN ו-IPS.

פרק 9 – ניהול אבטחת רשת מתקדם

11 שעות עיוני + 3 מעשי · שבועות 27–29

מטרות: עיצוב רשת מאובטחת · ניתוח פגיעות · ניהול סיכונים · הגנה עצמית · Nessus/Nmap
בבגרות: בקורות מנהלי/פיזי/לוגי, Nmap, אתיקה וחוק

לפני שמתחילים – מהניהול הטכני לניהול הארגוני (למי שאין רקע)

עד כה למדנו **סילב** (חומת אש, הצפנה, VPN פרק זה עוסק בלוחי – ההחלטות והנהלים סביב הכלים: **סיכון** (Risk) – ההסתברות שמשהו רע יקרה, כפול הנזק. אבטחה = ניהול סיכונים, לא ביטולם המוחלט (שבלתי אפשרי). **מדיניות** (Policy) – מסמך שקובע מה מותר ומה אסור בארגון (למשל "אסור להתחבר לרשת הארגון מ-Wi-Fi ציבורי"). **בקרה** (Control) – כל אמצעי שמקטין סיכון. יש שלושה סוגים: **מנהלית** (נהלים), **פיזית** (מנעולים), **לוגית** (סיסמאות, הצפנה). **גיבוי** (Backup) – עותק של המידע שנשמר בנפרד, כדי לשחזר אחרי תקלה/מתקפה. **בדיקת חדירה** (Penetration Test) – לשכור "האקר טוב" שינסה לפרוץ בכוונה, כדי למצוא חולשות לפני שהרעים ימצאו. **הרעיון:** הפרק מחבר את כל הקורס – איך משלבים את כל הכלים לכדי תוכנית אבטחה שלמה לארגון, ומה החוק והאתיקה דורשים.

9.1 מהניתוק הטכני לתמונה הניהולית

שמונת הפרקים הקודמים היו על כלים (ACL, IPS, VPN...). פרק 9 הוא על המערכת הניהולית שמחליטה איזה כלי, איפה, וכמה – כי אבטחה מושלמת עולה אינסוף, ואבטחה אפסית עולה בפריצה. זהו איזון של סיכון מול עלות. זה גם הפרק שקושר את הקורס לעולם המקצועי (SOC, CISO), ביקורת, חוק.

9.2 ניהול סיכונים (Risk Management)

הנוסחה

סיכון = איום × פגיעות × ערך הנכס. אם אחד מהם אפס – אין סיכון. אי אפשר לבטל איומים (הם קיימים), אבל אפשר להקטין פגיעות (בקורות) ולהקטין את ההשפעה.

תהליך ניהול הסיכונים

1. **זיהוי נכסים** – מה יש לנו ומה ערכו (מידע, שרתים, מוניטין).
2. **הערכת איומים ופגיעויות** – מה עלול לקרות (סריקות, ראיונות, בדיקות). 9.5.
3. **ניתוח סיכונים** – **כמותי** (בכסף: $SLE = ALE \times ARO$ – ההפסד השנתי הצפוי) או **איכותי** (מטריצה גבוה/בינוני/נמוך).
4. **טיפול בסיכון** – ראו להלן.
5. **ניטור וחזרה** – סיכון משתנה עם הזמן.

ארבע דרכי טיפול בסיכון (נושא מרכזי)

אסטרטגיה	משמעות	דוגמה
הפחתה / הימנעות (Mitigate/Avoid)	בקורות שמקטינות סיכון, או הפסקת הפעילות המסוכנת	התקנת IPS; הפסקת שירות ישן ופגיע
העברה (Transfer)	מעבירים את הנטל לגורם אחר	ביטוח סייבר; מיקור חוץ לענן
קבלה (Accept)	הסיכון נמוך/עלות הטיפול גבוהה – חיים איתו במודע	לא מצפינים מסך פנימי בעל ערך נמוך
בידוד (Isolation)	מפרידים את המערכת המסוכנת	רשת נפרדת למערכת legacy; DMZ; air-gap

9.3 עקרונות עיצוב רשת מאובטחת

- **הגנה לעומק** (Defense in Depth) – שכבות עצמאיות; כשל באחת לא מפיל הכול.
- **מינימום הרשאות** (Least Privilege) – כל אחד מקבל בדיוק מה שצריך, לא יותר.
- **הפרדת תפקידים** (Separation of Duties) – פעולה קריטית דורשת שני אנשים; מי שמאשר תשלום ≠ מי שמבצע. מונע הונאה פנימית.
- **סבב תפקידים** (Job Rotation) – חושף הונאות, מפחית תלות באדם יחיד.
- **Fail-Secure** – במקרה כשל, ברירת המחדל היא לחסום. (deny by default).
- **Zero Trust** – "לעולם אל תסמוך, תמיד תאמת"; אין "פנים מהימן".
- **KISS / פשטות** – מערכת מורכבת קשה לאבטח; מורכבות היא אויב האבטחה.
- **מגוון הגנות** (Diversity) – ספקים שונים בשכבות שונות, כדי שחולשה אחת לא תפיל הכול.

בבגרות (שאלה 6) – שלוש קטגוריות בקרה

מנהלית: כתיבת מדיניות, הנחיות, נהלים, תקנים, איסור עבודה ב-Zoom מרשת לא מאובטחת.
פיזית: הגנה על חדר שרתים וארונות תקשורת.
לוגית: שימוש ברשימות גישה, סיסמאות, מערכות למניעת גישה.

חלוקה משלימה לפי מתי הבקרה פועלת: **מונעת** (Preventive) – מנעול, הצפנה, **מגלה** (Detective) – IDS, מצלמה, לוג, **מתקנת** (Corrective) – גיבוי, (patch, **מרתיעה** (Deterrent) – שלט אזהרה, **משחזרת** (Recov-DRP). – ery

9.4 מדיניות, נהלים ותקנים

מדיניות (Policy)	מסמך-על: מה ולמה. "כל גישה מרחוק דרך VPN"
תקן (Standard)	חובה מדידה: "סיסמה ≥ 12 תווים, MFA"
הנחיה (Guideline)	המלצה גמישה.
נוהל (Procedure)	צעד-אחר-צעד: איך מגדירים VPN

מסמכים חשובים: **AUP** (Acceptable Use Policy) – מה מותר לעובד לעשות עם הציוד, מדיניות סיסמאות, מדיניות גיבוי, מדיניות תגובה לאירועים, סיווג מידע (סודי/פנימי/ציבורי).

9.5 בדיקות אבטחה: הערכה, סריקה ובדיקת חדירה

סוג בדיקה	מה זה
Security Audit	בדיקת עמידה במדיניות/תקן (ISO 27001) – מסמכים ותצורות
Vulnerability Assessment	סריקה אוטומטית לזיהוי פגיעויות ידועות (Nessus)
Penetration Test	ניסיון פריצה מבוקר – "לחשוב כמו תוקף" ולהוכיח ניצול
(Security Test & Evaluation) ST&E	בדיקה שיטתית שהבקורות עובדות כמתוכנן (מוזכר בתכנית)

סוגי pentest

Black box (התוקף לא יודע כלום – כמו תוקף חיצוני), **White box** (יודע הכול – יעיל, מהיר), **Gray box** (ידע חלקי – כמו עובד/משתמש). שלבים: תכנון והרשאה → סיור → סריקה → ניצול → דוח.

חובה: אישור בכתב (Scope & Authorization)

בדיקת חדירה ללא אישור כתוב = עבירה פלילית. חייבים: היקף מוגדר (אילו כתובות), חלון זמן, "get out of jail" letter, ואיש קשר. זה גם מה שמלמדים לתלמידים לגבי הכלים בהמשך.

9.6 כלי סריקת פגיעויות (נשאל בבגרות)

כלי	מה עושה
Nmap (Network Mapper)	גילוי, ניתוח ובקרה ברשתות תקשורת: מיפוי מארחים חיים, סריקת פורטים פתוחים, זיהוי שירותים וגרסאות (-sV, זיהוי מערכת הפעלה (-O). זו התשובה בבגרות. Zenmap = ה-GUI.
Nessus	סורק פגיעויות: מריץ אלפי בדיקות מול מארח ומדווח על חולשות ידועות (CVE) עם דירוג חומרה והמלצות תיקון. (התכנית כותבת "NESUS").
SuperScan	סורק פורטים ותיקוני TCP/UDP למערכות Windows (ישן; מוזכר בתכנית).
OpenVAS	חלופה חינמית ל-Nessus
Wireshark	ניתוח תעבורה (packet analyzer)
Metasploit	מסגרת לניצול פגיעויות (בדיקות חדירה)
Kali Linux	הפצת לינוקס עם כלי הבדיקה מותקנים

! דוגמאות Nmap (רק ברשת מעבדה מבודדת ובאישור!)
 # אילו מארחים חיים ואילו פורטים nmap 192.168.1.0/24
 # גרסאות שירותים nmap -sV 192.168.1.10
 # ניחוש מערכת הפעלה nmap -O 192.168.1.10
 # SYN scan nmap -sS -p 1-1000 192.168.1.10

סיפור מהחיים: Equifax – פגיעות אחת שלא תוקנה (2017)

דליפת המידע של Equifax חשפה נתונים של 147 מיליון אמריקאים (מספרי ביטוח לאומי, תאריכי לידה). הסיבה: פגיעות ידועה ב-Apache Struts (CVE-2017-5638) עם תיקון זמין חודשיים קודם. סורק פגיעויות היה מוצא אותה תוך דקות – אבל התהליך של Equifax לא סרק את השרת הזה. הלקח: ניהול פגיעויות הוא לא אירוע חד-פעמי אלא תהליך מתמשך (scan → prioritize → patch → verify). זה הלב של פרק 9.

9.7 הגנה עצמית ותגובה לאירועים

"מערכות הגנה עצמית" בתכנית: היכולת של הרשת לזהות ולהגיב אוטומטית. סיסקו קראה לזה Self-SDN (Defending Network) בעבר – שילוב IPS, NAC, קורלציה ותגובה אוטומטית (בידוד מחשב נגוע). היום: SOAR (Security Orchestration, Automation and Response) ו-XDR.

Incident Response – 6 שלבים (SANS/NIST)



הכנה (נהלים, כלים) → זיהוי (SIEM, IDS) → בלימה (ניתוק מהרשת) → מיגור (הסרת הנוזקה) → שחזור (החזרה לפעילות) → הפקת לקחים. הצוות: CSIRT/CERT.

9.8 המשכיות עסקית והתאוששות מאסון

	BCP (Business Continuity Plan)	DRP (Disaster Recovery Plan)
מטרה	שהעסק ימשיך לתפקד בזמן אסון	שחזור מערכות ה-IT אחרי אסון
היקף	כל העסק (אנשים, תהליכים, מבנים)	טכנולוגי (שרתים, נתונים)

BIA (Business Impact Analysis) מזהה תהליכים קריטיים ומגדיר שני יעדים: RTO (Recovery Time Objective) – כמה זמן מותר להיות מושבתים) ו-RPO (Recovery Point Objective) – כמה נתונים מותר לאבד = תדירות הגיבוי). (Worst Case Scenario WCS) – בתכנית) = תכנון לתרחיש הגרוע ביותר.

גיבויים ואתרי גיבוי

- **כלל 1-2-3:** 3 עותקים, 2 מדיות שונות, 1 מחוץ לאתר. (off-site) קריטי נגד כופרה.
- סוגים: מלא (Full), הפרשי (Differential), משלים. (Incremental).
- אתרי גיבוי: Hot site (פעיל, מידי, יקר), Warm site (חלקי), Cold site (מבנה ריק, זול, איטי).
- **בדיקת גיבוי** – גיבוי שלא נבדק שחזור ממנו = לא גיבוי. תרגלו שחזור!

SDLC 9.9 – פיתוח מאובטח

SDLC (Software/System Development Life Cycle) – מחזור חיי פיתוח מערכת. אבטחה חייבת להיכנס **מההתחלה** ("Security by Design", לא כטלאי בסוף – זול ויעיל פי כמה. שלבים: תכנון → ניתוח דרישות → עיצוב → מימוש → בדיקות → הטמעה → תחזוקה (זזה חוזר במעגל). התכנית מציינת "תוכנית מערך" SDLC ו"תחזוקה ותפעול". SDLC.

ב-DevSecOps משלבים בדיקות אבטחה אוטומטיות בכל commit. עקרונות קוד מאובטח: בדיקת קלט (נגד injection ו-buffer overflow – פרק 1, least privilege), ניהול סודות נכון, עדכון ספריות. (Log4Shell)

9.10 אבטחת מערכות מגוונות ושילוב גורמים

- **מייל** – ESA/anti-spam, SPF/DKIM/DMARC (נגד זיוף שולח – פרק 1 phishing).
- **טלפוניה** (VoIP) – SRTP, voice VLAN (פרק 6).
- **אפליקציות** – WAF, OWASP Top 10.
- **אלחוט** – WPA3-Enterprise, WIPS (פרק 6).
- **שילוב גורמים** – לקוחות, שותפים, עובדים: לכל אחד רמת גישה ומדיניות (least privilege), פילוח).
- ניהול מרכזי וחלוקת תפקידים (SOC, NOC), הפרדת תפקידים).

9.11 אתיקה, חוק ואחריות מקצועית

חובה ללמד – זו לא רק "המלצה"

בישראל: **חוק המחשבים, התשנ"ה-1995** אוסר חדירה לחומר מחשב שלא כדין (סעיף 4) – עד 3 שנות מאסר; שיבוש/הפרעה – עד 5 שנים. **חוק הגנת הפרטיות** ותקנות אבטחת מידע (2017) מחייבים ארגונים. באירופה: GDPR (קנסות עד 4% מהמחזור). הבהירו לתלמידים: הרצת Nmap או כלי פריצה על רשת שאינה שלכם וללא אישור בכתב – עבירה פלילית, גם "רק כדי לבדוק".

- **Hacker אתי** (White hat) פועל תמיד עם אישור והיקף מוגדר.
- קודים אתיים מקצועיים: (ISC)², EC-Council.
- Responsible/Coordinated Disclosure – מצאתם פגיעות? מדווחים ליצרן ונותנים זמן לתקן לפני פרסום.
- דילמות: פרטיות מול ניטור עובדים; חשיפת פגיעות מול ניצולה.

9.12 תרגילים לתלמידים

תרגיל 1 – סיווג בקרות

סווגו כל בקרה (מנהלית/פיזית/לוגית) וגם (מונעת/מגלה/מתקנת):
א. מצלמת אבטחה בכניסה. ב. נוהל גיבוי יומי. ג. חומת אש. ד. הדרכת מודעות לעובדים. ה. גיבוי ששוחזר

אחרי כופרה. ו. מנעול ביומטרי לחדר שרתים.

א. פיזית/מגלה ב. מנהלית/מתקנת (מכונה לשחזור) ג. לוגית/מונעת ד. מנהלית/מונעת ה. לוגית או מנהלית/מתקנת (recovery) ו. פיזית/מונעת

תרגיל 2 – טיפול בסיכון

לכל מצב בחרו: הפחתה / העברה / קבלה / בידוד.

א. שרת ישן הכרחי שאי אפשר לעדכן. ב. רכשו ביטוח סייבר. ג. סיכון נמוך של הדפסה בזבזנית – מתעלמים.
ד. מתקנים IPS מול האינטרנט.

א. בידוד (רשת נפרדת) ב. העברה ג. קבלה ד. הפחתה

תרגיל 3 – RTO/RPO

חנות אונליין מגבה כל 6 שעות ולוקח לה 2 שעות לשחזור. אירע כשל ב-13:00, הגיבוי האחרון ב-12:00. א. כמה נתונים אבדו (RPO) בפועל? ב. מתי חוזרים לפעול (RTO)? ג. אם החברה דורשת RPO של שעה – מה משנים?

א. שעה (12:00)–(13:00). ב. 2~15:00 שעות (שחזור). ג. מגבים כל שעה (או רפליקציה רציפה) כדי לצמצם את חלון האובדן.

תרגיל 4 – דיון אתי

תלמיד גילה שאתר בית הספר חושף ציונים דרך שינוי כתובת ב-URL מה עליו לעשות (ומה אסור)? נמקו לפי חוק המחשבים.

מותר/ראוי: לדווח למורה/מנהל הרשת מיד, לתעד בלי לגשת לנתונים של אחרים. אסור: להוריד/לשנות ציונים, לשטף, "לבדוק עד כמה זה גרוע" בגישה נרחבת – זו חדירה לחומר מחשב שלא כדין. Responsible disclosure.

תרגיל 5 – פרויקט מסכם

בחרו ארגון דמיוני (מרפאה / חנות / בית ספר). כתבו מסמך של עמוד: 3 נכסים קריטיים, איום ופגיעות לכל אחד, ובקרה מכל פרק בקורס שתגן עליו. (זה מחבר את כל 9 הפרקים.)

דוגמה למרפאה: נכס=תיקים רפואיים → הצפנה (3) AAA+(4) ACL+(7); נכס=זמינות מערכת → IPS (5)+גיבוי/storm control (6)+(9) DRP; נכס=גישה מרחוק של רופאים → (3) MFA+(8) VPN+נתב מוקשח. (2) מודעות עובדים נגד. (1) phishing

9.13 שאלות בסגנון בגרות

שאלה 1

התאימו אמצעי אבטחה (מנהלי/פיזי/לוגי) לתיאור: (1) הגנה על חדר שרתים; (2) כתיבת מדיניות ונהלים; (3) שימוש ברשימות גישה וסיסמאות.

(1) פיזי (2) מנהלי (3) לוגי

שאלה 2

מה מאפשרת תוכנת Nmap? 1. זיהוי וירוסים. 2. זיהוי סוסים טרויאנים. 3. גילוי, ניתוח ובקרה ברשתות תקשורת. 4. חסימת פורטים

3 – גילוי מארחים, סריקת פורטים וזיהוי שירותים. אינה אנטי-וירוס ואינה חוסמת.

שאלה 3

מהן ארבע הדרכים לטיפול בסיכון? תנו דוגמה לכל אחת.
הפחתה (IPS), העברה (ביטוח), קבלה (חיים עם סיכון נמוך), בידוד/הימנעות (רשת נפרדת/הפסקת שירות).

שאלה 4

מה ההבדל בין BCP ל-DRP?

BCP – המשכיות תפקוד כלל העסק בזמן אסון (אנשים, תהליכים).
DRP – שחזור מערכות ה-IT והנתונים.

שאלה 5

עובד הריץ Nmap על רשת חברה מתחרה "כדי לבדוק". האם זו עבירה? נמקו.

כן – סריקה של רשת שאינה שלו וללא אישור מהווה ניסיון חדירה/גישה לפי חוק המחשבים התשנ"ה-1995.
גם "רק בדיקה" אסורה ללא היקף ואישור בכתב.

שאלה 6

מדוע עדיף לשלב אבטחה כבר בשלב העיצוב של SDLC ולא בסוף?

תיקון פגיעות בשלב מוקדם זול ויעיל בהרבה; "Security by Design" מונע פגמים מבניים שקשה וריקם לתקן במערכת גמורה.

9.14 (מעבדה 3) שעות

1. Nmap **במעבדה מבודדת בלבד** (רשת סגורה, לא רשת בית הספר, באישור): מפו מארחים, סרקו פורטים, זהו שירותים וגרסאות. דונו בכל פלט: מה תוקף לומד ומה מגן לומד.
2. סרקו VM עם שירות ישן; זהו פורט/גרסה פגיעים; הציעו טיפול (patch)/כיבוי/ACL – מדגים את מעגל ניהול הפגיעויות.
3. **תכנון (על נייר)**: קבלו טופולוגיה של ארגון וסמנו את כל הבקורות מ-9 הפרקים במקומן (נתב מוקשח, AAA, IPS, ACL/ZPF, מתג מאובטח, VPN, גיבוי).
4. **סימולציית אירוע**: "מחשב עובד נדבק בכופרה" – עברו בכיתה את 6 שלבי ה-Incident Response.
5. **פרויקט מסכם** (תרגיל 5) כמצגת קבוצתית – חזרה מצוינת לבגרות.

בנק שאלות שתלמידים שואלים – ותשובות מוכנות

שאלות נפוצות בפרק ניהול האבטחה, עם תשובות מוכנות.

ש: "אם יש לנו את כל הכלים (חומת אש, IPS, VPN), למה בכלל צריך 'ניהול'?"

ת: כי כלים בלי מדיניות ותהליך לא מספיקים. מי מחליט מה לחסום? מי בודק שהגיבוי עובד? מה עושים כשקורה אירוע? אבטחה היא תהליך ניהולי מתמשך, לא מוצר שקונים פעם אחת.

ש: "אפשר להגיע לאבטחה מושלמת (100%)?"

ת: לא, וזו לא המטרה. אבטחה מושלמת עולה אינסוף ומשתקת עבודה. המטרה היא מינוכיס לווהינ: להשקיע היכן שהסיכון (הסתברות x נזק) הכי גבוה, ולקבל סיכונים קטנים במודע.

ש: "מה ההבדל בין בקרה מנהלית, פיזית ולוגית?"

ת: **מנהלית** = מדיניות, נהלים, הדרכות (מה שאנשים עושים). **פיזית** = מנעולים, מצלמות, חדר שרתים נעול (הגנה על החומרה). **לוגית/טכנית** = סיסמאות, הצפנה, חומת אש, ACL (הגנה בתוכנה). שאלה נפוצה בבגרות.

ש: "מה מאפשרת תוכנת Nmap? האם היא כלי תקיפה או הגנה?"

ת: Nmap מגלה מארחים חיים, סורק פורטים פתוחים ומזהה שירותים/גרסאות. היא תישומיש-וד: תוקף משתמש בה לסיור (פרק 1), ומגן משתמש בה כדי לגלות מה חשוף ברשת שלו לפני שהתוקף יעשה זאת. היא **אינה** אנטי-וירוס ואינה חוסמת פורטים.

ש: "מה ההבדל בין סריקת פגיעויות (Nessus) לבדיקת חדירה (pentest)?"
 ת: סורק פגיעויות (Nessus) הוא כלי יטמוטוא שמדווח על חולשות ידועות. בדיקת חדירה היא פדא שמנסה בפועל לנצל אותן ולפרוץ, "לחשוב כמו תוקף", ולהוכיח את הנזק. הסריקה מוצאת דלתות; ה-pentest בודק אילו באמת נפתחות.

ש: "מה ההבדל בין BCP ל-DRP?"
 ת: BCP (המשכיות עסקית) = איך העסק דקפתל רישממ בזמן אסון (אנשים, תהליכים, מבנים).
 (התאוששות מאסון) = איך IT-ה תוכרעמ תא סירזחשמ והנתונים. DRP הוא חלק טכני בתוך ה-BCP הרחב.

ש: "מהו כלל 3-2-1 לגיבויים?"
 ת: 3 עותקים של המידע, על 2 סוגי מדיה שונים, כשלפחות 1 נמצא רתאל פוחמ (off-site/ענן).
 זה קריטי נגד כופרה: אם המתקפה הצפינה את הרשת, יש עותק מנותק לשחזר ממנו. זכרו - יוביג וניא ונממ רוזחש קדבנ אלש יוביג.

ש: "תלמיד מצא חולשה באתר בית הספר. מה מותר לו לעשות?"
 ת: לדווח מיד למורה/מנהל הרשת, ולתעד בלי לגשת למידע של אחרים. רוסא להוריד/לשנות נתונים, לשתף, או "לבדוק עד כמה זה חמור" בגישה נרחבת - זו חדירה לחומר מחשב שלא כדין (חוק המחשבים, 1995). זה נקרא Responsible Disclosure.

ש: "למה לשלב אבטחה כבר בשלב התכנון (SDLC) ולא בסוף?"
 ת: כי תיקון חולשה שהתגלתה בסוף עולה פי כמה, ולפעמים דורש לבנות מחדש. "אבטחה מהעיצוב" (Security by Design) זולה ויעילה בהרבה מטלאי מאוחר.

מילון מונחים - הגדרות

הגדרות תמציתיות של המונחים המרכזיים בפרק. שימושי גם כדף עזר לבחינה.

מונח	הגדרה
ניהול סיכונים	תהליך זיהוי, הערכה וטיפול בסיכונים אבטחה.
סיכון (Risk)	= איום x פגיעות x ערך הנכס.
טיפול בסיכון	הפחתה, העברה (ביטוח), קבלה, או בידוד/הימנעות.
מדיניות (Policy)	מסמך הקובע מה מותר ואסור בארגון (לא איך).
נוהל (Procedure)	הוראות צעד-אחר-צעד ליישום המדיניות.
בקרה מנהלית	מדיניות, נהלים, הדרכות, בדיקות רקע.
בקרה פיזית	מנעולים, מצלמות, חדר שרתים נעול.
בקרה לוגית	סיסמאות, הצפנה, חומת אש, ACL.
הגנה לעומק (Defense in Depth)	שכבות הגנה עצמאיות; כשל באחת אינו מפיל הכול.
מינימום הרשאות	מתן בדיוק ההרשאות הנדרשות, לא יותר.
הפרדת תפקידים	פעולה קריטית דורשת שני אנשים; מונע הונאה.
Zero Trust	'לעולם אל תסמוך, תמיד אמת' - אין אזור פנימי מהימן.
Vulnerability Assessment	סריקה אוטומטית לזיהוי פגיעויות ידועות. (Nessus)
Penetration Test	ניסיון פריצה מבוקר, באישור, כדי לאתר חולשות.
Nmap	כלי לגילוי מארחים, סריקת פורטים וזיהוי שירותים.
Nessus	סורק פגיעויות המדווח על חולשות ידועות. (CVE)
ST&E	בדיקה שיטתית שהבקות עובדות כמתוכנן.
BCP	תוכנית המשכיות עסקית - שהעסק ימשיך לתפקד בזמן אסון.
DRP	תוכנית התאוששות מאסון - שחזור מערכות ה-IT והנתונים.
RTO / RPO	זמן ההשבתה המרבי המותר (RTO) וכמות הנתונים המרבית לאיבוד. (RPO)
כלל 3-2-1	3 עותקי גיבוי, 2 מדיות, 1 מחוץ לאתר.
SDLC	מחזור חיי פיתוח מערכת; משלבים אבטחה כבר בעיצוב.
חוק המחשבים התשנ"ה-1995	החוק האוסר חדירה ושיבוש של חומר מחשב שלא כדין.
